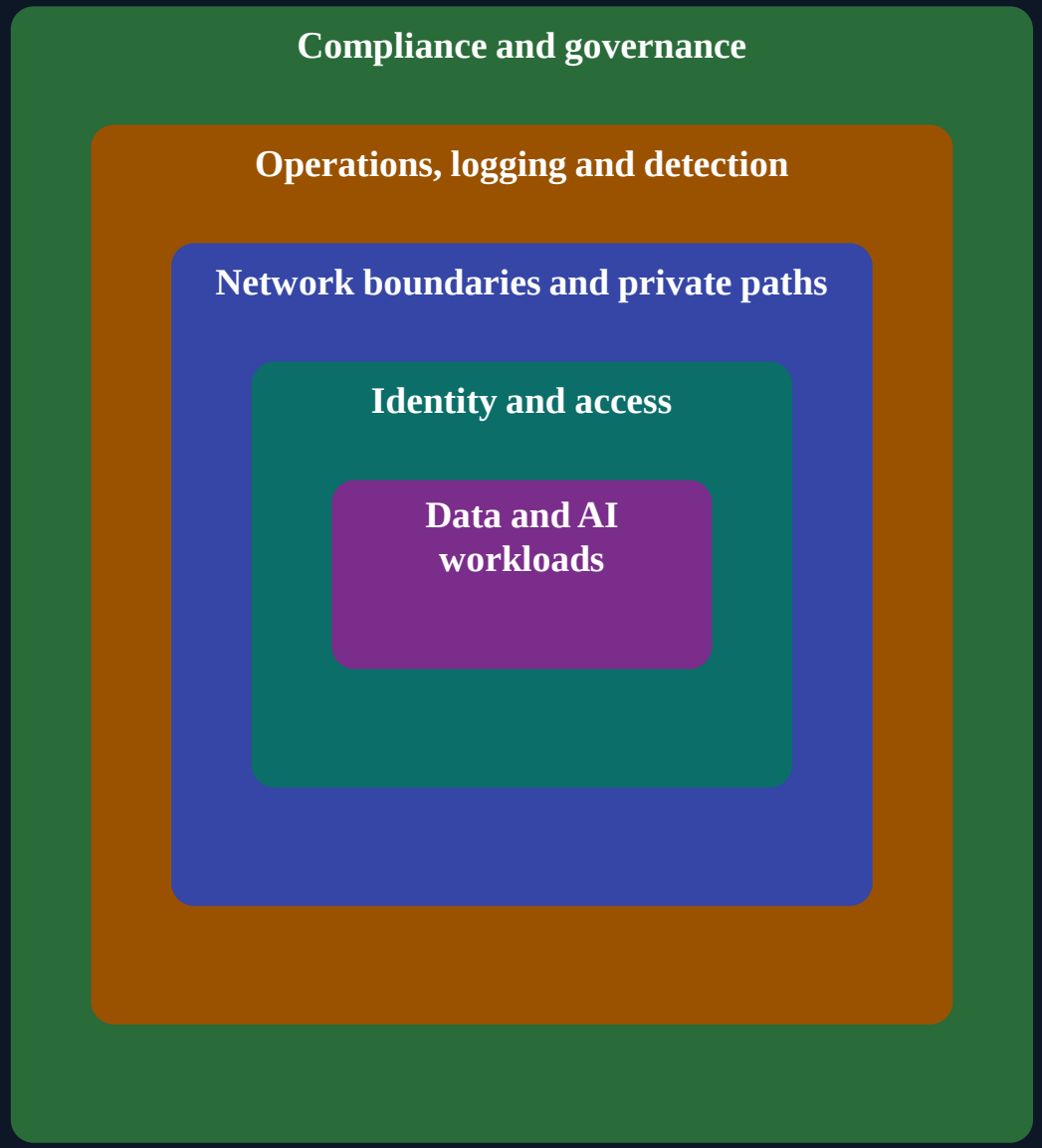
GOOGLE CLOUD CERTIFICATION

Professional Cloud Security Engineer

5
exam sections

76
case studies

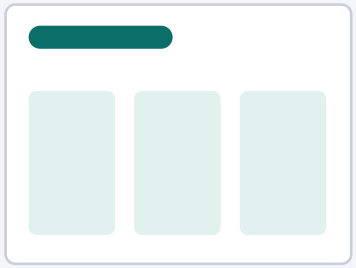


Defence in depth: each exam section is one ring of protection

ORIENTATION

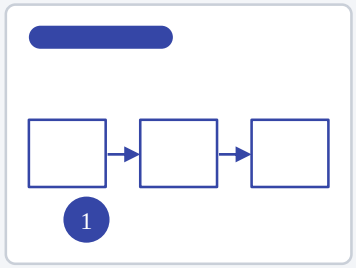
How to Use This Tutorial

Every exam objective follows the same rhythm, so you always know what kind of slide you are on and what to do with it.



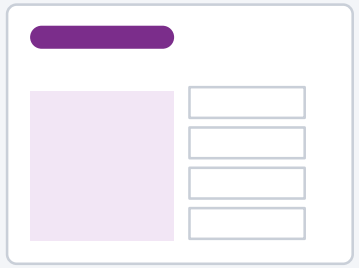
Concept

Plain language explanation of one idea, with the reason it exists and when it is the right tool.



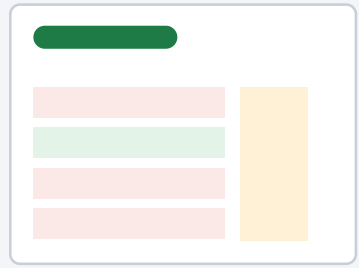
Diagram

Text box diagrams with numbered badges. Read the badge notes in order; they trace the request or the data.



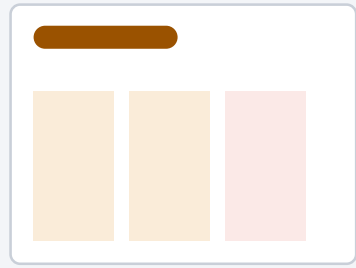
Case study

A Google style scenario with four options. Pause, choose, and commit before you move on.



Answer

Green row is correct, red rows are not. Each wrong option says exactly why it fails the scenario.



Recap

Must remember facts, keyword triggers, and the traps examiners plant in distractors.

ORIENTATION

Contents and Slide Map

0	Orientation: exam format, question anatomy, study plan	Slides 1 to 11
1	Section 1: Configuring access (16 case studies)	Slides 12 to 82
2	Section 2: Communications and boundaries (16 case studies)	Slides 83 to 143
3	Section 3: Data protection, including AI workloads (15 case studies)	Slides 144 to 200
4	Section 4: Managing operations (13 case studies)	Slides 201 to 251
5	Section 5: Supporting compliance (6 case studies)	Slides 252 to 273
6	Mixed mock exam (10 case studies) and answer key	Slides 274 to 295
7	Exam day strategy, cheat sheet, closing	Slides 296 to 298

ORIENTATION

The Exam at a Glance

Know the format before you study the content. Confirm the current details on the official registration page before you book.

2 hours

Exam length. Budget about two minutes per question and flag long ones.

50 to 60

Questions, mostly scenario based. No labs, no command typing.

2 formats

Multiple choice (one answer) and multiple select (the stem says how many).

2 years

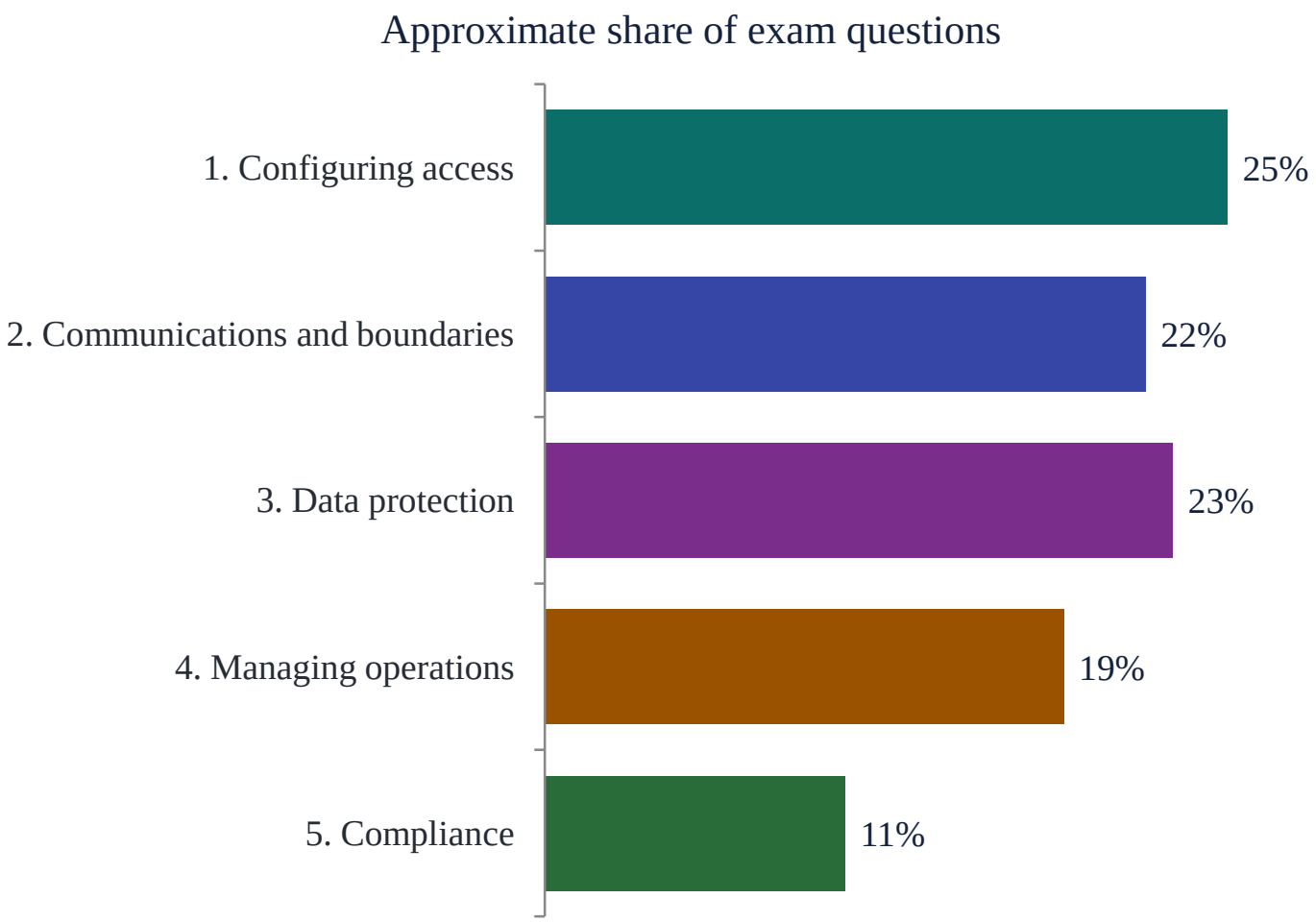
Certification validity. Recertify before it lapses.

What the exam really measures

Not memory of console clicks. It measures judgement: given a business situation with constraints, can you pick the Google Cloud control that meets the requirement with the least privilege, the least operational overhead and no gaps? Every case study in this deck trains that judgement.

ORIENTATION

The Blueprint: Where the Marks Are



Read the chart like a study budget

Sections 1 to 3 hold about 70% of the marks. Identity, networking and data protection deserve most of your hours.

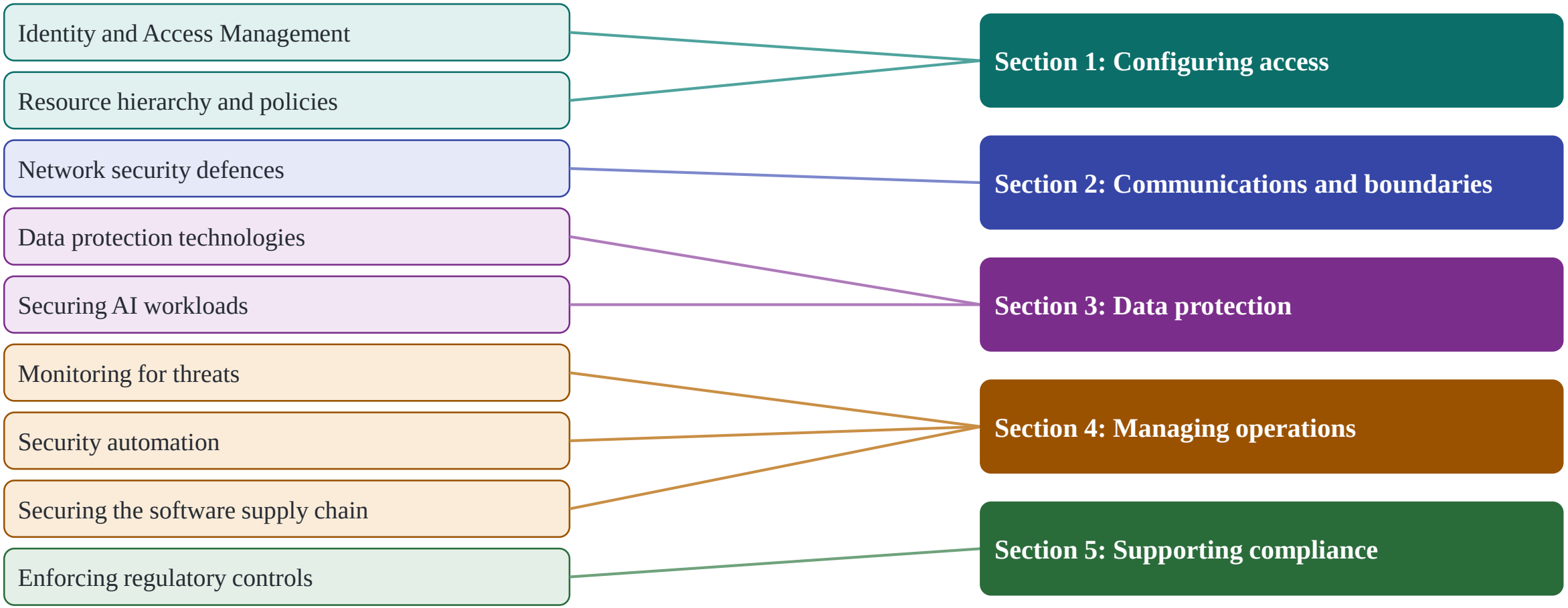
But do not skip Section 5

Compliance is only about 11%, yet its ideas (residency, Assured Workloads, Access Transparency) reappear inside questions from every other section.

ORIENTATION

What Google Expects a Security Engineer to Do

The official role description lists nine competencies. Each one lives in a specific exam section. Lines show where.



ORIENTATION

The Structure of a Google Style Case Study Question

1. A regional insurer runs its claims platform on Google Cloud and must meet a national data residency law.
2. Developers currently download service account keys to run batch jobs from on premises servers.
3. The security team wants to eliminate long lived keys with minimal changes to the batch scripts.
4. **What should you do?**
5. A. Rotate the keys every 30 days with a scheduled job.
   B. Configure Workload Identity Federation for the on premises jobs.
   C. Store the keys in Secret Manager.
   D. Grant the developers the Owner role.

1. **Context.** Industry and regulation hint at hidden requirements (residency, audit).
2. **Current state.** The anti pattern you must replace. Here: downloaded keys.
3. **Constraint words.** "Eliminate" and "minimal changes" rank the options for you.
4. **The ask.** "What should you do?" means the single best action, not every good idea.
5. **Distractors.** A and C manage keys; only B eliminates them. D breaks least privilege.

ORIENTATION

Decoding the Qualifier Words

Two options are usually both technically possible. The qualifier in the stem decides which one is best.

When the stem says...	Google usually wants...	Typical wrong answer
Least privilege	Narrowest predefined role, at the lowest resource level, granted to a group	Basic roles (Owner, Editor) or grants at the organization node
Minimal operational overhead	A managed service or organization policy instead of custom code	Cron jobs, scripts, self managed appliances
Prevent	A preventive control: org policy, IAM deny, VPC Service Controls	A detective control: alerts, logs, Security Command Center findings
Detect or investigate	Audit logs, Security Command Center, Log Analytics, flow logs	A preventive control that would not reveal what happened
Without changing application code	Infrastructure level control: proxy, IAP, VPC Service Controls, CMEK	Rewriting the app to call an API
Google recommended practice	The current feature (federation, uniform bucket access, Autokey)	The legacy approach (keys, ACLs, project wide SSH keys)

ORIENTATION

The Four Distractor Patterns

Learn to name why an option is wrong. Almost every wrong answer in this exam falls into one of these four families.

1 Right tool, wrong scope

Correct service applied at the wrong level: a firewall rule when the threat is data exfiltration through APIs; a project policy when the requirement covers the whole organization.

2 Works, but heavy

A custom script, a self managed VM, or a manual process that meets the goal with far more effort than a managed feature. Rejected whenever the stem mentions overhead or scale.

3 Detects instead of prevents

Alerting, logging or a dashboard when the requirement says "ensure" or "prevent". Logs record the breach; they do not stop it.

4 Legacy or insecure habit

Downloaded service account keys, basic roles, object ACLs, external IPs for admin access, secrets in metadata. Google steers away from all of them.

ORIENTATION

Course Map: Controls by Layer

Keep this picture in mind. Each case study is really asking which layer the threat lives in, then which control on that layer fits.

5 Compliance	Assured Workloads, Access Transparency, Access Approval, resource location policy, shared responsibility
4 Operations	Cloud Audit Logs, log sinks, Security Command Center, Binary Authorization, Artifact Analysis, VM Manager
3 Data and AI	Cloud KMS, CMEK, Cloud EKM, Sensitive Data Protection, Secret Manager, Confidential Computing, Model Armor
2 Network	Cloud NGFW, Cloud Armor, IAP, VPC Service Controls, Private Service Connect, Cloud NAT, HA VPN, Interconnect
1 Identity	Cloud Identity, SSO, Workforce and Workload Identity Federation, IAM, deny policies, PAM, org policies

ORIENTATION

A Six Week Study Plan

Hours follow the blueprint weights. Each week ends with the case studies for that section, done closed book.

1	2	3	4	5	6
Week 1	**Week 2**	**Week 3**	**Week 4**	**Week 5**	**Week 6**
Identity, Cloud Identity, service accounts, authentication	IAM, deny, PAM, hierarchy and org policies	Firewalls, Cloud Armor, VPC SC, private connectivity	Sensitive Data Protection, KMS, Confidential Computing, AI security	Supply chain, logging, Security Command Center	Compliance, then full mock exam twice

Daily habit: read one concept slide group, redraw its diagram from memory on paper, then answer its case studies without looking.

01

Configuring Access

Who is allowed in, how they prove it, and exactly what they may touch. The largest section of the exam and the foundation of every other control.

Exam weight: about 25% of questions

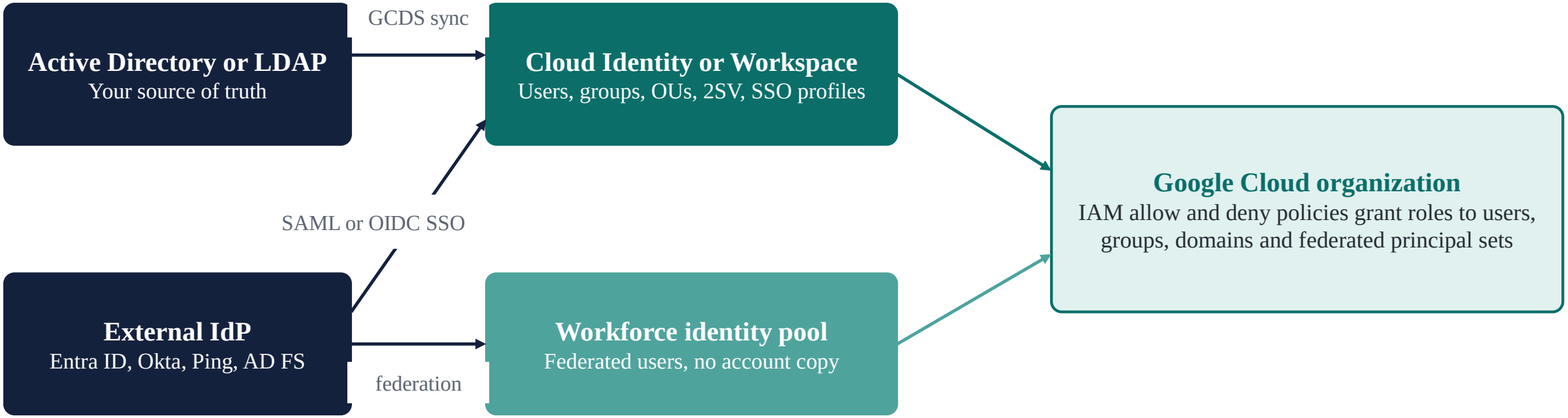


Bar scaled so that 30% would fill the track

- **1.1** Managing Cloud Identity
- **1.2** Managing service accounts
- **1.3** Managing authentication
- **1.4** Authorization controls
- **1.5** Defining the resource hierarchy

Where Google Cloud Identities Come From

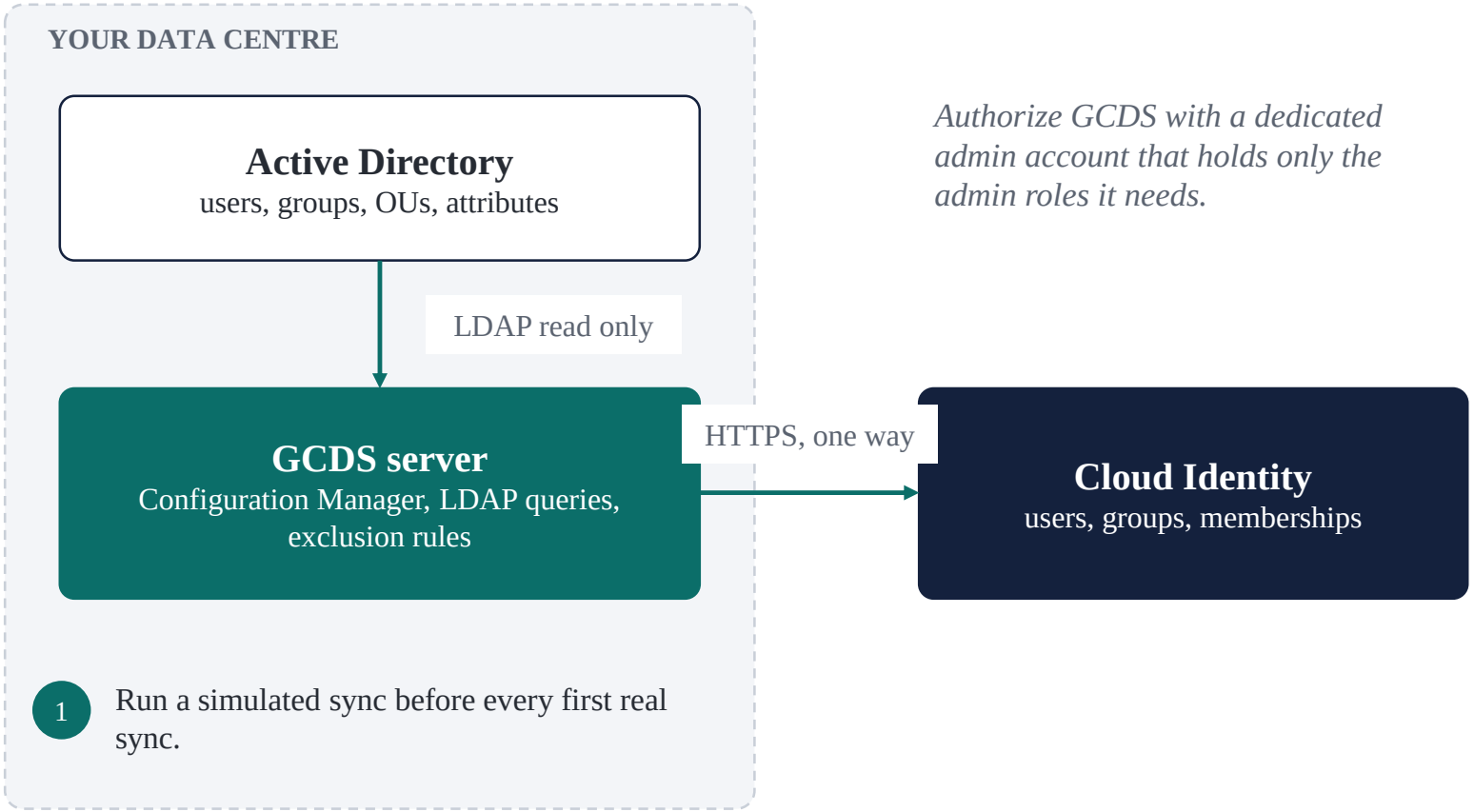
Google Cloud never stores its own user directory. Every human principal is a Google identity that lives in Cloud Identity or Google Workspace, or is federated in from outside.



Exam reflex

Need Workspace apps or a full Google account per person? Cloud Identity with GCDS plus SSO. Only need Google Cloud access with no copied accounts? Workforce Identity Federation.

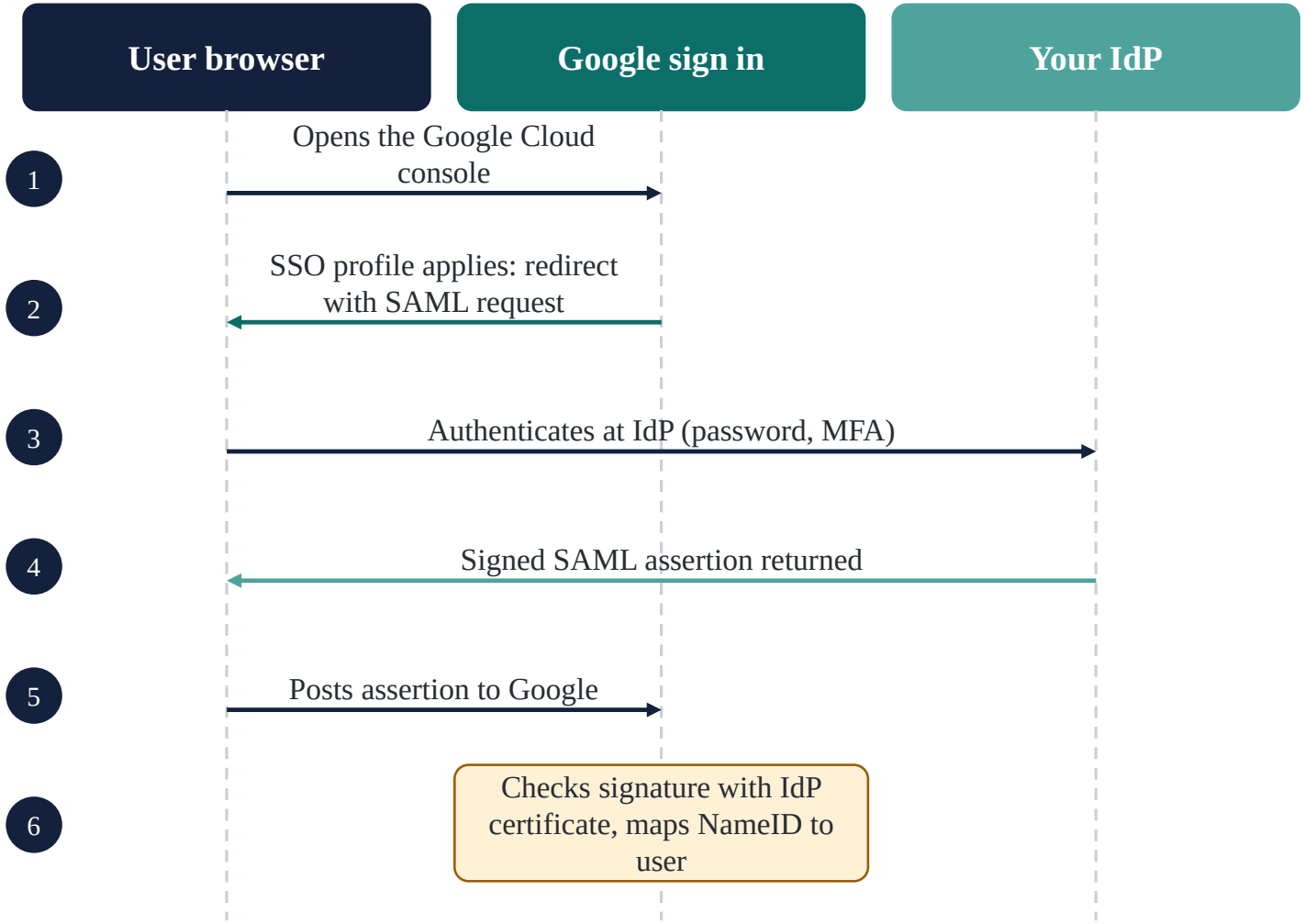
Google Cloud Directory Sync: How It Works



Authorize GCDS with a dedicated admin account that holds only the admin roles it needs.

1. **One direction only.** GCDS reads your directory and writes to Google. It never changes Active Directory.
2. **Runs on your server,** inside your network, on a schedule you set. Nothing is installed in Google Cloud.
3. **Passwords optional.** With SSO you do not sync passwords at all; your IdP keeps them.
4. **Exclusion rules** protect accounts that exist only in Google, such as super admins and break glass accounts.
5. **Deletes follow the source.** A user removed from AD is suspended or deleted in Cloud Identity on the next run.

Single Sign On with a Third Party IdP: The SAML Flow



What you configure

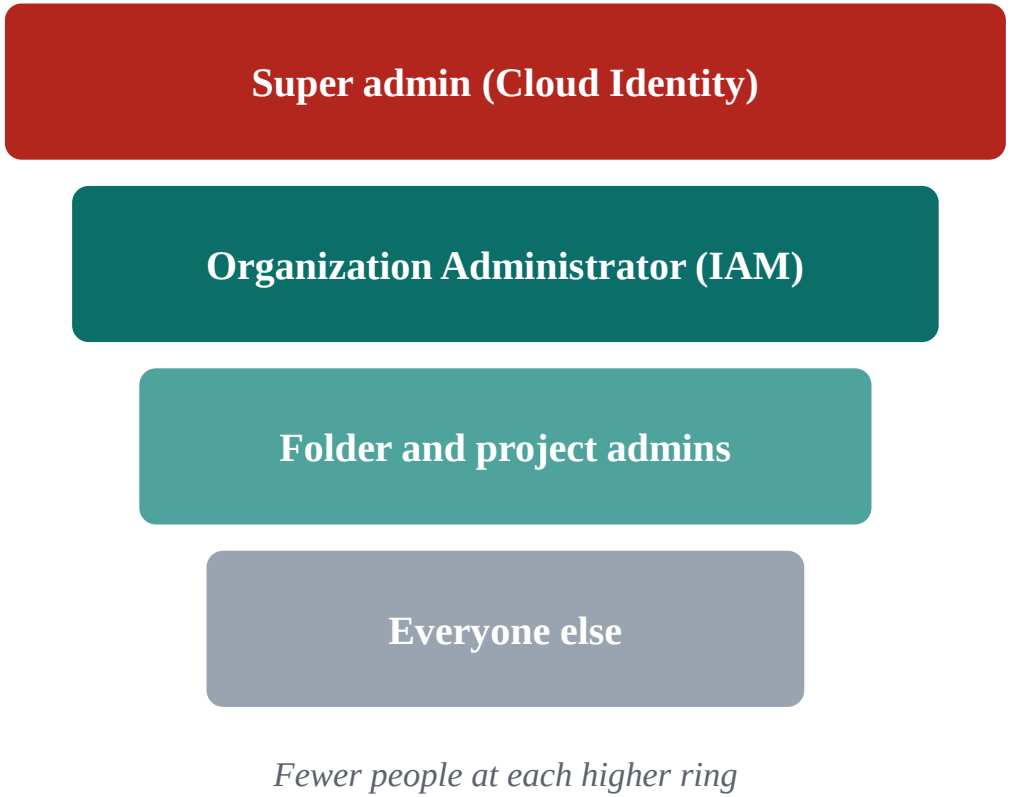
- An SSO profile (SAML or OIDC) with the IdP sign in URL and signing certificate
- Assign the profile to OUs or groups
- The user must already exist in Cloud Identity

Keep a way back in

Super admins signing in to the Admin console are not redirected to the IdP. That is your escape route if the IdP fails or its certificate expires.

Protecting the Super Administrator Account

The super admin of Cloud Identity can reset any password and grant itself any IAM role. Treat it as the crown jewel, not a daily account.



Fewer people at each higher ring

Dedicated accounts

A separate super admin identity per person, never their daily email. Use it only for Admin console tasks.

Few, but not one

Keep a small number (at least two) so one lost key does not lock you out.

Strongest 2SV

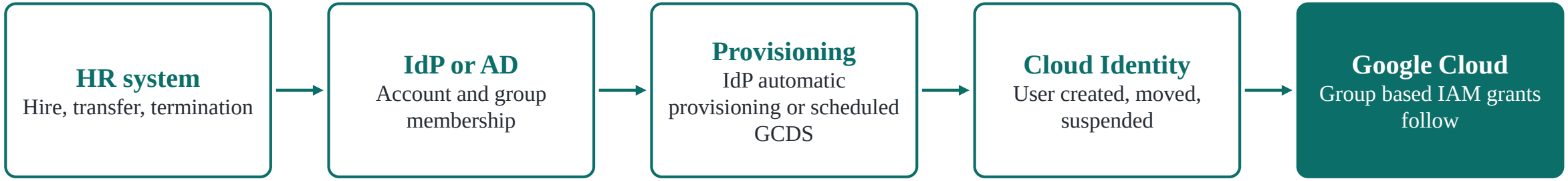
Enforce hardware security keys for super admins. Register recovery options.

Not for Google Cloud work

Grant Organization Administrator to a group for cloud tasks; super admin stays out of daily IAM.

Automating the User Lifecycle: Joiner, Mover, Leaver

Manual account changes are slow and forgotten. Drive every change from the HR system through the IdP so access follows employment automatically.



Joiner

Account created in the IdP, added to role groups, provisioned to Cloud Identity. IAM access arrives through those groups, no ticket needed.

Mover

Group memberships change with the new role. Old access disappears because it was granted to groups, not to the person.

Leaver

Disable in the IdP; provisioning suspends the Google account at once. Later delete, after transferring owned data.

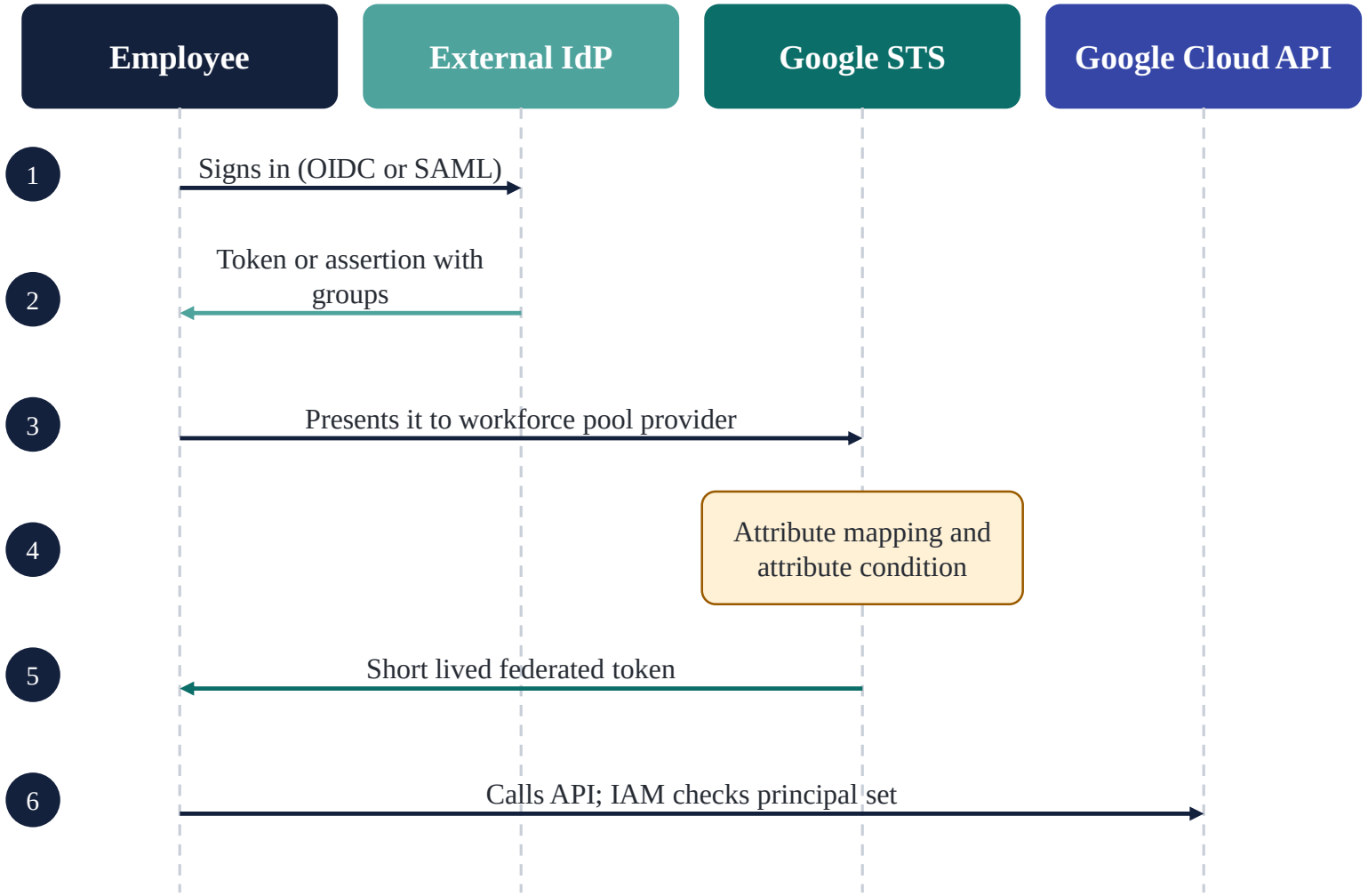
Administering Users and Groups Programmatically

Interface	Best for	Security note
Admin SDK Directory API	Bulk create, update, suspend users; manage OUs and group membership from scripts	Call it with a service account that holds a narrowly scoped admin role
Cloud Identity Groups API	Create groups, manage memberships, security labels, dynamic groups	Can be called with Google Cloud credentials and IAM, ideal for automation
Assigning admin roles to a service account	Automation that needs Admin console powers without a human account	Preferred over domain wide delegation: no user impersonation
Domain wide delegation	Legacy tools that must act as users	Powerful and risky; restrict OAuth scopes and review regularly
Terraform and GCDS	Groups as code; directory driven sync	Store state securely; review plans for membership changes

Why groups matter here

Automation should change group membership, not IAM policies. The IAM policy stays stable and auditable; the group decides who is in.

Workforce Identity Federation: Access Without Account Copies



1. Pool lives at the **organization** level.
2. **Mapping:** google.subject and google.groups from IdP claims.
3. **Condition** rejects tokens that fail, for example wrong tenant.
4. Grant IAM roles to **principalSet** of a group, not to individuals.

Choosing an Identity Pattern

Requirement in the stem	GCDS plus SSO (Cloud Identity accounts)	Workforce Identity Federation
Users also need Google Workspace apps	Yes, accounts exist in Google	No, federated users are not Workspace users
Do not store or sync user records at Google	No, users are copied by GCDS	Yes, attributes arrive in each token
Partner or contractor with their own IdP	Possible, but you manage their accounts	Ideal: add a provider for the partner IdP
Grant access by IdP group	Sync groups with GCDS, grant to group	Map google.groups, grant to principalSet
Product coverage	All Google Cloud services	Most services; check supported product list
Licensing	Cloud Identity Free or Premium per user	No Cloud Identity licence needed

Memory hook: GCDS copies people into Google. Workforce federation lets people visit Google with a passport issued by their own IdP.

Case Study 1: One Password for Everything

THE SCENARIO

Harbourline Logistics

Harbourline has 4,000 employees in on premises Active Directory and is adopting both Google Workspace and Google Cloud.

Security policy says user passwords must never be stored by any third party, and accounts must appear in Google automatically when HR creates them in AD.

Which approach meets these requirements?

A. Use Google Cloud Directory Sync to provision users and groups from AD, and configure SAML SSO with AD FS as the IdP.

B. Export users from AD to CSV each week and upload the file in the Admin console.

C. Configure Workforce Identity Federation with AD FS as a SAML provider and grant IAM roles to the workforce pool.

D. Use Google Cloud Directory Sync with password synchronization so users keep their AD passwords in Google.

ANSWER | CLOUD IDENTITY

Case Study 1 Answer: A

A

Use Google Cloud Directory Sync to provision users and groups from AD, and configure ...

Correct. GCDS creates the accounts automatically from AD; SSO keeps authentication at AD FS so Google never holds passwords.

B

Export users from AD to CSV each week and upload the file in the Admin console.

Incorrect. Manual and weekly: new hires wait days, and leavers keep access until the next upload.

C

Configure Workforce Identity Federation with AD FS as a SAML provider and grant IAM ...

Incorrect. Federated workforce users cannot use Workspace apps such as Gmail and Drive, which Harbourline is adopting.

D

Use Google Cloud Directory Sync with password synchronization so users keep their AD ...

Incorrect. Synchronizing password hashes stores them at Google, which the policy forbids.

Exam lesson

Workspace plus AD means Cloud Identity accounts. GCDS provisions them, SSO keeps credentials at the IdP.

Clue words in the stem

"Both Workspace and Google Cloud", "never stored by any third party", "automatically"

Case Study 2: The IdP Is Down

THE SCENARIO

Corvane Media

Corvane uses SAML SSO with a third party IdP for all users. Overnight the IdP signing certificate expired.

Every employee, including members of the Google Cloud Organization Administrator group, now fails to sign in to Google. Production is running, but the team must update the SSO certificate in the Admin console urgently.

What is the fastest supported way to restore access?

A. Use a service account key with the Organization Administrator role to change the SSO settings.

B. Create a new Cloud Identity account in a different domain and grant it Organization Administrator.

C. Open a support case and ask Google to disable SSO for the domain.

D. Sign in at the Admin console with a dedicated super admin account, which is not redirected to the IdP, and upload the new certificate.

ANSWER | SUPER ADMINISTRATOR

Case Study 2 Answer: D

A

Use a service account key with the Organization Administrator role to change the SSO ...

Incorrect. SSO profiles are Admin console settings, not Google Cloud IAM resources; an IAM role cannot change them.

B

Create a new Cloud Identity account in a different domain and grant it Organization ...

Incorrect. A new account still cannot reach the existing Admin console, and it cannot grant itself rights in this organization.

C

Open a support case and ask Google to disable SSO for the domain.

Incorrect. Support can help, but it is slower and unnecessary when a super admin can fix it directly.

D

Sign in at the Admin console with a dedicated super admin account, which is not ...

Correct. Super admins authenticate with Google credentials at the Admin console, which is exactly why dedicated super admins are kept.

Exam lesson

Dedicated super admin accounts with security keys are the break glass path when SSO fails. Plan for it before the outage.

Clue words in the stem

"Certificate expired", "including Organization Administrators", "Admin console"

Case Study 3: The Leaver Who Stayed

THE SCENARIO

Brightwater Health Analytics

Brightwater uses Okta as its IdP for SSO into Google Cloud. Accounts in Cloud Identity were created manually by the IT team.

An audit found that employees who left still had active Google accounts for up to three weeks, and some still held IAM roles on production projects.

What should you recommend to prevent this with the least ongoing effort?

A. Run a monthly IAM review of every production project and remove leavers.

B. Enable automatic user provisioning from Okta to Cloud Identity so that deactivating a user in Okta suspends the Google account.

C. Shorten the Google Cloud session length to one hour for all users.

D. Write a Cloud Function that deletes IAM bindings for users not seen in audit logs for 30 days.

ANSWER | USER LIFECYCLE

Case Study 3 Answer: B

A

Run a monthly IAM review of every production project and remove leavers.

Incorrect. Monthly and manual: leavers keep access for weeks between reviews.

B

Enable automatic user provisioning from Okta to Cloud Identity so that deactivating a ...

Correct. Provisioning ties the Google account to the IdP lifecycle, so termination in Okta immediately suspends access everywhere.

C

Shorten the Google Cloud session length to one hour for all users.

Incorrect. Shorter sessions force reauthentication, but the account still exists; if SSO is bypassed or a token remains, it is not a lifecycle fix.

D

Write a Cloud Function that deletes IAM bindings for users not seen in audit logs for 30 ...

Incorrect. Custom code, and inactivity is not termination. It also leaves the Google account itself active.

Exam lesson

Fix lifecycle problems at the source: automate provisioning and deprovisioning from the authoritative IdP or directory.

Clue words in the stem

"Created manually", "employees who left", "least ongoing effort"

Case Study 4: Contractors from Another Company

THE SCENARIO

Sable Retail Group

Sable hires an analytics consultancy for six months. Consultants authenticate with their own Microsoft Entra ID tenant.

They need the Google Cloud console and BigQuery in one project. Sable does not want to create, license, or deprovision accounts for them in its Cloud Identity.

What should you do?

A. Create Cloud Identity accounts for each consultant and enforce 2 step verification.

B. Configure Workload Identity Federation for the consultancy tenant and grant roles to the pool.

C. Create a service account with BigQuery roles and share its key with the consultancy.

D. Create a workforce identity pool with an OIDC provider for the consultancy tenant, map the consultant group, and grant BigQuery roles to that principal set on the project.

ANSWER | WORKFORCE IDENTITY FEDERATION

Case Study 4 Answer: D

A

Create Cloud Identity accounts for each consultant and enforce 2 step verification.

Incorrect. Works, but it is exactly the account creation and lifecycle burden Sable wants to avoid.

B

Configure Workload Identity Federation for the consultancy tenant and grant roles to the ...

Incorrect. Workload Identity Federation is for workloads such as pipelines, not for humans signing in to the console.

C

Create a service account with BigQuery roles and share its key with the consultancy.

Incorrect. Shared keys remove individual accountability and are long lived credentials, the opposite of best practice.

D

Create a workforce identity pool with an OIDC provider for the consultancy tenant, map ...

Correct. Workforce federation lets humans from an external IdP use the console with no account copies; the group mapping keeps access group based.

Exam lesson

Humans from an external IdP: Workforce Identity Federation. Machines from outside Google Cloud: Workload Identity Federation.

Clue words in the stem

"Their own Entra ID tenant", "console", "does not want to create accounts"

Three Kinds of Service Account

A service account is an identity for a workload, not a person. It is both a principal (it can hold roles) and a resource (others can hold roles on it).

User managed

- You create it in a project.
- You choose its roles.
- Best practice: one per workload, least privilege.
- Example: invoice processor on Cloud Run.

Default service accounts

- Created automatically when you enable Compute Engine or App Engine.
- Historically granted the Editor role on the project.
- Attached to new VMs unless you choose another.
- A prime target for privilege escalation.

Service agents

- Google managed identities that let a Google service act in your project.
- Example: the Cloud KMS or Cloud Storage service agent using your CMEK key.
- Do not remove their roles; services break.

Exam reflex

If a VM or job is described as using the default service account, the better answer almost always creates a dedicated service account with only the roles it needs.

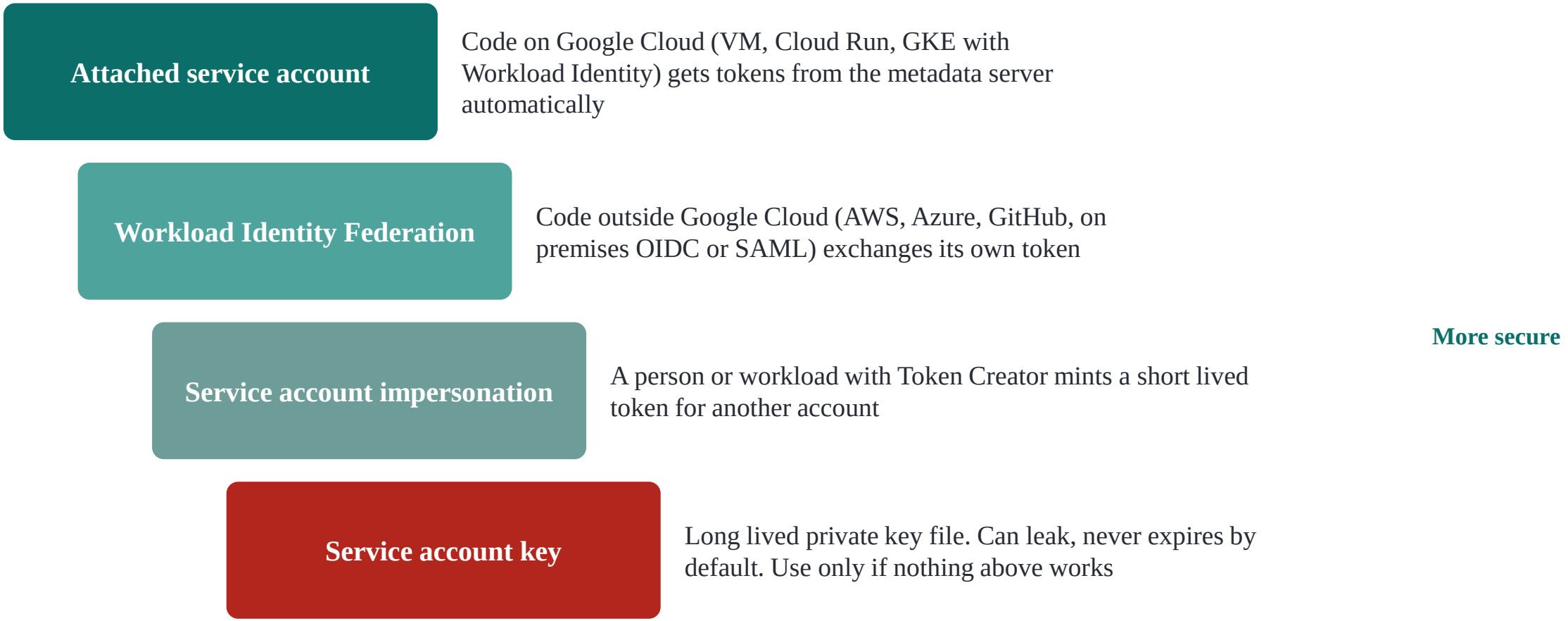
Taming Default Service Accounts



Control	What it does	Watch out
iam.automaticIamGrantsForDefaultServiceAccounts	Stops Editor being granted to default accounts in new projects	Affects only accounts created after enforcement
Disable the default account	Blocks its use while you migrate	Workloads still attached to it will fail
Deleting the default account	Possible but rarely advised	Some services expect it; prefer disable or deprivilege
Access scopes on VMs	Legacy limit on OAuth scopes for the VM	Not a substitute for IAM; use the cloud platform scope plus least privilege IAM

The Credential Ladder: Prefer the Top Rung

When a workload needs Google credentials, climb as high as the environment allows. Keys are the last resort, not the default.



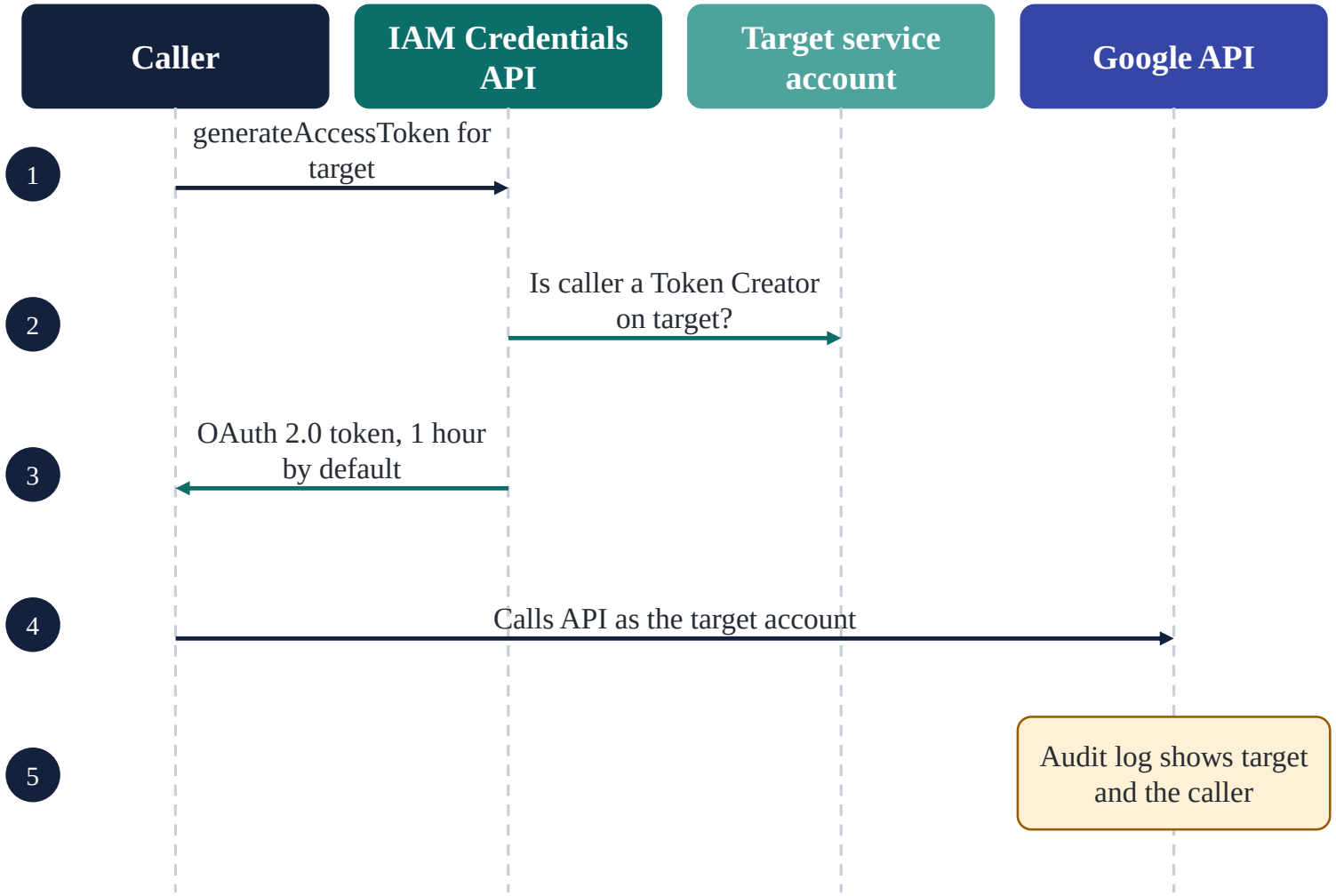
Securing, Auditing and Limiting Service Account Keys

Goal	Control	Type
Stop new keys being created	Org policy iam.disableServiceAccountKeyCreation	Preventive
Stop externally generated keys being uploaded	Org policy iam.disableServiceAccountKeyUpload	Preventive
Force keys to expire	Org policy iam.serviceAccountKeyExpiryHours	Preventive
React to keys leaked publicly	Org policy iam.serviceAccountKeyExposureResponse disables exposed keys	Responsive
Find unused keys and accounts	Activity Analyzer and service account insights (Policy Intelligence)	Detective
Spot risky keys	Security Command Center findings such as user managed keys and leaked credentials	Detective
Know who used a key	Audit logs record the key ID in authentication info	Detective

If a key truly is required

Grant creation rights to few people, store the key in Secret Manager rather than on disk or in code, rotate it, and monitor its use in audit logs.

Short Lived Credentials with the IAM Credentials API



Method	Returns
generateAccessToken	OAuth 2.0 access token
generateIdToken	OIDC ID token for Cloud Run, IAP
signJwt and signBlob	Signature by the Google managed key

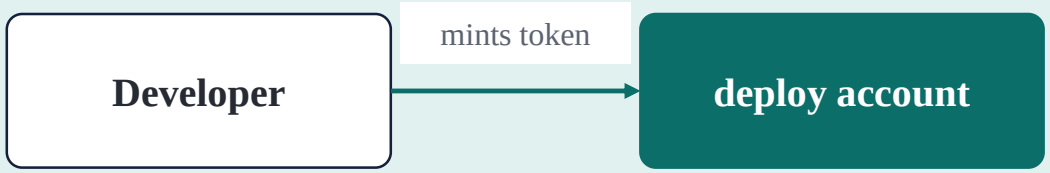
Lifetime

Tokens last one hour by default. Up to 12 hours is allowed only when the org policy constraint that permits lifetime extension lists the account.

Impersonation versus Attaching: Two Different Powers

Two roles on a service account are confused constantly in exam options. Learn which verb each one grants.

Service Account Token Creator



Grants: getAccessToken, signBlob, signJwt on that account.

Use it for: gcloud or code acting as the account temporarily, with every call logged against both identities.

Scope it: grant on the single service account, never project wide.

Service Account User



Grants: actAs, so you can attach the account to a VM, Cloud Run service or job.

Risk: anyone who can deploy code with that account gains its permissions indirectly.

Scope it: on the specific account; project level grants actAs on every account in the project.

Workload Identity Federation: Keyless Access from Outside



Attribute mapping

Translate claims into Google attributes: google.subject from the token subject; attribute.repository from a GitHub claim.

Attribute condition

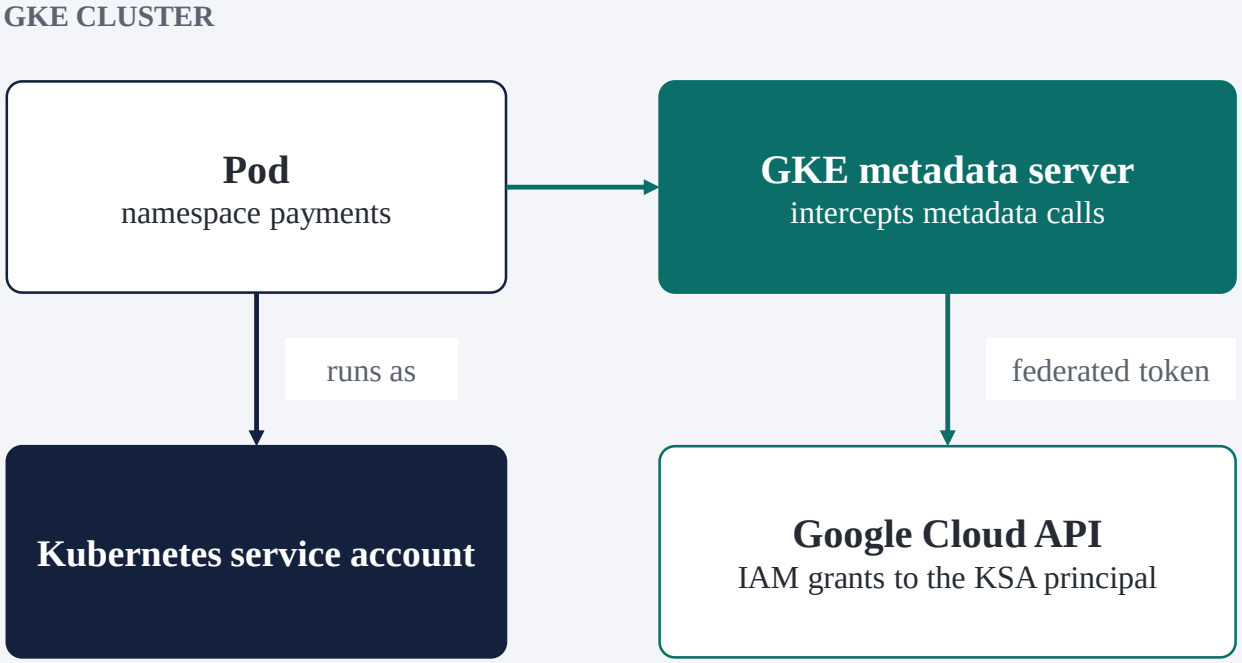
A CEL rule every token must pass. Example: only tokens whose repository claim equals your organization repo. Without it, any repo on the platform could federate.

Granting access

Grant Workload Identity User on a service account to the principal set, or grant resource roles directly to the federated principal.

The credential configuration file that clients use contains no secret. It only says where to find the external token and which provider to call.

Workload Identity Federation for GKE



Pods no longer see the node service account or its token. Each Kubernetes service account gets its own IAM identity.

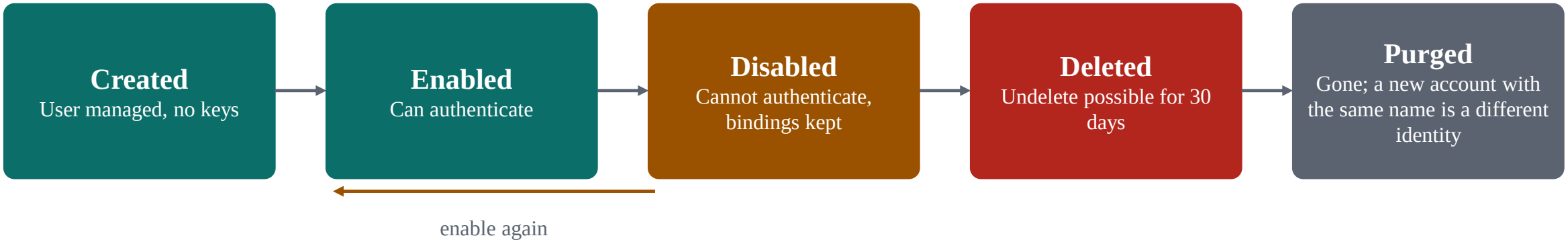
Why it beats the alternatives

- No keys in Kubernetes secrets
- No shared node identity across all pods
- Per namespace, per app least privilege

Exam trap

Granting roles to the node service account gives every pod on the node the same access. Choose Workload Identity Federation for GKE instead.

Service Account Lifecycle: Create, Disable, Delete



Disable before delete

Disable first and watch for failures. If something breaks, re enable in seconds; a delete is far harder to reverse.

Deleted identities in policies

Bindings for a deleted account remain, shown with a deleted prefix. They do not grant access to a new account that reuses the name.

Who can do what

Service Account Admin creates and deletes; Service Account Key Admin manages keys. Keep these separate from Token Creator.

Case Study 5: Editor Everywhere

THE SCENARIO

Quillmark Publishing

A review shows that most Compute Engine VMs across 300 projects run as the Compute Engine default service account, which holds the Editor role in each project.

New projects are created weekly by a project factory. Leadership wants least privilege enforced for all future projects and existing workloads fixed safely.

Which two actions should you take? (Choose two.)

A. Enforce the organization policy that disables automatic IAM grants for default service accounts.

B. Restrict VM access scopes to read only on all instances and keep the Editor role.

C. Create a dedicated service account for each workload with only the roles it needs, and attach it to the VMs.

D. Delete the default service account in every project immediately.

ANSWER | DEFAULT SERVICE ACCOUNTS

Case Study 5 Answer: A and C

A

Enforce the organization policy that disables automatic IAM grants for default service ...

Correct. Stops new projects from granting Editor to the default account, which covers the weekly project factory.

B

Restrict VM access scopes to read only on all instances and keep the Editor role.

Incorrect. Access scopes are a legacy limit and do not replace IAM; Editor stays on the identity.

C

Create a dedicated service account for each workload with only the roles it needs, and ...

Correct. Replaces the shared, over privileged identity with per workload least privilege for existing VMs.

D

Delete the default service account in every project immediately.

Incorrect. Running workloads would fail at once. Disable or deprivilege after migration, not first.

Exam lesson

Prevent the problem for the future with an org policy; fix the present with dedicated, minimal service accounts.

Clue words in the stem

"All future projects", "existing workloads fixed safely", "choose two"

Case Study 6: Keys in the Pipeline

THE SCENARIO

Lumen Fintech

Lumen deploys to Cloud Run from GitHub Actions. Today a JSON service account key is stored as a GitHub repository secret.

A penetration test flagged the key as a long lived credential. Lumen wants no long lived secrets anywhere and only its own deployment repository allowed to deploy.

What should you do?

A. Move the key into Secret Manager and have the workflow fetch it at runtime.

B. Create a separate service account per developer and let each developer deploy locally.

C. Configure Workload Identity Federation with a GitHub OIDC provider, an attribute condition on the repository claim, and grant Workload Identity User on the deploy service account.

D. Set the key expiry org policy to 24 hours and rotate the key daily from a scheduled job.

ANSWER | WORKLOAD IDENTITY FEDERATION

Case Study 6 Answer: C

A

Move the key into Secret Manager and have the workflow fetch it at runtime.

Incorrect. The workflow still needs a credential to reach Secret Manager, and the key remains long lived.

B

Create a separate service account per developer and let each developer deploy locally.

Incorrect. Moves the problem to laptops and loses the controlled pipeline.

C

Configure Workload Identity Federation with a GitHub OIDC provider, an attribute ...

Correct. GitHub issues a short lived OIDC token per run; the condition limits trust to one repository; no secret is stored anywhere.

D

Set the key expiry org policy to 24 hours and rotate the key daily from a scheduled job.

Incorrect. Shorter lived, but still a key that must be distributed and rotated by custom code.

Exam lesson

CI/CD outside Google Cloud should authenticate with Workload Identity Federation plus an attribute condition that pins the repository.

Clue words in the stem

"No long lived secrets anywhere", "only its own repository"

Case Study 7: Running as the Deployer

THE SCENARIO

Tidewell Insurance

Release engineers sometimes run Terraform by hand as the terraform service account in the production project.

Today they share a downloaded key. Security wants each engineer to act as that account without keys, and wants audit logs to show which engineer did it.

What should you do?

A. Grant each engineer the same roles as the terraform service account directly.

B. Grant the release engineer group Service Account Token Creator on the terraform service account and have Terraform use impersonation.

C. Create one key per engineer for the terraform service account.

D. Grant the release engineer group Service Account User on the production project.

ANSWER | IMPERSONATION

Case Study 7 Answer: B

A

Grant each engineer the same roles as the terraform service account directly.

Incorrect. Breaks the single controlled identity for Terraform and spreads production power to many people permanently.

B

Grant the release engineer group Service Account Token Creator on the terraform service ...

Correct. Engineers mint short lived tokens for that one account; audit logs record both the account and the human who impersonated it.

C

Create one key per engineer for the terraform service account.

Incorrect. More keys, more risk; still long lived credentials.

D

Grant the release engineer group Service Account User on the production project.

Incorrect. Service Account User grants actAs to attach accounts to resources, and at project level it covers every account in the project.

Exam lesson

Token Creator on a single service account is the keyless, auditable way for people to act as a workload identity.

Clue words in the stem

"Act as that account", "without keys", "which engineer did it"

Case Study 8: A Key on a Public Repository

THE SCENARIO

Orchid Labs

Security Command Center reports that a user managed key for the data loader service account was found in a public code repository two hours ago.

The account has write access to a Cloud Storage bucket with research data. You must contain the incident and understand impact.

What should you do first? (Choose two.)

A. Review Cloud Audit Logs filtered on the key ID to see what the key accessed.

B. Disable or delete the exposed key immediately.

C. Wait for the key expiry policy to remove the key at the end of the day.

D. Delete the data loader service account and recreate it with the same name.

ANSWER | LEAKED KEYS

Case Study 8 Answer: A and B

A

Review Cloud Audit Logs filtered on the key ID to see what the key accessed.

Correct. Authentication info in audit logs includes the service account key ID, showing exactly what the attacker did.

B

Disable or delete the exposed key immediately.

Correct. Containment comes first: a disabled key cannot authenticate any further requests.

C

Wait for the key expiry policy to remove the key at the end of the day.

Incorrect. Hours of exposure is unacceptable; expiry is a safety net, not a response.

D

Delete the data loader service account and recreate it with the same name.

Incorrect. Breaks every workload using the account; a recreated account is a new identity that needs all grants again.

Exam lesson

Leaked key response: contain by disabling the key, then investigate with audit logs keyed on the key ID.

Clue words in the stem

"Contain the incident and understand impact", "two hours ago"

Password and Session Policy

Password policy (Admin console)

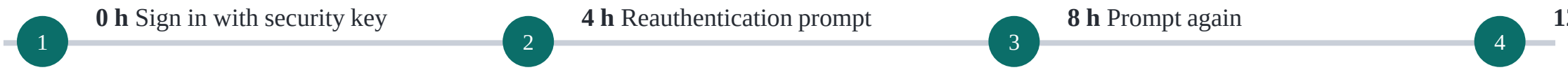
- Minimum and maximum length
- Enforce strong passwords
- Prevent reuse of old passwords
- Expiration if your standard demands it
- Enforce the policy at next sign in

Google Cloud session control

- Sets how often users must reauthenticate to the console and gcloud
- Choose an interval, for example 1 to 24 hours
- Choose the method: password or security key
- Apply to a group or OU, such as privileged admins

With SSO in place

- Password rules live at your IdP, not Google
- Session control still decides when Google sends users back to sign in
- Revoke sessions by signing a user out from the Admin console



Example: a four hour reauthentication policy for the admin group

SAML, OAuth 2.0 and OpenID Connect

Protocol	Answers the question	In Google Cloud you meet it when...
SAML 2.0	Who is this user? (authentication for SSO)	Your IdP signs users in to Google (SSO profile) or to a workforce pool
OAuth 2.0	What may this app do on the user's behalf? (delegated authorization)	Apps request scopes; the OAuth consent screen; service account access tokens
OpenID Connect	Who is this user, in a token? (identity on top of OAuth)	OIDC SSO profiles, workforce and workload providers, IAP and Cloud Run ID tokens

OAuth consent screen

Internal apps are limited to your organization users. External apps need verification for sensitive scopes.

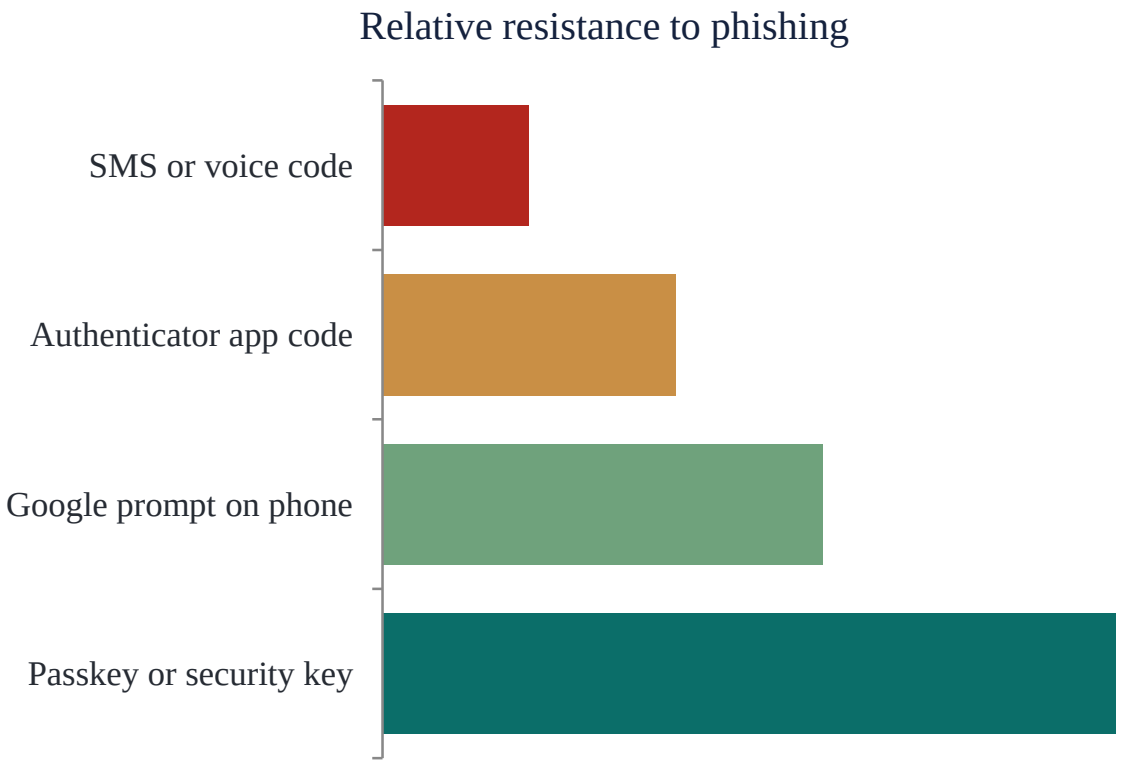
Control third party apps

In the Admin console, mark apps as trusted, limited, or blocked, and restrict high risk Google API scopes.

Protect client secrets

Store OAuth client secrets in Secret Manager, never in source code or front end bundles.

2 Step Verification: Methods and Enforcement



Illustrative ranking. Only security keys and passkeys are phishing resistant, because the browser binds them to the real Google domain.

1. **Enforce by OU or group.** Start with admins, then everyone.
2. **New user enrollment period** gives new hires a window to enroll before enforcement locks them out.
3. **Allowed methods** can be restricted to security keys only for privileged groups.
4. **Advanced Protection Program** adds the strictest protections for high risk users.
5. **Backup codes** stored safely prevent lockout when a key is lost.

Case Study 9: Four Hours, Then Prove It Again

THE SCENARIO

Meridian Capital

A regulator requires that staff with administrative access to Meridian's Google Cloud environment reauthenticate at least every four hours when using the console or the gcloud command line tool.

Reauthentication must use a hardware security key. Other staff should not be affected.

What should you configure?

A. Google Cloud session control in the Admin console for the admin group, with a four hour reauthentication frequency and security key as the method.

B. An IAM condition on admin role bindings that checks request.time against a four hour window.

C. A Cloud Scheduler job that revokes admin sessions every four hours.

D. An organization policy that limits OAuth access token lifetime to four hours.

ANSWER | SESSION CONTROL

Case Study 9 Answer: A

A

Google Cloud session control in the Admin console for the admin group, with a four hour ...

Correct. Session control is designed for this: per group, interval, and reauthentication method, covering console and gcloud.

B

An IAM condition on admin role bindings that checks request.time against a four hour window.

Incorrect. Conditions on request.time grant or deny by clock time; they cannot force anyone to sign in again.

C

A Cloud Scheduler job that revokes admin sessions every four hours.

Incorrect. Custom and brittle, and it would not enforce the security key method.

D

An organization policy that limits OAuth access token lifetime to four hours.

Incorrect. There is no such organization policy for user sessions; token lifetime extension relates to service accounts.

Exam lesson

Reauthentication frequency for Google Cloud is set with Google Cloud session control, scoped to groups or OUs.

Clue words in the stem

"Reauthenticate every four hours", "console and gcloud", "security key", "other staff not affected"

Case Study 10: Phishing Resistant Admins

THE SCENARIO

Vantor Energy

Vantor suffered a phishing attack in which an administrator approved a fake sign in by typing an authenticator code into a look alike page.

The CISO wants administrators protected against this attack, while other staff keep their current methods during a gradual rollout.

What should you do?

A. Shorten the password expiry for administrators to 30 days.

B. Require SMS verification codes for all users immediately.

C. Enable Advanced Protection for every employee on the same day.

D. Enforce 2 step verification for the admin OU with security keys as the only allowed method, using an enrollment period.

ANSWER | 2 STEP VERIFICATION

Case Study 10 Answer: D

A

Shorten the password expiry for administrators to 30 days.

Incorrect. Passwords were not the weak point; the code was relayed by the attacker.

B

Require SMS verification codes for all users immediately.

Incorrect. SMS codes can be phished exactly like authenticator codes, and it changes everyone at once.

C

Enable Advanced Protection for every employee on the same day.

Incorrect. Too broad for a gradual rollout; it disrupts staff who were not targeted.

D

Enforce 2 step verification for the admin OU with security keys as the only allowed ...

Correct. Security keys are bound to the genuine domain, so a look alike page cannot use them; scoping to the admin OU matches the gradual rollout.

Exam lesson

Phishing resistance means security keys or passkeys. Enforce them first for the highest risk group.

Clue words in the stem

"Typing a code into a look alike page", "administrators", "gradual rollout"

Structure of an IAM Allow Policy

```
{
  "bindings": [ {
    "role": "roles/storage.objectViewer",
    "members": [
      "group:finance_analysts@example.com",
      "serviceAccount:report@prj.iam.gserviceaccount.com" ],
    "condition": {
      "title": "finance buckets only",
      "expression": "resource.name.startsWith(
        'projects/_/buckets/finance')" }
  } ],
  "etag": "BwX1...", "version": 3
}
```

1. **Role:** a named bundle of permissions. Prefer predefined roles.
2. **Members:** principals. Grant to groups so membership, not policy, changes.
3. **Condition:** optional CEL that narrows when or where the binding applies. Requires policy version 3.
4. **Etag:** optimistic concurrency. Read, modify, write back; stale writes fail.
5. **Attached** to an organization, folder, project or supported resource, and inherited downward.

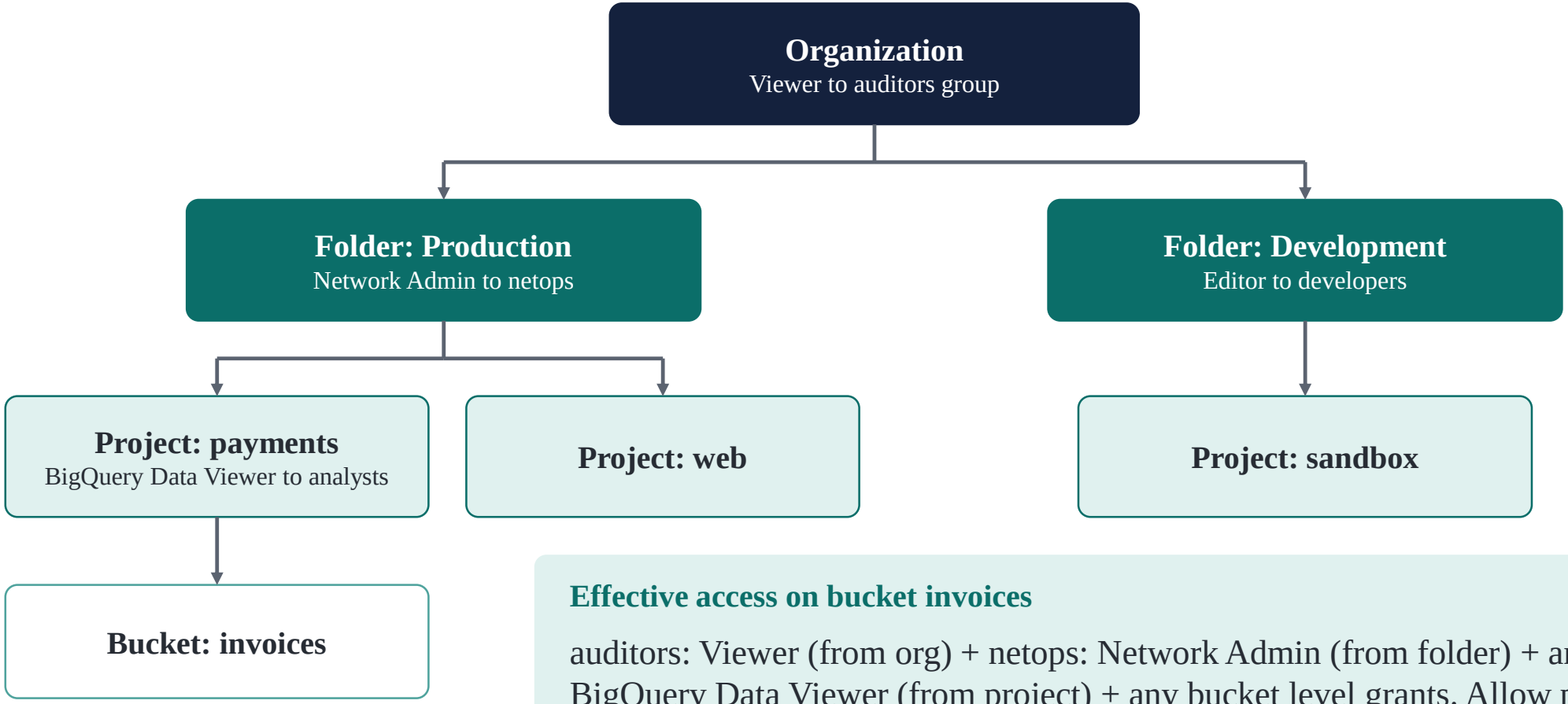
Basic, Predefined and Custom Roles

	Basic roles	Predefined roles	Custom roles
Examples	Owner, Editor, Viewer	Storage Object Viewer, Compute Network Admin	Your bundle of chosen permissions
Granularity	Thousands of permissions across all services	One service or job function	Exactly what you list
Maintained by	Google	Google, updated as services change	You; new permissions are not added automatically
Where defined	Built in	Built in	Organization or project level only (not folders)
Exam stance	Avoid in production	Default choice for least privilege	Only when no predefined role is narrow enough

Why custom roles are not the first answer

They carry maintenance overhead, some permissions are not supported in them, and a custom role defined in one project cannot be used in another. Pick them only when the stem rules out every predefined role.

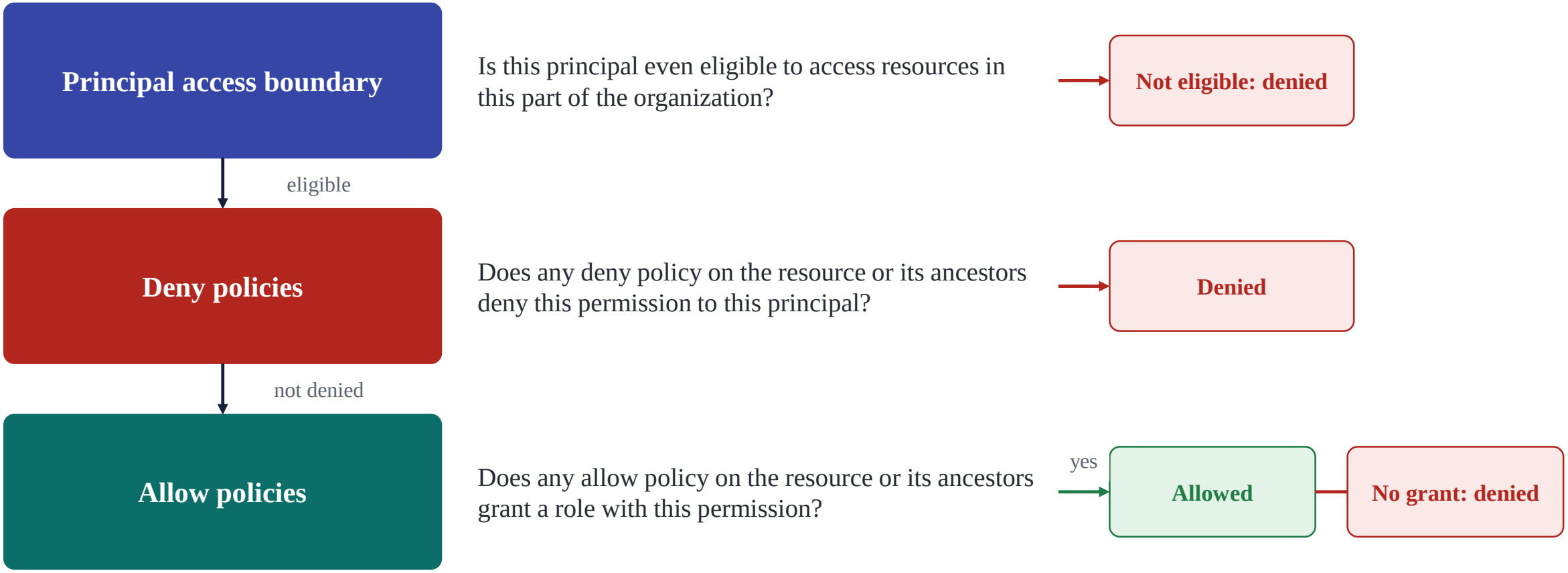
Inheritance: Access Flows Down and Adds Up



Effective access on bucket invoices

auditors: Viewer (from org) + netops: Network Admin (from folder) + analysts: BigQuery Data Viewer (from project) + any bucket level grants. Allow policies only add; a lower level can never remove an inherited grant. Only a deny policy can.

How IAM Decides: The Evaluation Order



Organization policies are separate: they restrict what configurations resources may have, not who may call an API.

IAM Conditions: Narrowing When and Where

Use case	Attribute	Example expression idea
Temporary access	request.time	Grant expires at the end of the change window
Only some resources of a type	resource.name, resource.type	Buckets whose name starts with finance
Tag based access	resource.matchTag()	Only resources tagged environment = dev
IAP access by context	Access levels, request.host, request.path	Only from a managed device, only path /admin
IAP TCP forwarding	destination.ip, destination.port	SSH to port 22 on one instance only

Strength

Fine grained access without creating many projects or custom roles.

Limit

Not every service evaluates every attribute. Check support before relying on a condition.

Exam cue

"Only until", "only resources tagged", "only from" usually points to a condition.

IAM Deny Policies: Guardrails That Override Allow

A deny rule, read aloud

Denied principals	principalSet of all users in the domain
Exception principals	group: break glass admins
Denied permissions	cloudresourcemanager.googleapis.com/projects.delete
Denial condition	Optional: only where tag environment = prod

1. **Attached** to an organization, folder or project and inherited by everything below.
2. **Evaluated before allow,** so a project Owner is still blocked.
3. **Permissions use a fully qualified format** that names the service.
4. **Managed with** the Deny Admin role, which should be held by very few people.
5. **Use for:** invariants such as "nobody deletes production projects" or "nobody but the security team changes IAM".

Separation of Duties with IAM Roles

No single person should be able to both perform and approve, or both hold the key and read the data. Split the powers across groups.

Duty	Role held by one group	Kept away from that group
Key management	Cloud KMS Admin (create, rotate, destroy keys)	CryptoKey Encrypter Decrypter (use the keys)
Organization structure	Organization Administrator	Day to day project Owner roles
Network	Compute Network Admin, Shared VPC Admin	Instance Admin for application teams
Policy	Organization Policy Administrator	Application developers
Security tooling	Security Admin, Security Center Admin	Billing Administrator
Logs	Logging Admin, private log viewing	The engineers whose actions are logged

Tip: put encryption keys in a dedicated key project so data project owners cannot manage keys by inheritance.

Cloud Storage: IAM, ACLs and Uniform Access

Fine grained (legacy)
Bucket IAM plus per object ACLs. Two systems to audit; an object can quietly be made public by an ACL.



Uniform bucket level access
IAM only. ACLs are disabled for the bucket and its objects. One place to audit, works with IAM Conditions and VPC Service Controls.

Enforce at scale

Org policy storage.uniformBucketLevelAccess makes every new bucket uniform.

Never public

Public access prevention (and its org policy) blocks allUsers and allAuthenticatedUsers.

Temporary sharing

Signed URLs give time limited access to one object without any IAM grant.

Change window

After enabling uniform access you have 90 days to revert before it is locked.

Access Context Manager: Context as a Condition

Access policy
Container for levels and perimeters

Access level
IP ranges, regions, device policy (managed, encrypted, screen lock), or custom CEL

One definition, reused by three enforcement points. Define "corporate device in the UK" once and apply it everywhere.

VPC Service Controls
Allow API calls into a perimeter only from approved networks or devices

Identity Aware Proxy
IAM condition on IAP requires the access level for an app or VM

Context aware access
Require a managed device for the console and Google APIs for chosen groups

Policy Intelligence: Four Tools, Four Questions

1 Role recommendations

- Question: "Which permissions does this principal actually use?"
- Uses about 90 days of usage to suggest a smaller role or removal.
- Best for: shrinking Editor to the right predefined role.

2 Policy Analyzer

- Question: "Who can access this resource, or what can this principal reach?"
- Searches effective access across the hierarchy, including groups.
- Best for: audits and investigations.

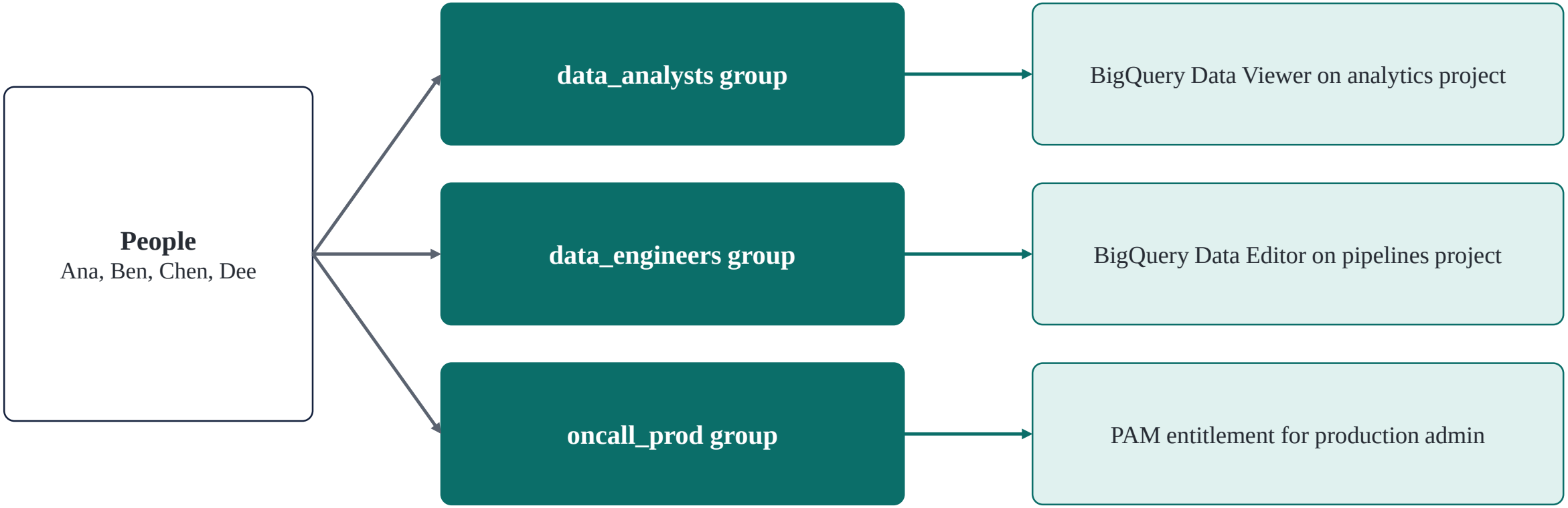
3 Policy Troubleshooter

- Question: "Why does this user have, or not have, access?"
- Explains the bindings, denies and boundaries involved.
- Best for: access denied tickets.

4 Policy Simulator

- Question: "What breaks if I change this policy?"
- Replays recent access against the proposed policy.
- Best for: safe removal of roles at scale.

Managing Permissions Through Groups



Rules of thumb: grant roles to groups named after job functions; let HR driven membership move people; review membership, not policies; keep individual grants for break glass only.

Privileged Access Manager: Just in Time Elevation



Use it for

- Production admin during incidents
- Break glass with an approval trail
- Rare, high risk roles such as IAM admin

Instead of

- Standing Owner grants
- IAM conditions with an expiry set by hand
- Shared emergency accounts

Exam cue

- "Temporary", "approval", "justification", "automatically revoked"
- All four together point to PAM

Case Study 11: Nobody Deletes Production

THE SCENARIO

Kestrel Payments

Several teams hold the Owner role on their own projects inside the Production folder. Last quarter a project was deleted by mistake.

Leadership wants a guarantee that no one can delete any production project, except members of a small break glass group, without changing teams' existing roles.

What should you do?

A. Create an alert on project deletion audit log entries.

B. Attach an IAM deny policy to the Production folder that denies the project delete permission to all principals, with the break glass group as an exception.

C. Remove the Owner role from all teams and grant Editor instead.

D. Place a lien on each production project.

ANSWER | IAM DENY POLICIES

Case Study 11 Answer: B

A

Create an alert on project deletion audit log entries.

Incorrect. Detective only. The project is already deleted when the alert fires.

B

Attach an IAM deny policy to the Production folder that denies the project delete ...

Correct. Deny is evaluated before allow and is inherited by every project in the folder, including future ones; the exception keeps a controlled path.

C

Remove the Owner role from all teams and grant Editor instead.

Incorrect. Changes teams' roles, and Editor can still do great damage; it does not express the invariant.

D

Place a lien on each production project.

Incorrect. Liens are per project and can be removed by anyone with permission to update liens, often the same Owners.

Exam lesson

Guarantees that must hold "even for Owners" are deny policies, attached high in the hierarchy with explicit exceptions.

Clue words in the stem

"Guarantee", "no one", "except", "without changing existing roles"

Case Study 12: Two Hours of Production

THE SCENARIO

Ashgrove Telecom

On call engineers occasionally need the Compute Admin role on production projects to resolve incidents.

Security wants no standing access, a written justification for every elevation, approval from a team lead, automatic removal after at most two hours, and a full audit trail.

What should you implement?

A. Grant Compute Admin permanently and review audit logs weekly.

B. Share a break glass account whose password is stored in Secret Manager.

C. Grant Compute Admin with an IAM condition that expires two hours after the start of each shift.

D. Create a Privileged Access Manager entitlement for the on call group with Compute Admin, a two hour maximum, required justification, and team leads as approvers.

ANSWER | PRIVILEGED ACCESS MANAGER

Case Study 12 Answer: D

A

Grant Compute Admin permanently and review audit logs weekly.

Incorrect. Standing access is exactly what security wants to remove.

B

Share a break glass account whose password is stored in Secret Manager.

Incorrect. Shared accounts destroy individual accountability and are a classic audit failure.

C

Grant Compute Admin with an IAM condition that expires two hours after the start of each ...

Incorrect. Time bound, but no justification or approval, and someone must edit the policy every shift.

D

Create a Privileged Access Manager entitlement for the on call group with Compute Admin, ...

Correct. PAM delivers just in time grants with justification, approval, maximum duration and automatic revocation, all logged.

Exam lesson

Temporary, justified, approved and automatically revoked access is the definition of a PAM entitlement.

Clue words in the stem

"No standing access", "justification", "approval", "automatic removal"

Case Study 13: Shrinking Editor Safely

THE SCENARIO

Pinecrest Biotech

A data science team of 40 people holds Editor on five research projects. The security team must move them to least privilege.

Research must not be interrupted, and the team lead cannot list exactly which services each person uses.

What is the best approach?

A. Use IAM role recommendations to identify the permissions actually used, then validate the proposed changes with Policy Simulator before applying them.

B. Use Policy Troubleshooter for each user to find what access they have.

C. Remove Editor from everyone and add roles back as people report errors.

D. Create a custom role containing every permission in Editor and grant that instead.

ANSWER | POLICY INTELLIGENCE

Case Study 13 Answer: A

A

Use IAM role recommendations to identify the permissions actually used, then validate ...

Correct. Recommendations are based on observed usage, and the simulator shows what would break before you change anything.

B

Use Policy Troubleshooter for each user to find what access they have.

Incorrect. Troubleshooter explains one access decision; it does not recommend smaller roles.

C

Remove Editor from everyone and add roles back as people report errors.

Incorrect. Guaranteed disruption, which the stem forbids.

D

Create a custom role containing every permission in Editor and grant that instead.

Incorrect. Identical power with extra maintenance; nothing is reduced.

Exam lesson

Rightsizing roles: recommendations to find the target, Policy Simulator to prove it is safe.

Clue words in the stem

"Least privilege", "must not be interrupted", "cannot list which services"

Case Study 14: Only from Company Laptops

THE SCENARIO

Ellison Wealth Partners

Ellison's cloud administrators sometimes sign in to the Google Cloud console from personal computers at home.

Compliance now requires that members of the cloud admins group can use the console and Google Cloud APIs only from company managed, encrypted devices. Other employees are unaffected.

What should you configure?

A. Identity Aware Proxy in front of the Google Cloud console.

B. A Cloud NGFW rule that allows HTTPS only from the corporate IP range.

C. An access level with a device policy for managed, encrypted devices, applied to the cloud admins group with context aware access.

D. An IAM condition on every admin binding that checks the device operating system.

ANSWER | ACCESS CONTEXT MANAGER

Case Study 14 Answer: C

A

Identity Aware Proxy in front of the Google Cloud console.

Incorrect. IAP protects your own applications and VMs, not the Google Cloud console.

B

A Cloud NGFW rule that allows HTTPS only from the corporate IP range.

Incorrect. Firewall rules protect your VPC resources, not Google's console and API endpoints.

C

An access level with a device policy for managed, encrypted devices, applied to the ...

Correct. Context aware access enforces an access level with device attributes for a chosen group on the console and Google APIs.

D

An IAM condition on every admin binding that checks the device operating system.

Incorrect. IAM conditions do not offer device posture attributes for general Google Cloud API access.

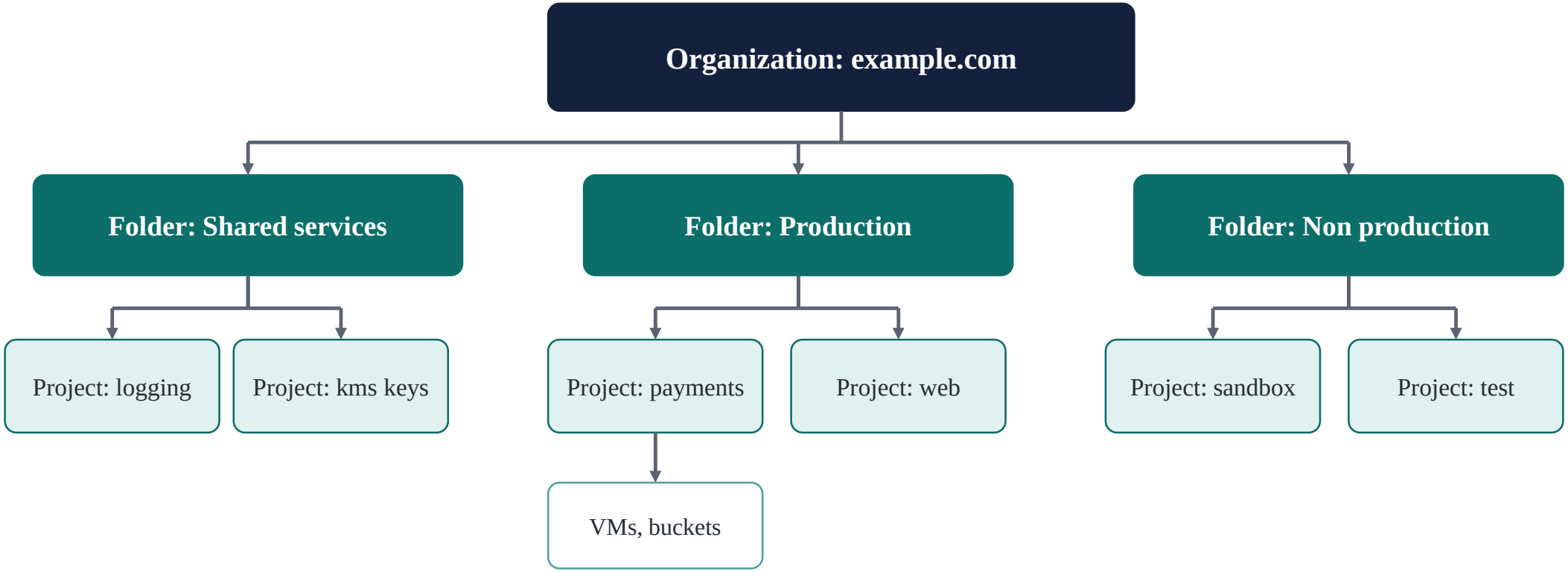
Exam lesson

Device and location requirements for console and API use are access levels enforced by context aware access.

Clue words in the stem

"Company managed, encrypted devices", "console and APIs", "admins group only"

The Resource Hierarchy at a Glance



1. **Folders** group projects by environment, business unit or compliance need; up to 10 levels deep.
2. **IAM and org policies inherit downward,** so put shared guardrails high and exceptions low.
3. **Projects** are the billing, quota and API boundary, and the usual trust boundary for workloads.

Managing Folders and Projects at Scale

Infrastructure as code

- Create folders, projects, IAM and policies with Terraform
- A project factory applies standard groups, APIs, budgets and labels
- Changes reviewed and versioned

Control project creation

- New organizations grant Project Creator and Billing Account Creator broadly
- Remove those defaults; grant creation only to the factory
- Stops shadow projects outside guardrails

Tags and labels

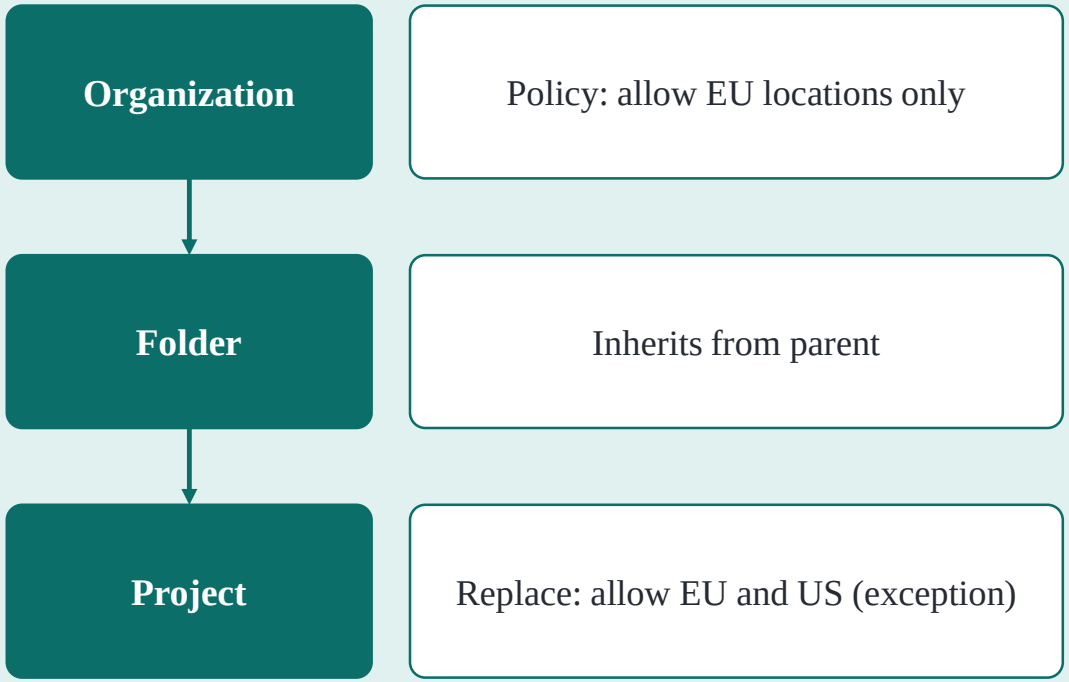
- Tags (Resource Manager) carry policy: conditional IAM, org policy, firewall
- Labels carry metadata: cost and inventory
- Tags inherit; labels do not

Protect what matters

- Liens block accidental project deletion
- Deny policies make it a guarantee
- Essential contacts route security notices to the right team

Organization Policies: Constraints on Configuration

How a policy is evaluated



Children can inherit, merge or replace, unless overrides are prevented.

Type	Behaviour
Boolean	On or off, for example require OS Login
List	Allowed or denied values, for example permitted regions
Managed	Newer Google defined constraints with richer parameters
Custom	Your CEL rule on resource fields, CREATE or UPDATE

Safe rollout

- Dry run mode logs what would be blocked without blocking it
- Policy Simulator for org policies previews violations
- Tags allow conditional enforcement per environment

Constraints Every Candidate Should Know

Constraint	Effect
iam.allowedPolicyMemberDomains	Domain restricted sharing: IAM grants only to identities in your listed customer IDs
iam.disableServiceAccountKeyCreation	No new service account keys
iam.automaticIamGrantsForDefaultServiceAccounts	No automatic Editor grant to default service accounts
compute.vmExternalIpAccess	Only listed VMs (or none) may have external IP addresses
compute.requireOsLogin	SSH access through IAM linked OS Login, not metadata keys
compute.requireShieldedVm	New VMs must use Shielded VM images
compute.skipDefaultNetworkCreation	New projects get no permissive default network
storage.publicAccessPrevention	Buckets cannot be made public
gcp.resourceLocations	Resources may be created only in allowed locations
gcp.restrictNonCmekServices	Listed services must use customer managed keys
sql.restrictPublicIp	Cloud SQL instances cannot have public IP addresses

Custom Organization Policy Constraints

```
name: custom.gkeRequireBinAuthz
resourceTypes:
  container.googleapis.com/Cluster
methodTypes: CREATE, UPDATE
condition:
  resource.binaryAuthorization
    .evaluationMode ==
    "PROJECT_SINGLETON_POLICY_ENFORCE"
actionType: ALLOW
displayName: GKE clusters must use
  Binary Authorization
```

1. **Write** a CEL condition on fields of a supported resource type.
2. **Choose** ALLOW (must match) or DENY (must not match), for CREATE and UPDATE.
3. **Enforce** it like any constraint, at organization, folder or project, with dry run first.
4. **Prevents** non compliant resources at creation time; existing ones are reported, not deleted.
5. **Pair** with Security Health Analytics custom modules to detect what already exists.

Case Study 15: No Personal Gmail Accounts

THE SCENARIO

Northgate Councils Shared Services

A developer granted BigQuery Data Viewer on a project to a personal Gmail address so he could work from home.

Northgate wants to ensure IAM roles can only ever be granted to identities in its own Cloud Identity domain, across every current and future project.

What should you do?

A. Create an IAM deny policy at the organization that denies all permissions to allUsers.

B. Enforce the domain restricted sharing organization policy (iam.allowedPolicyMemberDomains) at the organization with Northgate's customer ID.

C. Run a weekly Policy Analyzer query to find external members and remove them.

D. Use a VPC Service Controls perimeter around all projects.

ANSWER | ORGANIZATION POLICIES

Case Study 15 Answer: B

A

Create an IAM deny policy at the organization that denies all permissions to allUsers.

Incorrect. A deny on allUsers does not stop grants to a specific external account like a Gmail address.

B

Enforce the domain restricted sharing organization policy ...

Correct. The constraint rejects any IAM binding whose member is outside the allowed customer IDs, everywhere below the organization.

C

Run a weekly Policy Analyzer query to find external members and remove them.

Incorrect. Detective and periodic; the external grant works until the next run.

D

Use a VPC Service Controls perimeter around all projects.

Incorrect. Perimeters control API access paths, not who may appear in IAM policies.

Exam lesson

Restricting who can be granted access is a configuration rule, so it is an organization policy: domain restricted sharing.

Clue words in the stem

"Can only ever be granted to", "every current and future project"

Case Study 16: Clusters Must Be Born Compliant

THE SCENARIO

Aurelia Gaming

Aurelia runs dozens of GKE clusters created by many teams. The security standard says every cluster must have Binary Authorization enforcement enabled.

No predefined organization policy constraint enforces this setting. Non compliant clusters must be blocked at creation, not cleaned up later.

What should you do?

A. Document the standard and require approval tickets for new clusters.

B. Create a Security Health Analytics custom module that flags clusters without Binary Authorization.

C. Create a custom organization policy constraint for GKE clusters that requires the Binary Authorization evaluation mode, and enforce it at the organization.

D. Trigger a Cloud Function from audit logs that deletes non compliant clusters.

ANSWER | CUSTOM CONSTRAINTS

Case Study 16 Answer: C

A

Document the standard and require approval tickets for new clusters.

Incorrect. Manual process with no technical enforcement.

B

Create a Security Health Analytics custom module that flags clusters without Binary ...

Incorrect. Detects after creation; the stem requires blocking at creation.

C

Create a custom organization policy constraint for GKE clusters that requires the Binary ...

Correct. Custom constraints evaluate CREATE and UPDATE requests against your CEL rule and reject non compliant clusters up front.

D

Trigger a Cloud Function from audit logs that deletes non compliant clusters.

Incorrect. Reactive and destructive; a non compliant cluster exists for a while and deletion may cause outages.

Exam lesson

When no predefined constraint exists and the requirement is prevention, write a custom organization policy constraint.

Clue words in the stem

"No predefined constraint", "blocked at creation, not cleaned up later"

SECTION 1 RECAP

Section 1 Recap: Configuring Access

Must remember

- GCDS is one way, AD to Google; SSO keeps passwords at the IdP
- Super admins bypass SSO at the Admin console: protect them with security keys
- Workforce federation for humans, Workload federation for machines
- Credential ladder: attached account, federation, impersonation, keys last
- Deny is evaluated before allow; allow policies only add
- Custom roles: organization or project only
- PAM: just in time, justified, approved, auto revoked

Pick this when you read...

"Workspace too" GCDS plus SSO

"No account copies" Workforce Identity Federation

"GitHub, AWS, no keys" Workload Identity Federation

"Act as, auditable" Token Creator

"Even Owners cannot" IAM deny policy

"Only our domain" Domain restricted sharing

"Temporary with approval" PAM

"Which roles are used" Role recommendations

Classic traps

- Service Account User at project level
- Deleting default service accounts first
- Secret Manager as a cure for keys
- Liens as a guarantee
- Alerts when the stem says prevent
- IAP to protect the Google Cloud console

02

Securing Communications and Boundaries

Every packet and every API call takes a path. This section is about choosing the safest path and placing the right control on it.

Exam weight: about 22% of questions



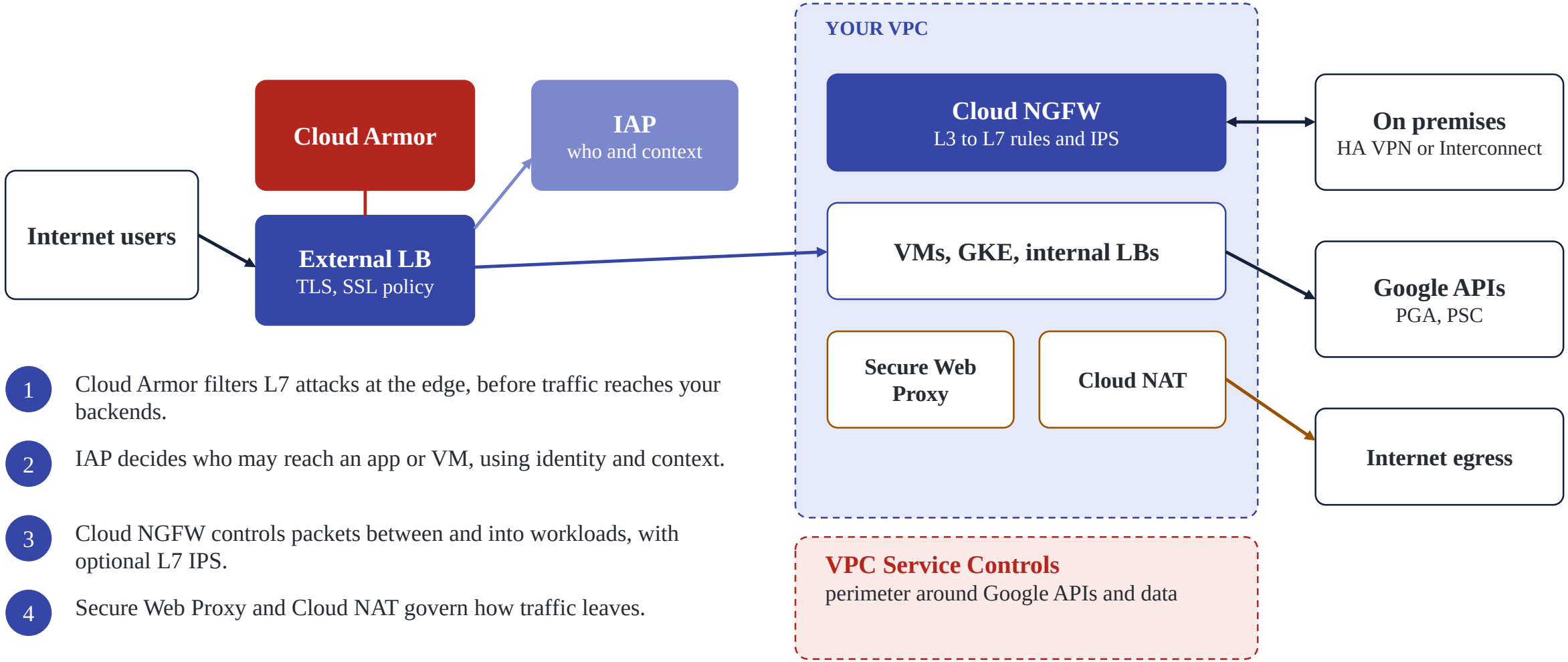
Bar scaled so that 30% would fill the track

2.1 Perimeter security: NGFW, IAP, Cloud Armor, Secure Web Proxy, DNS

2.2 Boundary segmentation: VPC design, Shared VPC, VPC Service Controls

2.3 Private connectivity: VPN, Interconnect, Private Google Access, PSC, Cloud NAT

The Perimeter Map: Where Each Control Sits



1. Cloud Armor filters L7 attacks at the edge, before traffic reaches your backends.
2. IAP decides who may reach an app or VM, using identity and context.
3. Cloud NGFW controls packets between and into workloads, with optional L7 IPS.
4. Secure Web Proxy and Cloud NAT govern how traffic leaves.

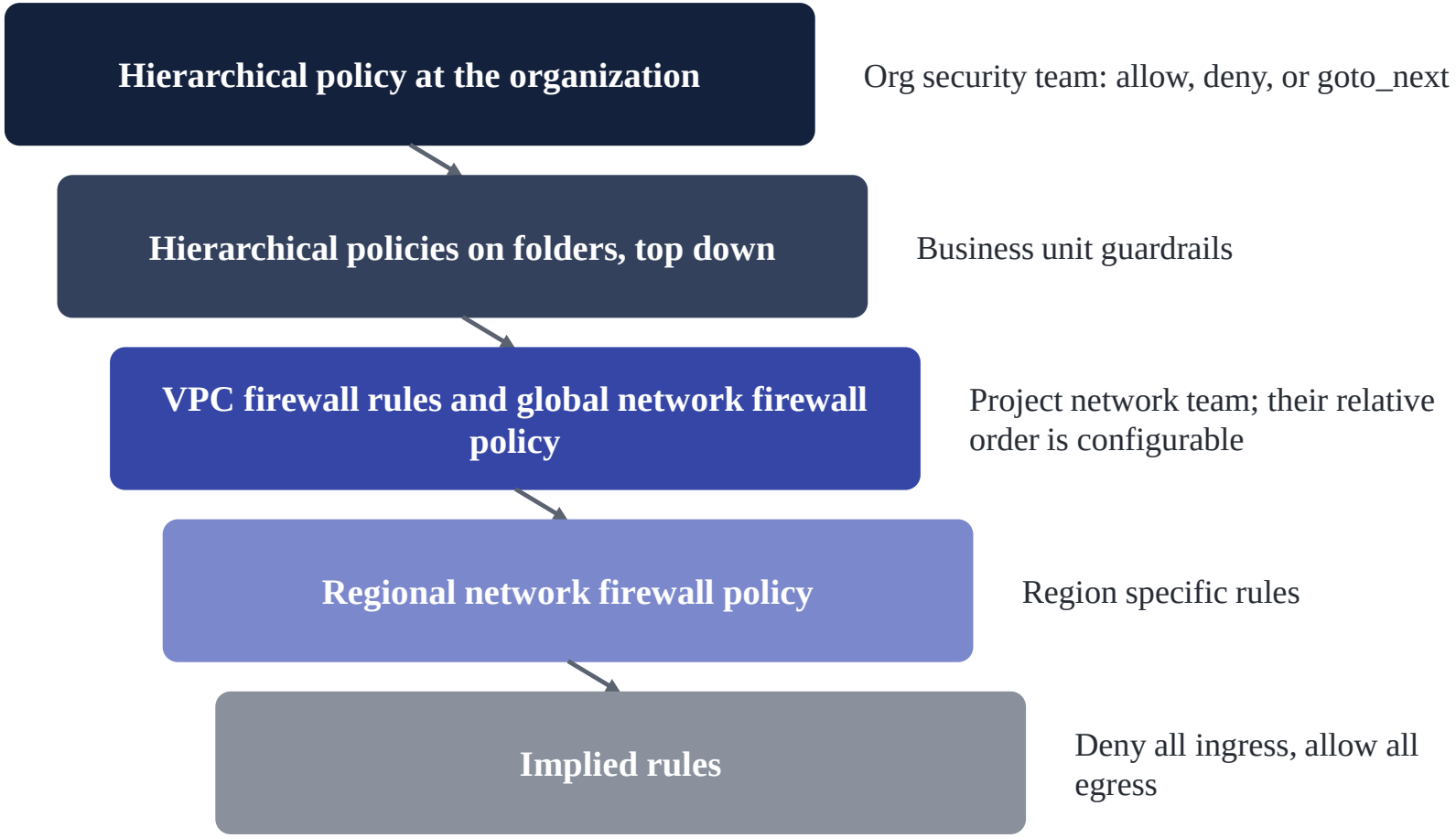
Cloud NGFW: Three Tiers

Capability	Essentials	Standard	Enterprise
Stateful L3 and L4 allow and deny rules	Yes	Yes	Yes
Hierarchical, global and regional firewall policies	Yes	Yes	Yes
Address groups and IAM governed secure tags	Yes	Yes	Yes
FQDN objects (allow or deny by domain name)		Yes	Yes
Geolocation objects (by country)		Yes	Yes
Threat intelligence lists (known bad IPs, Tor exit nodes)		Yes	Yes
Intrusion prevention with layer 7 inspection			Yes
TLS inspection of encrypted traffic			Yes

Exam cue

Block by country or by domain: Standard. Detect and block exploits and malware inside traffic: Enterprise.

Firewall Policy Evaluation Order



Within one policy

- Lowest priority number wins
- First match decides: allow, deny or goto_next
- goto_next hands the decision to the next level

Why it matters

A deny in the organization policy cannot be overridden by any project. Put non negotiable rules (block SSH from the internet) at the top.

Targeting Rules: Tags, Service Accounts and Secure Tags

Network tags

- Free text strings on a VM
- Anyone who can edit the VM can add a tag and gain the rule
- No IAM control over who applies them
- Fine for labs, weak for security boundaries

Service accounts

- Rule targets VMs running as a given service account
- Changing the account needs actAs on it, an IAM check
- Stronger identity based segmentation
- Supported in VPC rules and firewall policies

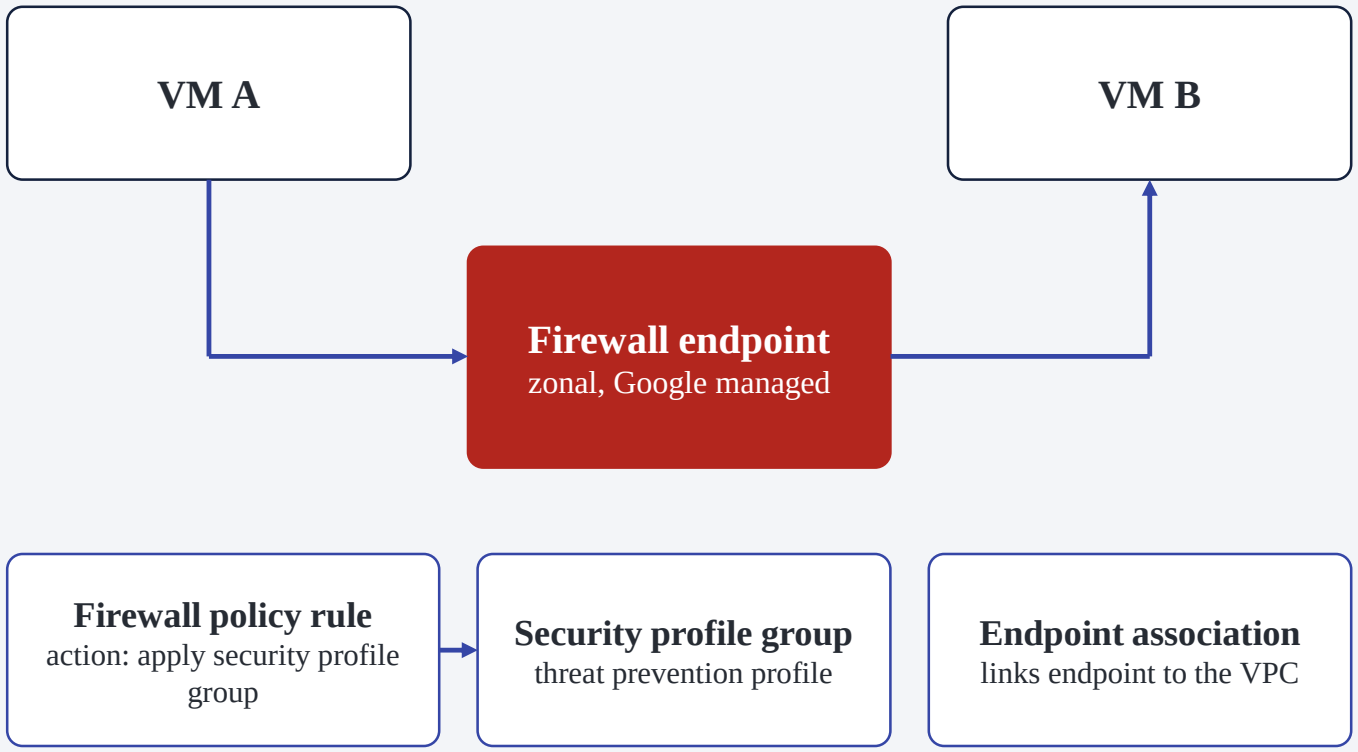
Secure tags

- Resource Manager tags bound to VMs
- IAM controls who can create and bind each tag value
- Used in network firewall policies
- Best choice for scalable, governed micro segmentation

Exam reflex

If an option says "developers could add the tag themselves", the fix is to target by service account or secure tag, because both are protected by IAM.

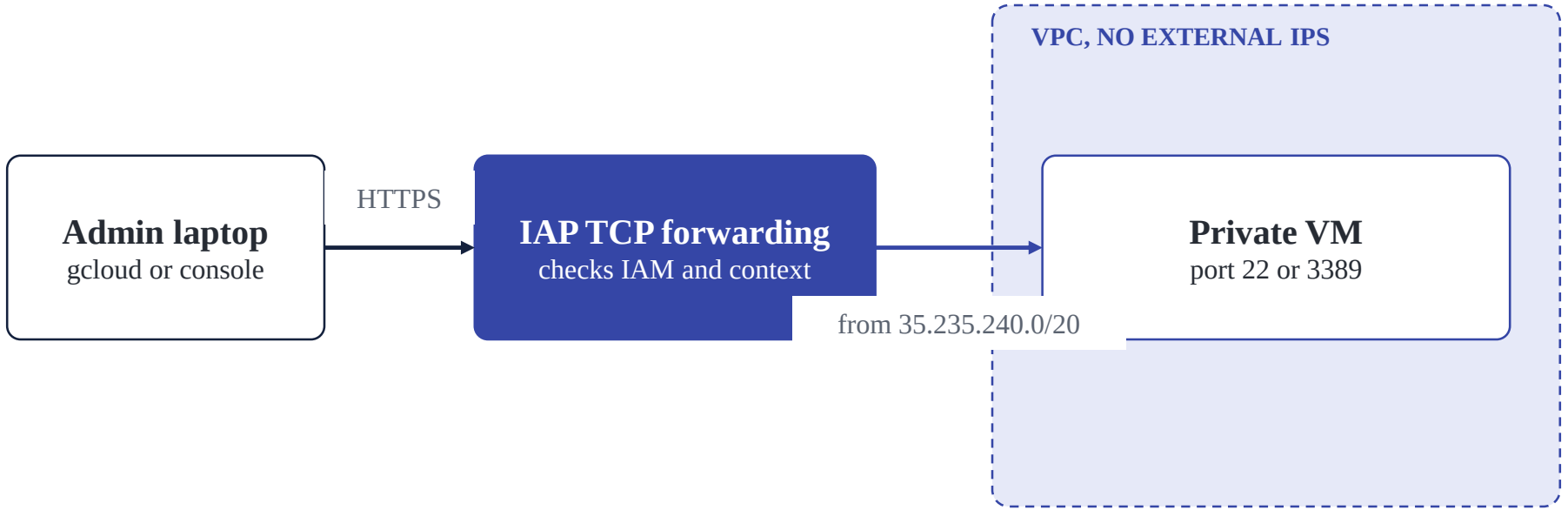
Layer 7 Inspection with Cloud NGFW Enterprise



Optional TLS inspection decrypts traffic using a CA pool from Certificate Authority Service.

1. **Create** a firewall endpoint in each zone you need, at the organization level.
2. **Associate** it with the VPC network in that zone.
3. **Define** a threat prevention security profile (severity actions, overrides) inside a profile group.
4. **Write** a firewall policy rule whose action applies that profile group to matching traffic.
5. **Review** threat logs in Cloud Logging; matched threats are alerted or blocked.

Identity Aware Proxy for SSH and RDP

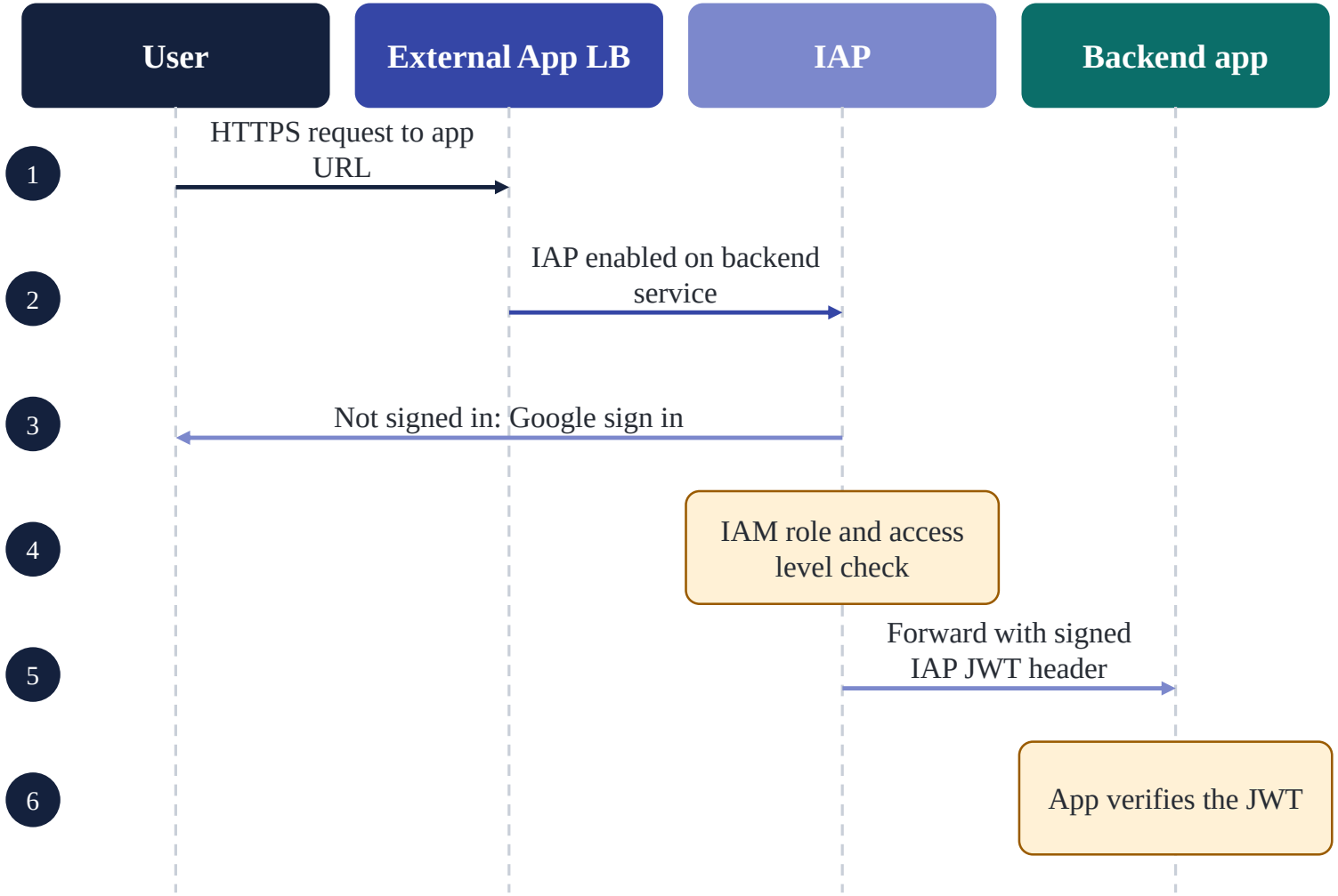


Replaces

- Bastion hosts
- External IPs on VMs
- Per user VPN for admin access

1. **Firewall:** allow ingress from 35.235.240.0/20 to the SSH or RDP port only.
2. **IAM:** grant IAP Secured Tunnel User to the admins group, optionally with a condition on destination port or instance.
3. **OS Login** ties Linux accounts to Google identities and 2SV.
4. **Result:** no bastion host, no public IPs, every session in audit logs.

Identity Aware Proxy for Web Applications



Configure

- Enable IAP on the backend service
- Grant IAP Secured Web App User to groups
- Add an access level for device or location

Do not forget

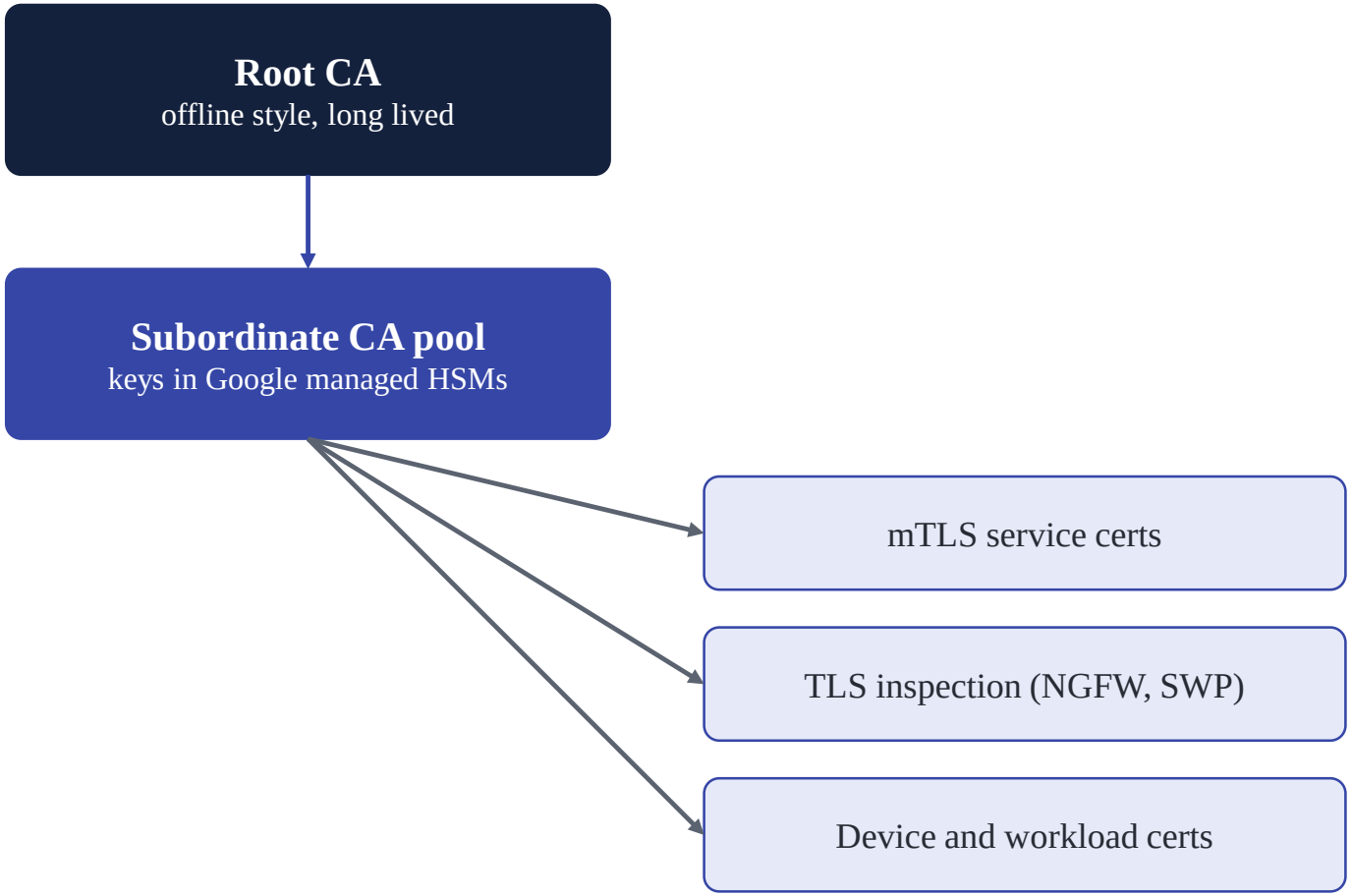
Block direct paths that bypass the load balancer with firewall rules, and verify the signed header in the app.

Load Balancers as Security Control Points

Load balancer	Scope	Security features
Global external Application LB	Internet, HTTP(S), proxy	Cloud Armor backend and edge policies, IAP, SSL policies, Google managed certificates, Cloud CDN
Regional external Application LB	Internet, one region	Cloud Armor, IAP, regional data residency for TLS termination
External proxy Network LB	Internet, TCP or SSL	TLS offload, Cloud Armor for some protections
External passthrough Network LB	Internet, regional, keeps client IP	Firewall rules on backends; network edge security policies with advanced DDoS protection
Internal Application LB	Private, HTTP(S)	Internal TLS, IAP, service to service policies
Internal passthrough Network LB	Private, TCP or UDP	Firewall rules; next hop for appliances

SSL policies set the minimum TLS version and cipher profile (Compatible, Modern, Restricted or Custom) on proxy load balancers. "Disable TLS 1.0 and 1.1" is an SSL policy answer.

Certificate Authority Service and Certificate Manager



Tier	Built for
Enterprise	Long lived certificates, revocation lists, CA hierarchies
DevOps	High volume, short lived certificates; no revocation tracking

Certificate Manager

- Public certificates for load balancers
- Google managed (DNS authorization) or your own
- Trust configs for client mTLS validation
- Use CAS when you need your own private PKI

Private and Public IP Addressing

Private (internal) addresses

- RFC 1918: 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16
- Reachable only inside the VPC, peered VPCs, or over VPN and Interconnect
- Default choice for every workload

Public (external) addresses

- Ephemeral or static; regional, or global for load balancers
- Exposed to the internet, so they need firewall and Cloud Armor
- Give them to load balancers, not to VMs

Reaching out without exposure

- Cloud NAT for internet egress
- Private Google Access or PSC for Google APIs
- IAP for admin access in

Enforce it

Organization policy compute.vmExternalIpAccess lets only listed VMs, or none, hold external IPs. Pair it with sql.restrictPublicIp for Cloud SQL. "No public IPs anywhere" in a stem points here.

Google Cloud Armor: The Request Pipeline



Preconfigured WAF rules

OWASP based signatures for SQL injection, cross site scripting, local file inclusion, remote code execution, with tunable sensitivity.

Rate limiting

Throttle clients above a threshold, or ban them for a period after they exceed it. Keys: IP, header, cookie and more.

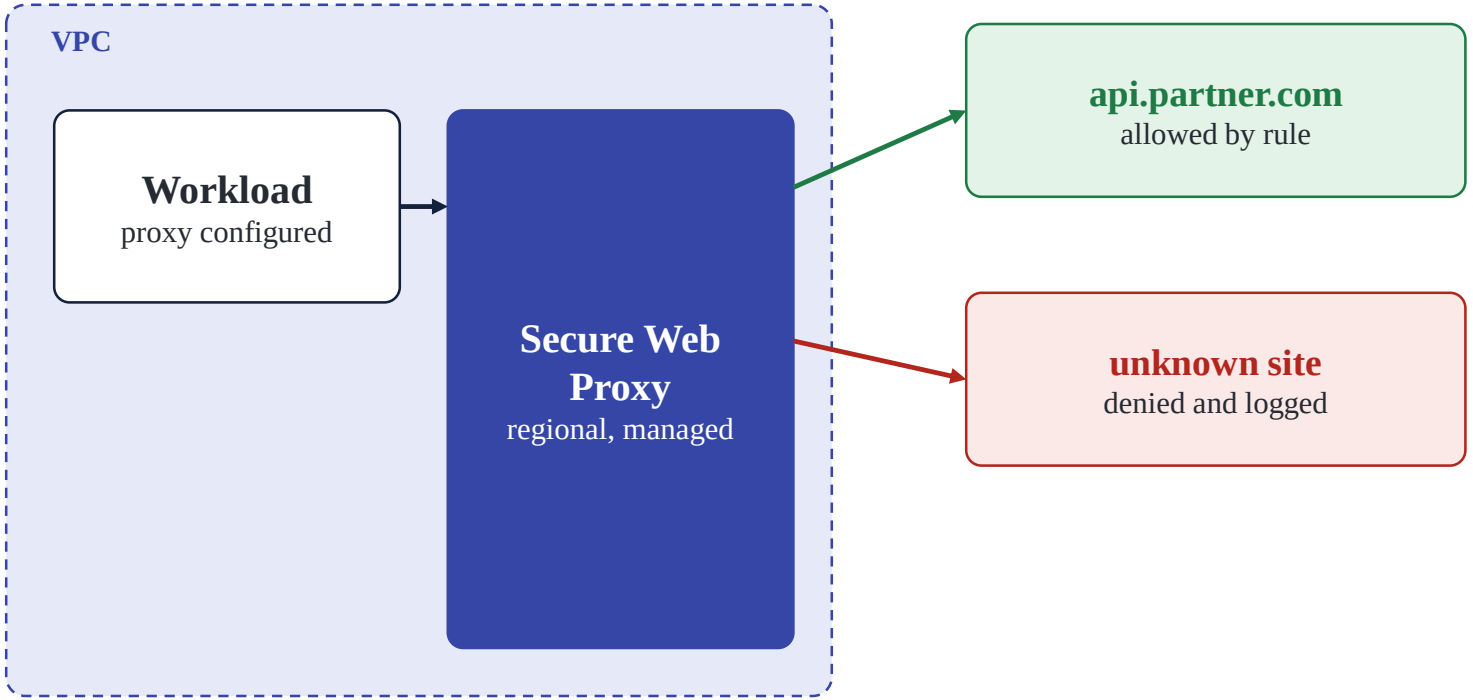
Adaptive Protection

Machine learning baselines normal traffic, alerts on layer 7 DDoS, and suggests a rule you can deploy.

Preview mode

Log what a rule would do without enforcing it. Tune false positives first, then enforce.

Secure Web Proxy: Governed Egress



1. **Policy rules** use CEL session matching on host or SNI, source secure tags or service accounts.
2. **URL lists** hold allowed domains and wildcards.
3. **TLS inspection** (with CAS) lets application matching inspect path and method.
4. **Logs** every request to Cloud Logging for audit.

Choose Secure Web Proxy when

The stem needs egress allowlisting by domain or URL, identity aware egress policy, or inspection of outbound HTTPS. Cloud NAT only translates addresses; it does not filter destinations.

Cloud DNS Security Settings

DNSSEC on public zones

Signs records so resolvers can detect spoofed answers. Enable on the zone and publish the DS record at your registrar.

Private zones

Answer only for authorized VPC networks. Internal names never leak to the internet.

Response policies

Override answers inside a VPC: block known bad domains, or point googleapis.com at restricted.googleapis.com.

Server policies and forwarding

Inbound forwarding lets on premises resolve private zones; outbound forwarding sends selected names to on premises DNS.

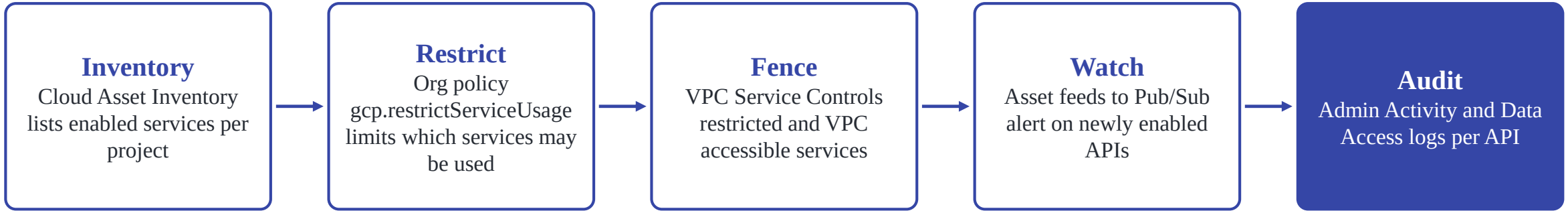
DNS logging

Records queries from VMs for threat hunting and data exfiltration detection.

Hygiene

Remove records pointing at deleted resources (dangling DNS) to prevent subdomain takeover. Limit DNS Admin.

Monitoring and Restricting Configured APIs



API keys done right

- Restrict each key to specific APIs
- Restrict to app identity: referrer, IP, Android or iOS app
- Rotate and delete unused keys
- Prefer service accounts for server to server calls

Your own APIs

- API Gateway or Apigee for authentication, quotas and keys
- Cloud Armor in front of public endpoints
- IAP or ID tokens for internal callers

Case Study 17: No More Bastion

THE SCENARIO

Granite Peak Manufacturing

Administrators reach 200 Linux VMs through a bastion host with a public IP. Auditors flagged the bastion as an exposed attack surface.

The CISO wants no VM, including any bastion, to have an external IP, and every SSH session tied to an individual identity.

What should you do?

A. Remove external IPs, allow ingress on port 22 from 35.235.240.0/20, grant IAP Secured Tunnel User to the admin group, and enable OS Login.

B. Keep the bastion but restrict its firewall rule to the corporate IP range.

C. Give each administrator a Classic VPN tunnel from their laptop.

D. Configure Cloud NAT so administrators can reach the VMs privately.

ANSWER | IDENTITY AWARE PROXY

Case Study 17 Answer: A

A

Remove external IPs, allow ingress on port 22 from 35.235.240.0/20, grant IAP Secured ...

Correct. IAP TCP forwarding needs no public IPs; IAM controls who connects and OS Login ties sessions to individual Google identities.

B

Keep the bastion but restrict its firewall rule to the corporate IP range.

Incorrect. The bastion keeps its public IP, which the CISO wants removed.

C

Give each administrator a Classic VPN tunnel from their laptop.

Incorrect. Per user VPNs are heavy to run and still do not tie SSH to Google identities.

D

Configure Cloud NAT so administrators can reach the VMs privately.

Incorrect. Cloud NAT is outbound only; it never lets anyone connect in.

Exam lesson

Private admin access without bastions is IAP TCP forwarding plus a firewall rule for the IAP range plus OS Login.

Clue words in the stem

"No external IP", "including any bastion", "individual identity"

Case Study 18: The Tag Anyone Could Add

THE SCENARIO

Riverstone Media

A firewall rule allows the payments database port only from VMs with the network tag payments. Developers hold Compute Instance Admin in the same project.

A red team showed that a developer added the tag to an unrelated VM and reached the database.

How should you redesign the rule with the least ongoing effort?

A. Lower the rule priority number so it is evaluated first.

B. Ask developers to sign a policy not to add tags.

C. Add a deny rule for all VMs without the tag.

D. Target the rule using the payments service account, or an IAM governed secure tag in a network firewall policy.

ANSWER | FIREWALL TARGETING

Case Study 18 Answer: D

A

Lower the rule priority number so it is evaluated first.

Incorrect. Priority changes evaluation order, not who can join the rule's target.

B

Ask developers to sign a policy not to add tags.

Incorrect. A procedural control with no technical enforcement.

C

Add a deny rule for all VMs without the tag.

Incorrect. Still relies on tags, which developers can add.

D

Target the rule using the payments service account, or an IAM governed secure tag in a ...

Correct. Joining the rule now requires IAM permission (actAs on the account, or permission to bind the tag), which developers do not have.

Exam lesson

Network tags are not a security boundary. Use service accounts or secure tags so IAM guards rule membership.

Clue words in the stem

"Developers hold Instance Admin", "added the tag"

Case Study 19: One Rule for the Whole Company

THE SCENARIO

Coastal Water Authority

Coastal has 150 projects, each with its own VPC managed by project teams. Security requires that SSH and RDP from the internet are blocked everywhere, with no exceptions possible at project level.

Traffic on these ports from the corporate VPN range may be allowed, but that decision is left to each project team.

What should you do?

A. Create a deny rule in each VPC with priority 0 using a Terraform module.

B. Create an organization hierarchical firewall policy: a higher priority goto_next rule for the VPN range on ports 22 and 3389, then a deny for those ports from 0.0.0.0/0.

C. Put Cloud Armor in front of every VM.

D. Create an organization policy constraint that blocks SSH.

ANSWER | HIERARCHICAL FIREWALL POLICIES

Case Study 19 Answer: B

A

Create a deny rule in each VPC with priority 0 using a Terraform module.

Incorrect. Project owners could delete or override those rules; 150 copies is also heavy to maintain.

B

Create an organization hierarchical firewall policy: a higher priority goto_next rule ...

Correct. Evaluated before every project rule; the deny cannot be overridden, while goto_next hands VPN traffic to the project teams to decide.

C

Put Cloud Armor in front of every VM.

Incorrect. Cloud Armor protects load balancer backends, not direct SSH to VMs.

D

Create an organization policy constraint that blocks SSH.

Incorrect. No organization policy constraint filters network traffic by port.

Exam lesson

Non negotiable network guardrails across many projects belong in hierarchical firewall policies.

Clue words in the stem

"Everywhere", "no exceptions possible at project level", "left to each project team"

Case Study 20: Exploits Moving East to West

THE SCENARIO

Halcyon Pharma

After an incident, Halcyon must detect and block known exploits and malware in traffic between application tiers inside its VPC, including encrypted traffic.

The team wants a managed service, not third party appliances to patch and scale.

What should you implement?

A. Cloud IDS with Packet Mirroring for all subnets.

B. A pair of next generation firewall VMs from the Marketplace with internal load balancers.

C. Google Cloud Armor preconfigured WAF rules on every internal service.

D. Cloud NGFW Enterprise: firewall endpoints associated with the VPC, a threat prevention security profile group, rules that apply it, and TLS inspection.

ANSWER | CLOUD NGFW ENTERPRISE

Case Study 20 Answer: D

A

Cloud IDS with Packet Mirroring for all subnets.

Incorrect. Cloud IDS detects and alerts, but does not block.

B

A pair of next generation firewall VMs from the Marketplace with internal load balancers.

Incorrect. Works, but these are exactly the appliances the team does not want to run.

C

Google Cloud Armor preconfigured WAF rules on every internal service.

Incorrect. Cloud Armor attaches to load balancers for inbound web traffic, not to arbitrary east west flows.

D

Cloud NGFW Enterprise: firewall endpoints associated with the VPC, a threat prevention ...

Correct. NGFW Enterprise inspects at layer 7, blocks threats inline, decrypts with TLS inspection, and is fully managed.

Exam lesson

Detect only: Cloud IDS. Detect and block inline, managed: Cloud NGFW Enterprise intrusion prevention.

Clue words in the stem

"Detect and block", "between tiers", "encrypted", "managed"

Case Study 21: The Login Page Under Attack

THE SCENARIO

Tallis Travel

Tallis serves its booking site through a global external Application Load Balancer. Logs show SQL injection attempts and a burst of 20,000 login requests per minute from rotating IPs.

Tallis wants to block the attacks at the edge and protect legitimate customers.

Which approach should you take?

A. Attach a Cloud Armor security policy with the preconfigured SQL injection rule, a rate based ban on the login path, and enable Adaptive Protection.

B. Move the site behind Cloud NAT so it has no public IP.

C. Create VPC firewall rules denying the attacking IP addresses.

D. Enable Identity Aware Proxy on the load balancer.

ANSWER | GOOGLE CLOUD ARMOR

Case Study 21 Answer: A

A

Attach a Cloud Armor security policy with the preconfigured SQL injection rule, a rate ...

Correct. WAF rules stop injection; rate based bans stop credential stuffing bursts; Adaptive Protection spots and suggests rules for new L7 attacks.

B

Move the site behind Cloud NAT so it has no public IP.

Incorrect. Cloud NAT is for outbound traffic and cannot host a public website.

C

Create VPC firewall rules denying the attacking IP addresses.

Incorrect. Proxy load balancers terminate connections, so backend firewall rules see Google proxy addresses; rotating IPs also defeat static lists.

D

Enable Identity Aware Proxy on the load balancer.

Incorrect. IAP requires users to sign in with Google identities, which would block public customers.

Exam lesson

Public web apps behind an external Application Load Balancer are protected at layer 7 by Cloud Armor.

Clue words in the stem

"SQL injection", "requests per minute", "at the edge", "legitimate customers"

Case Study 22: Only These URLs Out

THE SCENARIO

Ardent Clinical Research

Batch VMs upload results to a vendor at api.vendor.example over HTTPS. Policy says the VMs may reach only the path for uploads on that host, and every request must be logged.

All other internet egress must be denied.

What should you deploy?

A. A Cloud Armor policy on the VMs.

B. A Cloud NGFW Standard egress rule with an FQDN object for api.vendor.example.

C. Secure Web Proxy with TLS inspection, a rule matching the host and upload path, and a default deny.

D. Cloud NAT with manual static IP addresses.

ANSWER | SECURE WEB PROXY

Case Study 22 Answer: C

A

A Cloud Armor policy on the VMs.

Incorrect. Cloud Armor protects inbound traffic to load balancers, not outbound traffic from VMs.

B

A Cloud NGFW Standard egress rule with an FQDN object for api.vendor.example.

Incorrect. FQDN objects filter by domain at layers 3 and 4; they cannot see the URL path inside HTTPS.

C

Secure Web Proxy with TLS inspection, a rule matching the host and upload path, and a ...

Correct. With TLS inspection Secure Web Proxy can match host and path, deny everything else, and log each request.

D

Cloud NAT with manual static IP addresses.

Incorrect. NAT translates addresses; it does not restrict destinations or paths.

Exam lesson

Domain only egress: NGFW FQDN objects can work. Path level, inspected, logged egress: Secure Web Proxy.

Clue words in the stem

"Only the path", "every request logged", "HTTPS"

Case Study 23: Forged Answers

THE SCENARIO

Lindenfield Bank

Lindenfield hosts its public domain in a Cloud DNS public zone. A threat report warns that attackers are poisoning resolver caches to redirect customers to a fake banking site.

Lindenfield wants resolvers to be able to verify that answers really came from its zone.

What should you do?

A. Enable Cloud DNS query logging.

B. Enable DNSSEC on the public zone and add the DS record at the domain registrar.

C. Convert the zone to a private zone.

D. Create a DNS response policy that blocks the fake site.

ANSWER | CLOUD DNS

Case Study 23 Answer: B

A

Enable Cloud DNS query logging.

Incorrect. Logging records your own VPC queries; it does not protect external resolvers.

B

Enable DNSSEC on the public zone and add the DS record at the domain registrar.

Correct. DNSSEC signs the zone; with the DS record published at the parent, validating resolvers reject forged answers.

C

Convert the zone to a private zone.

Incorrect. Customers on the internet could no longer resolve the domain at all.

D

Create a DNS response policy that blocks the fake site.

Incorrect. Response policies affect only resolvers inside your own VPC networks, not customers.

Exam lesson

Authenticity of public DNS answers is DNSSEC. Remember the second half: the DS record at the registrar.

Clue words in the stem

"Verify that answers really came from its zone", "public"

Security Properties of a VPC Network

Global network, regional subnets

One VPC spans regions; each subnet lives in one region. Routes and firewall rules are network wide.

Custom mode, not auto mode

Auto mode creates a subnet in every region with fixed ranges that can clash with peers and on premises. Plan ranges yourself.

Delete the default network

It is auto mode and ships with rules allowing SSH, RDP and ICMP from anywhere. Block it with compute.skipDefaultNetworkCreation.

Per subnet switches

Private Google Access and VPC Flow Logs are enabled per subnet. Turn both on where workloads live.

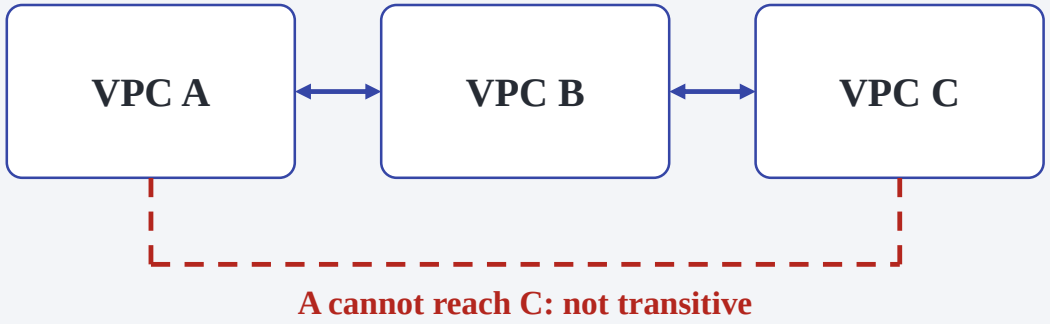
Default network rules
allow internal, SSH, RDP, ICMP from 0.0.0.0/0

→

Secure baseline
custom mode VPC, deny by default, explicit allows by service account or secure tag, flow logs on

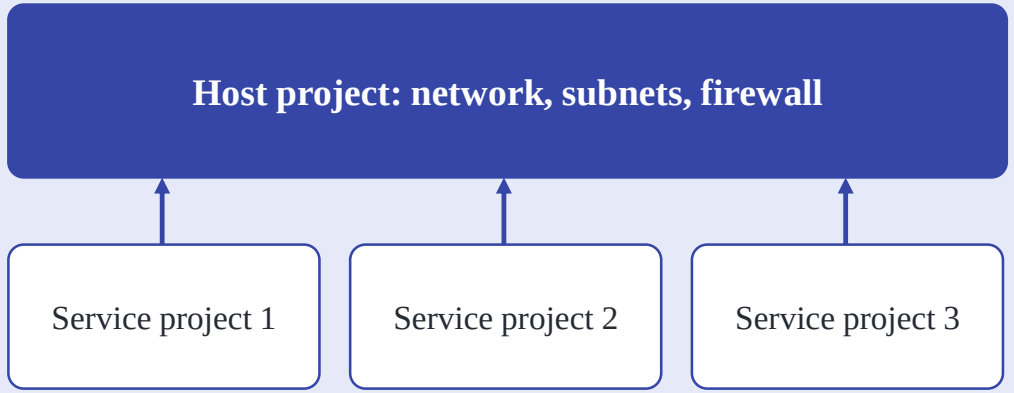
VPC Peering versus Shared VPC

VPC Network Peering



Each side keeps its own firewall and IAM. Ranges must not overlap.

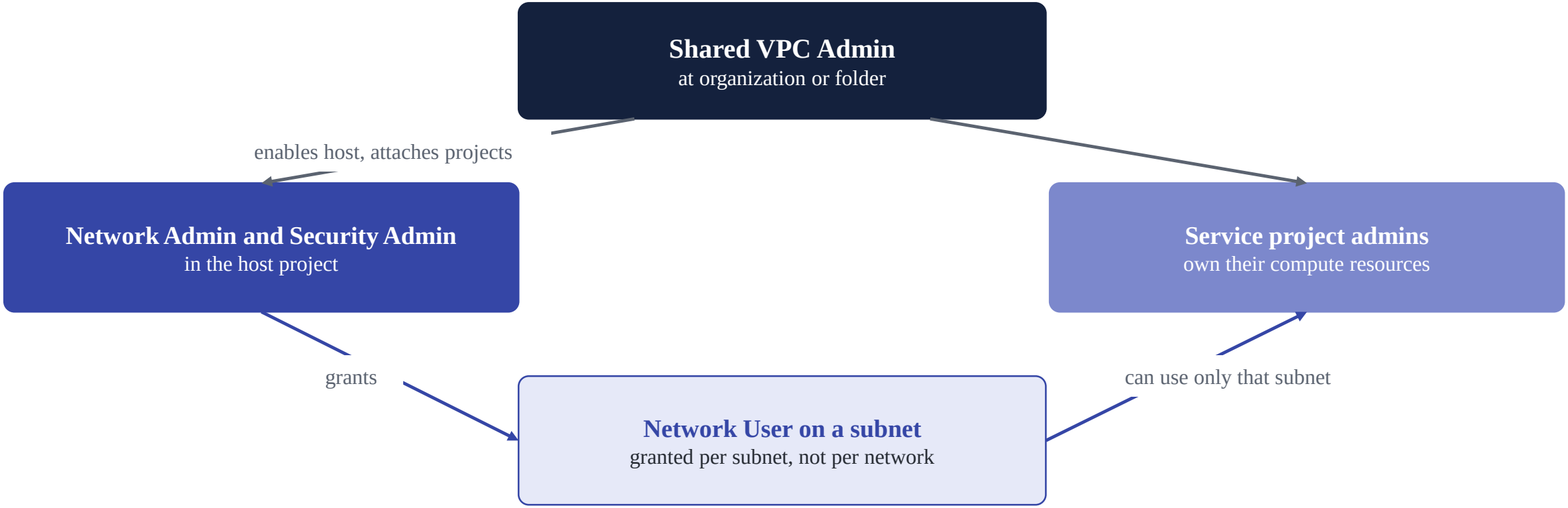
Shared VPC



Central network control; app teams deploy into shared subnets.

	VPC Peering	Shared VPC
Across organizations	Yes	No, same organization only
Who controls firewall	Each network owner	Central network admins in the host project
Best for	Connecting separately owned networks	One governed network for many projects

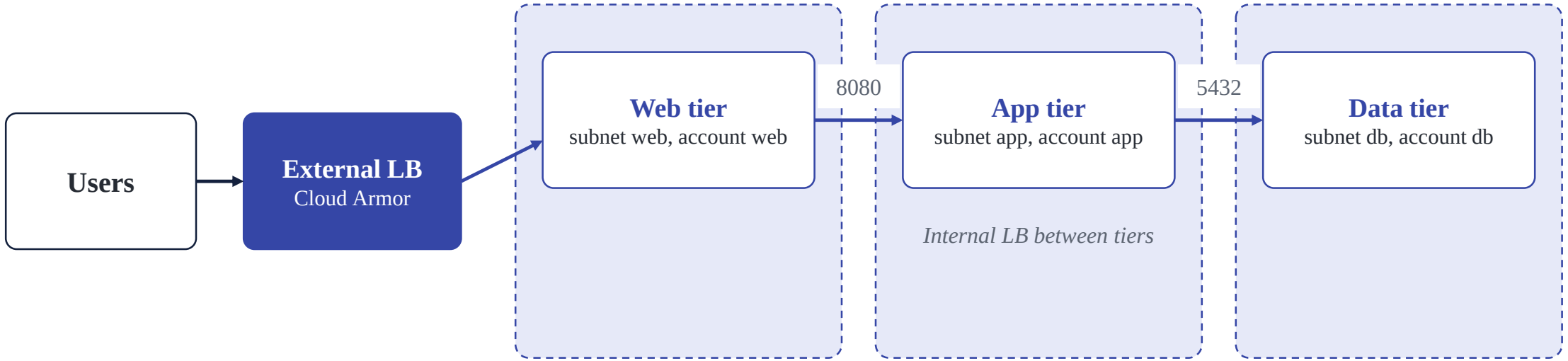
Shared VPC Roles and Delegation



Least privilege pattern

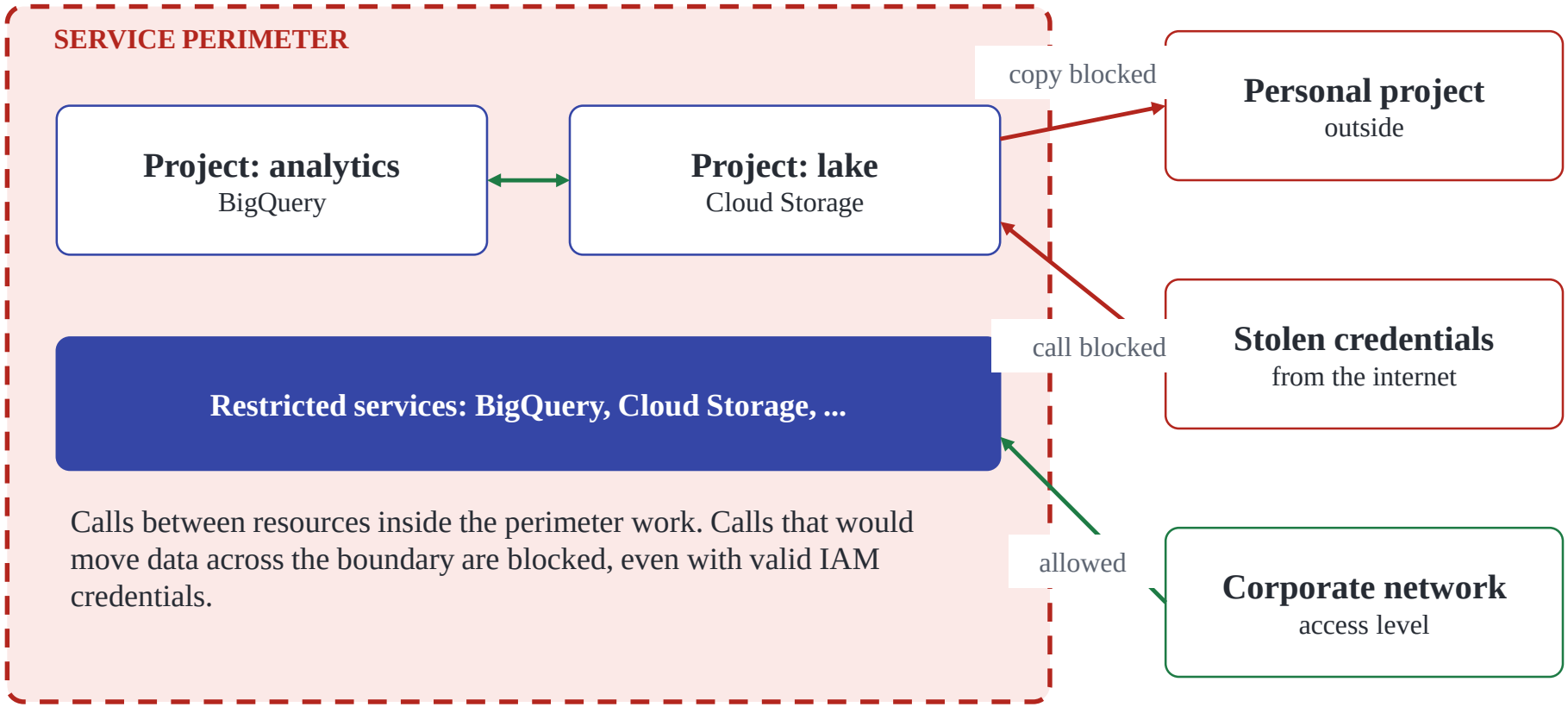
Grant Compute Network User on individual subnets to each service project team, so payments cannot deploy into the analytics subnet.

Isolating an N Tier Application



Rule	Source	Target	Port
Allow LB and health checks	Google front end ranges	web account	443
Allow web to app	web account	app account	8080
Allow app to data	app account	db account	5432
Deny everything else	any	any	all

VPC Service Controls: Fencing the APIs

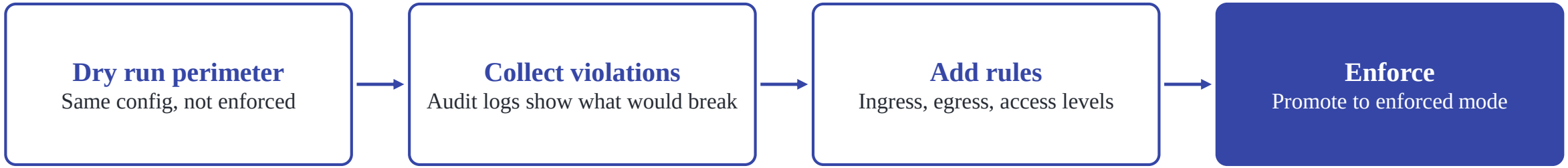


1. Protects **Google APIs**, not VM to VM packets.
2. Stops **exfiltration** by insiders and stolen credentials.
3. Complements IAM; it does not replace it.
4. Logged as **VPC SC violations** in audit logs.

One line definition: IAM decides who may call an API; VPC Service Controls decides from where, and to where, the data may flow.

Ingress Rules, Egress Rules and Dry Run

Element	Ingress rule (into the perimeter)	Egress rule (out of the perimeter)
From	Identities and sources: access levels or projects	Identities inside the perimeter
To	Protected resources and services, optionally methods	External projects and services, optionally methods
Typical use	A partner project writes to one bucket	A pipeline reads a public dataset outside



Prefer ingress and egress rules over perimeter bridges. Rules are precise (identity, resource, method); bridges open all restricted services between two perimeters.

Firewall, IAM and VPC Service Controls Compared

	Cloud NGFW	IAM	VPC Service Controls
Protects	Packets to and from VM interfaces	Every API call, by identity	Google API calls, by context and data flow
Question answered	Can this IP and port talk?	Is this identity allowed this permission?	Can data move across this boundary?
Stops stolen credential misuse from outside	No	No, credentials are valid	Yes, with access levels
Stops copying data to another project	No	Only if IAM on the target is denied	Yes
Typical exam phrase	"Block port", "segment tiers"	"Least privilege", "who can"	"Exfiltration", "even with valid credentials"

Defence in depth: strong designs use all three. Exam answers pick the one that matches the threat in the stem.

Case Study 24: Copying the Crown Jewels

THE SCENARIO

Oakridge Genomics

Researchers with legitimate BigQuery Data Viewer access could run a query and save results to a dataset in a personal project, or copy files to a personal bucket.

Oakridge must prevent sensitive data leaving its research projects, even by users with valid credentials, without removing their read access.

What should you do?

A. Create egress firewall rules that deny all traffic from the research VPC.

B. Add an IAM deny policy that denies bigquery.tables.export to all researchers.

C. Create a VPC Service Controls perimeter around the research projects that restricts BigQuery and Cloud Storage.

D. Run Sensitive Data Protection scans on the datasets weekly.

ANSWER | VPC SERVICE CONTROLS

Case Study 24 Answer: C

A

Create egress firewall rules that deny all traffic from the research VPC.

Incorrect. BigQuery and Cloud Storage are Google APIs, not traffic from the VPC; firewall rules do not apply.

B

Add an IAM deny policy that denies bigquery.tables.export to all researchers.

Incorrect. Covers one permission path; query results can still be written to another project and files copied in other ways.

C

Create a VPC Service Controls perimeter around the research projects that restricts ...

Correct. The perimeter blocks API operations that move data to resources outside it, regardless of the caller's IAM grants.

D

Run Sensitive Data Protection scans on the datasets weekly.

Incorrect. Discovery helps classification but prevents nothing.

Exam lesson

Data exfiltration through Google APIs by authorized users is the textbook VPC Service Controls scenario.

Clue words in the stem

"Even by users with valid credentials", "leaving its projects"

Case Study 25: A Partner Needs One Bucket

THE SCENARIO

Sterling Freight

Sterling's logistics projects are inside a VPC Service Controls perimeter. A partner runs a job from its own Google Cloud project, outside any perimeter, that must upload files to one Sterling bucket.

Nothing else in the perimeter should be reachable by the partner.

What should you configure?

A. Add an ingress rule that allows the partner's service account, from the partner project, to call Cloud Storage object create methods on that bucket only.

B. Create a perimeter bridge between Sterling's perimeter and the partner project.

C. Remove the bucket's project from the perimeter.

D. Add an access level that allows all traffic from the partner's IP ranges.

ANSWER | VPC SC INGRESS RULES

Case Study 25 Answer: A

A

Add an ingress rule that allows the partner's service account, from the partner project, ...

Correct. Ingress rules can be scoped to identity, source, resource and method: exactly the narrow path required.

B

Create a perimeter bridge between Sterling's perimeter and the partner project.

Incorrect. Bridges connect two perimeters; the partner project is in none, and bridges are broad.

C

Remove the bucket's project from the perimeter.

Incorrect. Removes protection from everything else in that project.

D

Add an access level that allows all traffic from the partner's IP ranges.

Incorrect. An access level by IP admits any identity from those ranges to all restricted services.

Exam lesson

Narrow cross boundary access is an ingress or egress rule scoped by identity, source, resource and method.

Clue words in the stem

"Outside any perimeter", "one bucket", "nothing else"

Case Study 26: Do Not Break Production

THE SCENARIO

Mirador Analytics

Mirador will place 40 production projects inside a new VPC Service Controls perimeter. Many pipelines call services across projects and from on premises.

Leadership will not accept outages caused by the rollout.

What should you do first?

A. Create the perimeter in enforced mode during a weekend change window.

B. Postpone VPC Service Controls and rely on IAM instead.

C. Create one perimeter per project to limit blast radius.

D. Create the perimeter in dry run mode, analyse the violation logs, add the needed access levels and rules, then enforce.

ANSWER | VPC SC ROLLOUT

Case Study 26 Answer: D

A

Create the perimeter in enforced mode during a weekend change window.

Incorrect. Enforcing blind is how outages happen, weekend or not.

B

Postpone VPC Service Controls and rely on IAM instead.

Incorrect. Abandons the exfiltration protection the business wants.

C

Create one perimeter per project to limit blast radius.

Incorrect. Forty perimeters break the cross project calls that must work, and adds overhead.

D

Create the perimeter in dry run mode, analyse the violation logs, add the needed access ...

Correct. Dry run records what would be blocked without blocking it, so every legitimate flow can be allowed before enforcement.

Exam lesson

New perimeters start in dry run. Violations in logs become the to do list for rules before enforcement.

Clue words in the stem

"Will not accept outages", "many pipelines", "first"

Case Study 27: One Network, Many Teams

THE SCENARIO

Clearwater Retail

Clearwater has twelve application teams, each with its own projects. A central network team must own all IP ranges, routes, firewall policies and hybrid connectivity.

Each application team must deploy only into its own subnets.

Which design should you use?

A. A VPC per team, all peered to each other in a full mesh.

B. Shared VPC with a host project managed by the network team, service projects for each team, and Compute Network User granted per subnet.

C. One project for all teams with the Network Admin role granted to every team.

D. A VPC per team, each with its own HA VPN to on premises.

ANSWER | SHARED VPC

Case Study 27 Answer: B

A

A VPC per team, all peered to each other in a full mesh.

Incorrect. Mesh peering is complex, non transitive and leaves firewall control with each team.

B

Shared VPC with a host project managed by the network team, service projects for each ...

Correct. Central control of the network, delegated use of specific subnets: exactly the requirement.

C

One project for all teams with the Network Admin role granted to every team.

Incorrect. Removes project isolation and gives everyone power over the network.

D

A VPC per team, each with its own HA VPN to on premises.

Incorrect. Duplicates hybrid connectivity and loses central control.

Exam lesson

Central network ownership plus decentralised workloads is Shared VPC with per subnet Network User grants.

Clue words in the stem

"Central network team must own", "only into its own subnets"

Case Study 28: Why Can A Not Reach C?

THE SCENARIO

Ferris Media

VPC A (tools) is peered with VPC B (shared services). VPC B is peered with VPC C (production). Firewall rules in all three networks allow the traffic.

Engineers in VPC A still cannot reach servers in VPC C, though both can reach VPC B.

What explains this, and what is a correct fix?

A. Firewall rules are shared across peered networks and are conflicting.

B. Peering does not exchange subnet routes; add static routes in VPC A.

C. Peering requires Cloud NAT; add a NAT gateway in VPC B.

D. VPC peering is not transitive; create a direct peering between A and C, or redesign with a hub such as Network Connectivity Center.

ANSWER | VPC PEERING

Case Study 28 Answer: D

A

Firewall rules are shared across peered networks and are conflicting.

Incorrect. Each network keeps its own firewall; rules are not shared.

B

Peering does not exchange subnet routes; add static routes in VPC A.

Incorrect. Subnet routes are exchanged automatically between directly peered networks.

C

Peering requires Cloud NAT; add a NAT gateway in VPC B.

Incorrect. Cloud NAT has nothing to do with peering.

D

VPC peering is not transitive; create a direct peering between A and C, or redesign with ...

Correct. Traffic cannot pass through B to reach C; only directly peered networks exchange routes.

Exam lesson

Peering is one hop only. Transitive designs need direct peerings, a hub, or appliances that route.

Clue words in the stem

"A to B works, B to C works, A to C fails"

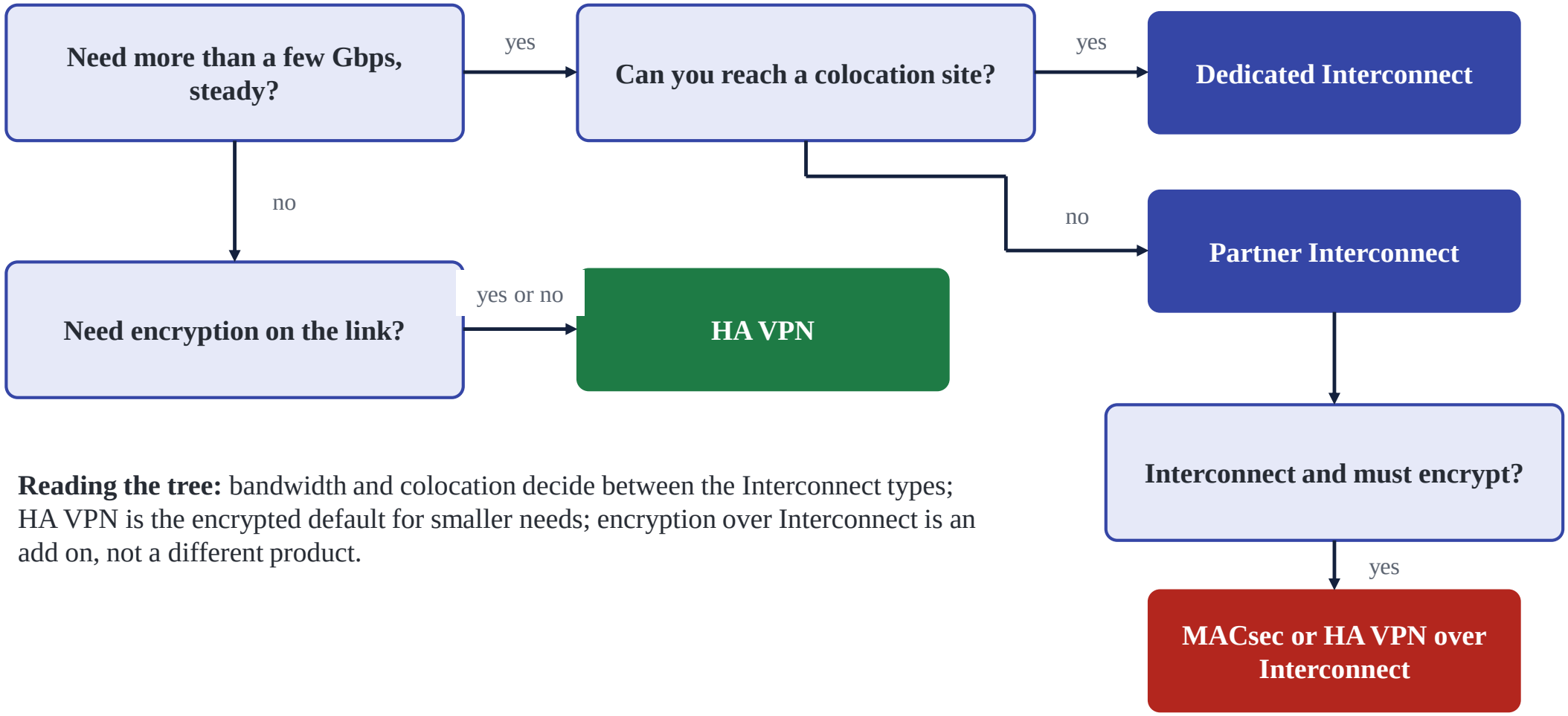
Hybrid Connectivity Options

Option	Bandwidth	Encrypted by default?	Choose when
HA VPN	Up to about 3 Gbps per tunnel; add tunnels	Yes, IPsec	Fast setup, encrypted, 99.99% SLA with two tunnels
Dedicated Interconnect	10 or 100 Gbps circuits	No	Large steady traffic, you can reach a colocation facility
Partner Interconnect	50 Mbps to 50 Gbps	No	No colocation presence; use a provider
Cross Cloud Interconnect	10 or 100 Gbps	No	Private link to another cloud provider
HA VPN over Interconnect	Interconnect capacity	Yes, IPsec	Interconnect plus encryption requirement
MACsec for Interconnect	Interconnect capacity	Yes, layer 2	Encryption between your router and Google edge

Exam trap

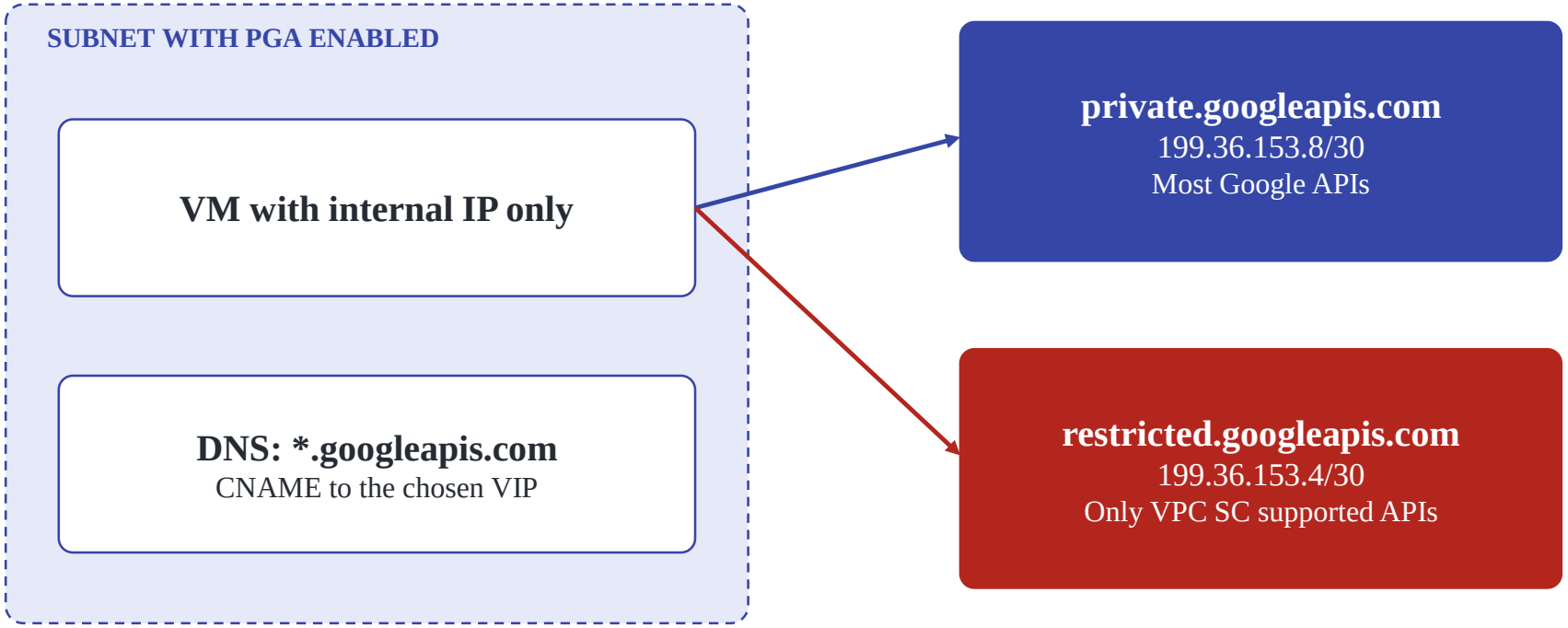
Interconnect is private but not encrypted. If the stem demands encryption over Interconnect, add MACsec or HA VPN over Interconnect.

Decision Tree: Which Hybrid Link?



Reading the tree: bandwidth and colocation decide between the Interconnect types; HA VPN is the encrypted default for smaller needs; encryption over Interconnect is an add on, not a different product.

Private Google Access: Two Virtual IP Ranges

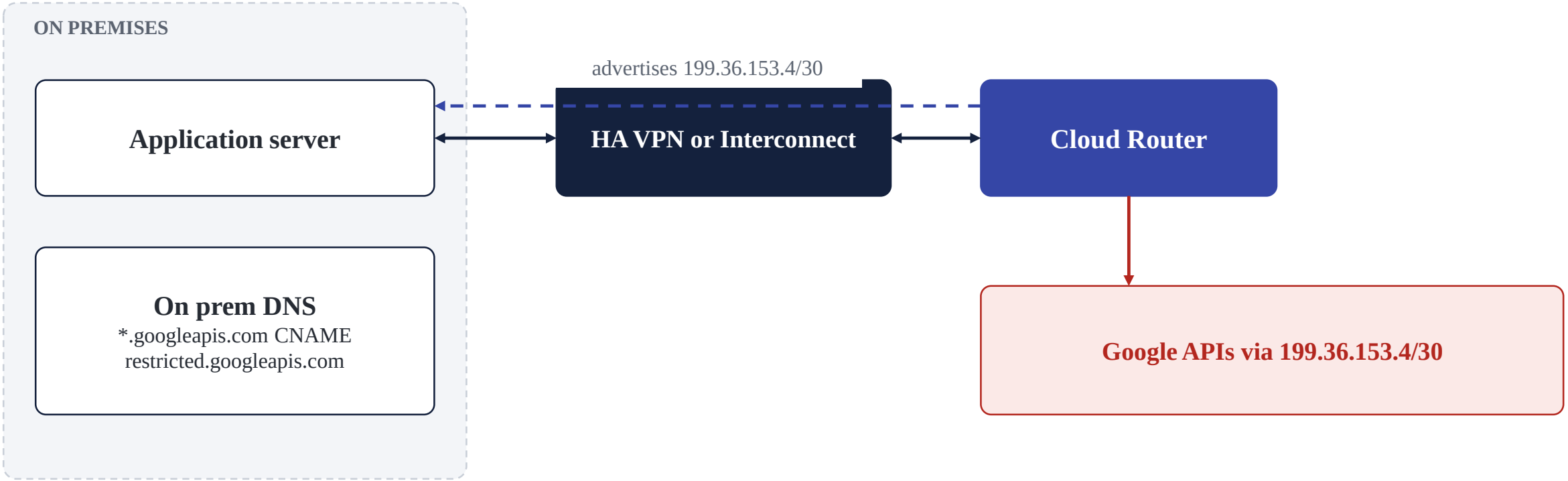


Pick restricted when

The project is in a VPC Service Controls perimeter. Calls to services that the perimeter cannot protect simply fail, closing the gap.

1. **Enable PGA** on the subnet; the VM needs no external IP and no NAT for Google APIs.
2. **Route** the VIP range to the default internet gateway; traffic still stays on Google's network.
3. **DNS** decides which VIP is used, typically with a private zone for googleapis.com.

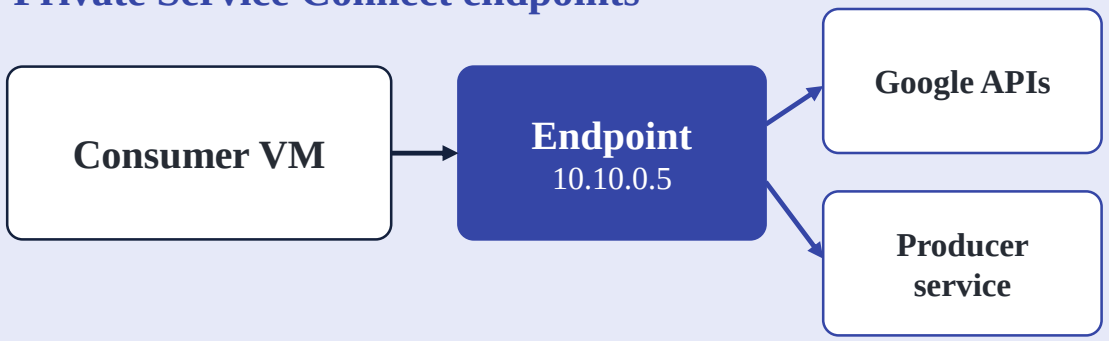
Private Google Access for On Premises Hosts



1. **Custom route advertisement** on Cloud Router sends the VIP range to on premises over BGP.
2. **On premises DNS** maps googleapis.com names to the restricted (or private) VIP.
3. **VPC route** for the VIP to the default internet gateway must exist in the VPC.
4. **Traffic never crosses the public internet,** and VPC SC can apply to it.

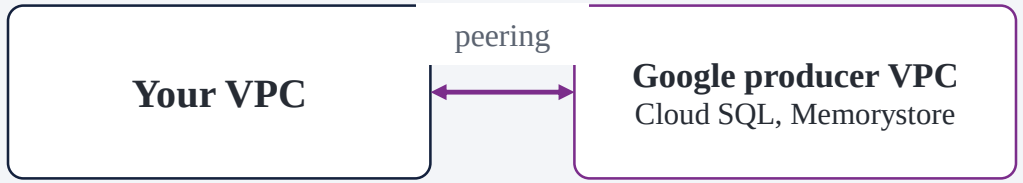
Private Service Connect and Private Services Access

Private Service Connect endpoints



An internal IP in your own subnet. No peering, so overlapping ranges are fine and the consumer cannot reach anything but the published service.

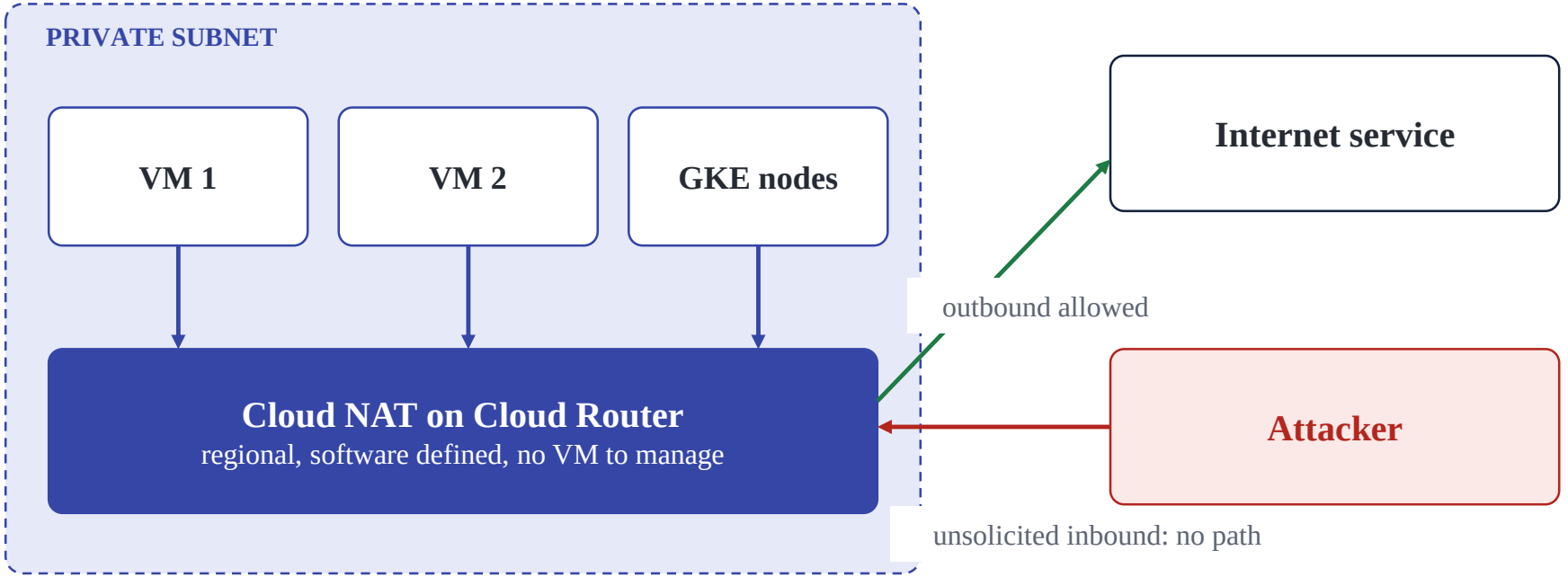
Private services access



You allocate an IP range; Google peers its service network to yours. Ranges must not overlap.

Need	Use
Reach Google APIs on an internal IP you choose	PSC endpoint for Google APIs
Consume a partner or SaaS service privately, ranges may overlap	PSC endpoint to the producer's service attachment
Private IP for Cloud SQL and similar managed services	Private services access (or PSC where supported)

Cloud NAT: Outbound Only, By Design



1. **Manual NAT IPs** give a fixed source address for partner allowlists.
2. **Logging** records translations and dropped packets.
3. **Does not** filter destinations; pair with Secure Web Proxy or NGFW egress rules.
4. **Not needed** for Google APIs when Private Google Access is on.

Exam reflex: "VMs without external IPs need to download updates" means Cloud NAT. "Need a fixed source IP for a partner" means Cloud NAT with manually reserved addresses.

Case Study 29: BigQuery from the Data Centre

THE SCENARIO

Norland Utilities

Norland's on premises ETL servers load data into BigQuery over a Dedicated Interconnect. The BigQuery project is inside a VPC Service Controls perimeter.

The servers must not use the public internet, and API calls must be able to honour the perimeter.

What should you configure?

A. Advertise 199.36.153.4/30 from Cloud Router, add a VPC route for it, and map googleapis.com to restricted.googleapis.com in on premises DNS.

B. Advertise 199.36.153.8/30 from Cloud Router and map googleapis.com to private.googleapis.com on premises.

C. Give the ETL servers public IPs and allow BigQuery through the corporate proxy.

D. Deploy Cloud NAT in the VPC so on premises traffic can reach Google APIs.

ANSWER | PRIVATE GOOGLE ACCESS ON PREMISES

Case Study 29 Answer: A

A

Advertise 199.36.153.4/30 from Cloud Router, add a VPC route for it, and map ...

Correct. The restricted VIP over Interconnect keeps traffic private and only serves services the perimeter can protect.

B

Advertise 199.36.153.8/30 from Cloud Router and map googleapis.com to ...

Incorrect. Private access works, but private.googleapis.com is not the VIP designed for VPC Service Controls.

C

Give the ETL servers public IPs and allow BigQuery through the corporate proxy.

Incorrect. Uses the public internet, which is forbidden.

D

Deploy Cloud NAT in the VPC so on premises traffic can reach Google APIs.

Incorrect. Cloud NAT handles outbound internet traffic from VPC resources, not on premises access to Google APIs.

Exam lesson

On premises to Google APIs privately: custom route advertisement of the VIP plus DNS. With VPC SC, use restricted.

Clue words in the stem

"On premises", "Interconnect", "VPC Service Controls perimeter", "not the public internet"

Case Study 30: Private Is Not Encrypted

THE SCENARIO

Corran Mutual Bank

Corran connects its data centre to Google Cloud through two 10 Gbps Dedicated Interconnect connections. A new regulation requires all data in transit between the data centre and Google Cloud to be encrypted.

Corran wants to keep using Interconnect and avoid application changes.

What should you do?

A. Require every application to use TLS 1.3.

B. Nothing: Dedicated Interconnect traffic is encrypted by default.

C. Enable MACsec for Cloud Interconnect on the connections, or deploy HA VPN over Cloud Interconnect.

D. Replace Interconnect with Classic VPN over the internet.

ANSWER | INTERCONNECT ENCRYPTION

Case Study 30 Answer: C

A

Require every application to use TLS 1.3.

Incorrect. Requires application changes and may miss protocols that cannot use TLS.

B

Nothing: Dedicated Interconnect traffic is encrypted by default.

Incorrect. Interconnect is a private circuit, but it is not encrypted by default.

C

Enable MACsec for Cloud Interconnect on the connections, or deploy HA VPN over Cloud ...

Correct. Both add encryption to the existing Interconnect path without touching applications.

D

Replace Interconnect with Classic VPN over the internet.

Incorrect. Loses Interconnect bandwidth and uses a legacy VPN type over the internet.

Exam lesson

Encryption over Interconnect is MACsec (layer 2) or HA VPN over Interconnect (IPsec).

Clue words in the stem

"Must be encrypted", "keep using Interconnect", "avoid application changes"

Case Study 31: A Partner Allowlist

THE SCENARIO

Brindle Insurance

Claims processing VMs have no external IPs, by organization policy. They must call a partner's REST API on the internet, and the partner allows only requests from two fixed source IP addresses.

Inbound connections to the VMs must remain impossible.

What should you do?

A. Enable Private Google Access on the subnet.

B. Configure Cloud NAT on the subnet with two manually reserved static IP addresses.

C. Grant the VMs static external IP addresses.

D. Create a Private Service Connect endpoint for the partner's API.

ANSWER | CLOUD NAT

Case Study 31 Answer: B

A

Enable Private Google Access on the subnet.

Incorrect. Private Google Access reaches Google APIs only, not a partner on the internet.

B

Configure Cloud NAT on the subnet with two manually reserved static IP addresses.

Correct. Gives a stable, known source address for outbound calls while allowing no unsolicited inbound traffic.

C

Grant the VMs static external IP addresses.

Incorrect. Breaks the organization policy and exposes the VMs to inbound traffic.

D

Create a Private Service Connect endpoint for the partner's API.

Incorrect. PSC needs the partner to publish a service in Google Cloud; this API is simply on the internet.

Exam lesson

Fixed egress IPs for private VMs is Cloud NAT with manual address allocation.

Clue words in the stem

"No external IPs", "fixed source IP", "inbound must remain impossible"

Case Study 32: Overlapping Ranges, Private Access

THE SCENARIO

Quayside Data

Quayside wants to consume a SaaS analytics service that the vendor hosts in its own Google Cloud organization. Both companies use 10.0.0.0/16 internally.

Traffic must stay private, and the vendor must not gain any route into Quayside's network.

What should you do?

A. Peer Quayside's VPC with the vendor's VPC.

B. Connect the two organizations with HA VPN.

C. Create a Private Service Connect endpoint in Quayside's VPC that targets the vendor's published service attachment.

D. Access the vendor service over its public IP through Cloud NAT.

ANSWER | PRIVATE SERVICE CONNECT

Case Study 32 Answer: C

A

Peer Quayside's VPC with the vendor's VPC.

Incorrect. Peering fails with overlapping ranges and exchanges routes in both directions.

B

Connect the two organizations with HA VPN.

Incorrect. VPN also needs non overlapping ranges and opens routing between the networks.

C

Create a Private Service Connect endpoint in Quayside's VPC that targets the vendor's ...

Correct. PSC uses an internal IP from Quayside's own range, works with overlap, and is one way: the vendor cannot initiate connections.

D

Access the vendor service over its public IP through Cloud NAT.

Incorrect. Not private; traffic goes to a public IP.

Exam lesson

Private, one way consumption of a service in another organization, even with overlapping ranges: Private Service Connect.

Clue words in the stem

"Overlapping 10.0.0.0/16", "no route into our network", "private"

SECTION 2 RECAP

Section 2 Recap: Communications and Boundaries

Must remember

- Hierarchical firewall policies are evaluated first and cannot be overridden below
- Implied rules: deny ingress, allow egress
- IAP TCP range: 35.235.240.0/20
- NGFW Standard adds FQDN, geo, threat intel; Enterprise adds IPS and TLS inspection
- Peering is not transitive; Shared VPC is same organization only
- restricted VIP 199.36.153.4/30 for VPC SC; private VIP 199.36.153.8/30
- Interconnect is not encrypted by default

Pick this when you read...

"No bastion, no public IP" IAP TCP

"SQL injection, L7 DDoS" Cloud Armor

"Detect and block exploits" NGFW Enterprise

"Egress by URL" Secure Web Proxy

"Exfiltration with valid credentials" VPC SC

"Central network, team subnets" Shared VPC

"Overlapping ranges, SaaS" PSC

"Fixed egress IP" Cloud NAT manual IPs

Classic traps

- Network tags as a boundary
- Cloud NAT for inbound access
- Cloud IDS when the stem says block
- Firewall rules to stop BigQuery copies
- Perimeter bridges for one partner bucket
- Assuming Interconnect is encrypted

03

Ensuring Data Protection

Find the sensitive data, limit who can read it, encrypt it with keys you control, and keep it safe even when an AI model is the one asking.

Exam weight: about 23% of questions



Bar scaled so that 30% would fill the track

3.1 Sensitive data and data loss prevention

3.2 Encryption at rest, in transit and in use

3.3 Securing AI workloads

Sensitive Data Protection: Three Jobs

Sensitive Data Protection (formerly Cloud DLP) answers three questions: where is sensitive data, what exactly is in it, and how do I make it safe to use?

Discover
Profiles BigQuery, Cloud SQL and Cloud Storage across the organization, continuously

→

Inspect
Deep scans of chosen tables, buckets or text for specific infoTypes

→

De identify
Redact, mask, tokenize or encrypt values so data stays useful

Discovery outputs

Data profiles with infoTypes found, sensitivity and data risk levels. Publish to Security Command Center, Pub/Sub, or tag resources for policy.

Inspection outputs

Findings per infoType with likelihood and location. Save to BigQuery for reporting, or trigger actions.

De identification outputs

Transformed copies of data or inline API responses. Reversible methods allow authorized re identification.

InfoTypes, Likelihood and Templates

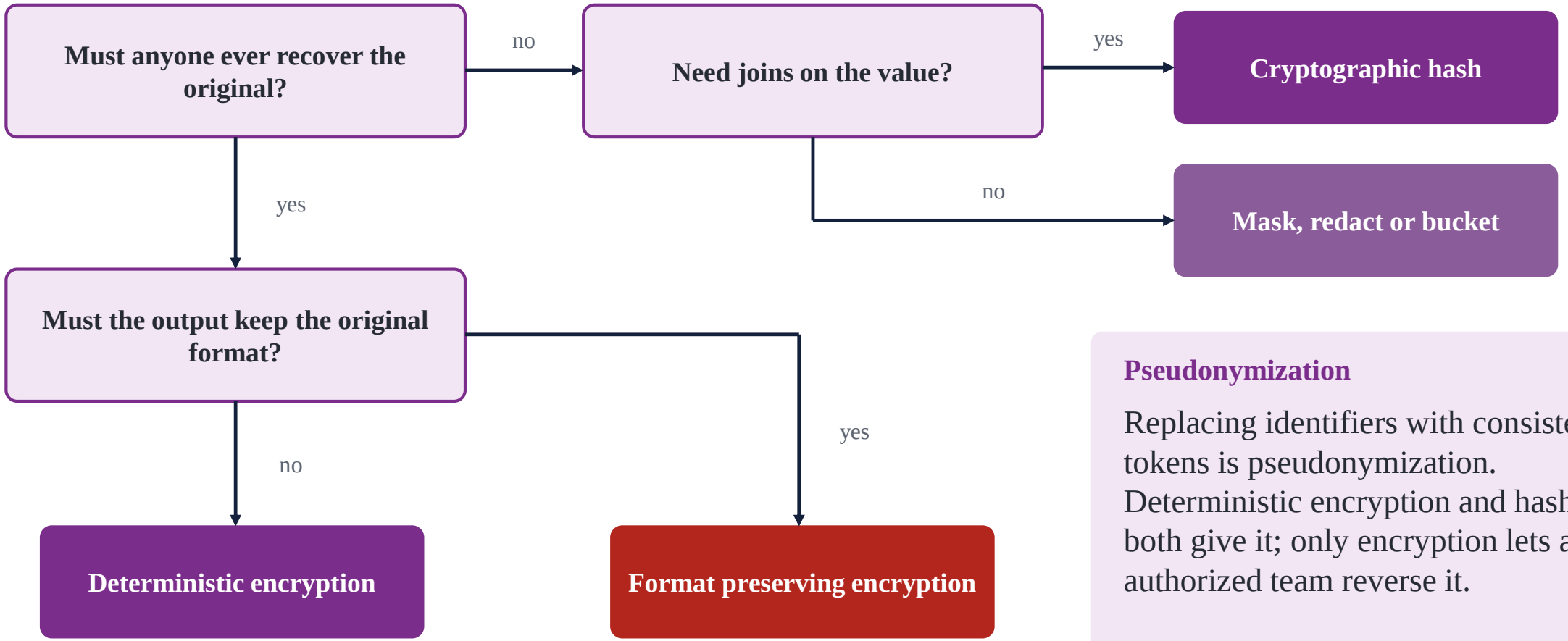
Concept	What it is	Example
Built in infoType	Google maintained detector	EMAIL_ADDRESS, CREDIT_CARD_NUMBER, UK_NATIONAL_INSURANCE_NUMBER
Custom dictionary	A word list you supply	Internal project code names
Custom regular expression	A pattern you define	Employee IDs such as EMP followed by six digits
Hotword rule	Nearby words raise or lower likelihood	"patient" near a number raises confidence of a medical ID
Likelihood	Confidence from VERY_UNLIKELY to VERY_LIKELY	Report only LIKELY and above to cut noise
Inspection template	Reusable detection configuration	One standard PII template for every team
De identification template	Reusable transformation configuration	Mask emails, tokenize customer IDs

De Identification Methods Compared

Method	Output for 4111 1111 1111 1234	Reversible?	Same input gives same output?	Keeps format?
Redaction	(removed)	No	n/a	No
Replace with infoType	[CREDIT_CARD_NUMBER]	No	Yes	No
Character masking	############1234	No	Yes	Length kept
Bucketing or generalization	Age 37 becomes 30 to 40	No	Yes	No
Date shifting	Dates moved by a random, consistent offset	With the key	Per entity	Yes
Cryptographic hash (HMAC SHA256)	Long hex token	No	Yes, joins still work	No
Deterministic encryption (AES SIV)	Token with surrogate tag	Yes, with the key	Yes, joins still work	No
Format preserving encryption (FFX)	9302 5728 1094 6620	Yes, with the key	Yes	Yes

Keys: use a key wrapped by Cloud KMS for every cryptographic method, so the token key itself is protected and auditable.

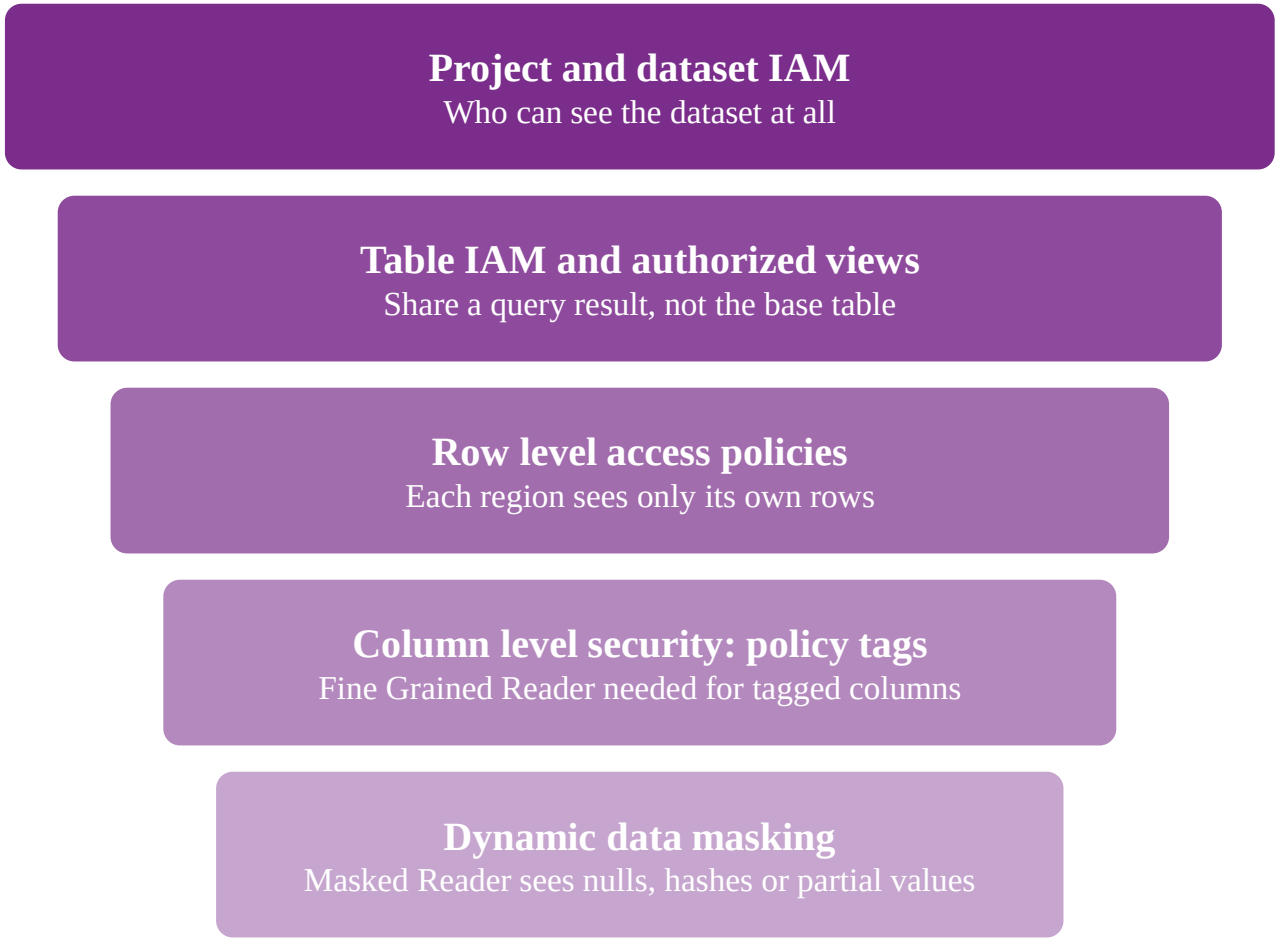
Choosing a De Identification Method



Pseudonymization

Replacing identifiers with consistent tokens is pseudonymization. Deterministic encryption and hashing both give it; only encryption lets an authorized team reverse it.

Restricting Access to BigQuery



Column security in practice

- Create a taxonomy of policy tags (for example PII > High)
- Tag sensitive columns
- Grant Fine Grained Reader on the tag to the few who need raw values
- Add masking rules for everyone else

Exam reflex

"Analysts may query the table but must not see the national ID column" is column level security with policy tags, optionally with dynamic masking. Not a copy of the table, not a view per team.

Restricting Access to Cloud Storage and Cloud SQL

Cloud Storage

Uniform bucket level access so IAM is the only control

Public access prevention enforced by organization policy

IAM Conditions on object name prefixes for shared buckets

Signed URLs for time limited sharing with no IAM grant

VPC Service Controls to stop copies to outside projects

CMEK and retention policies for regulated data

Cloud SQL

Private IP only; block public IP with sql.restrictPublicIp

Cloud SQL Auth Proxy or language connectors: IAM authorized, TLS encrypted, no allowlists

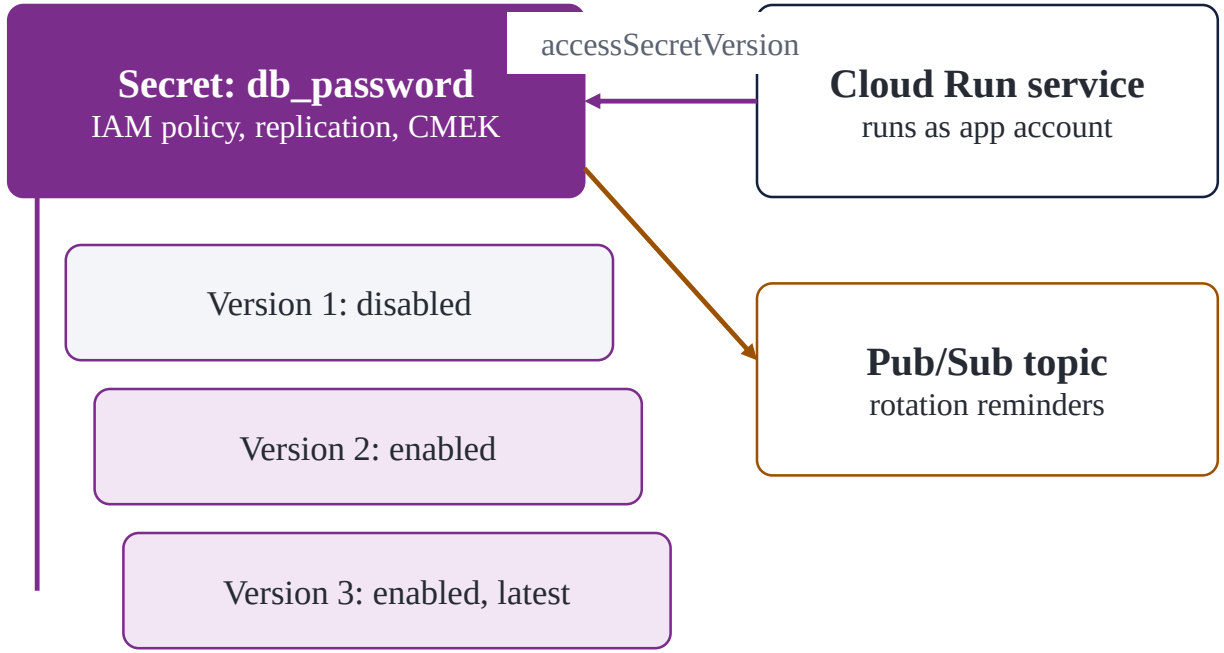
IAM database authentication instead of shared passwords

Require SSL/TLS for direct connections

Restrict authorized networks with an org policy

CMEK for the instance and backups

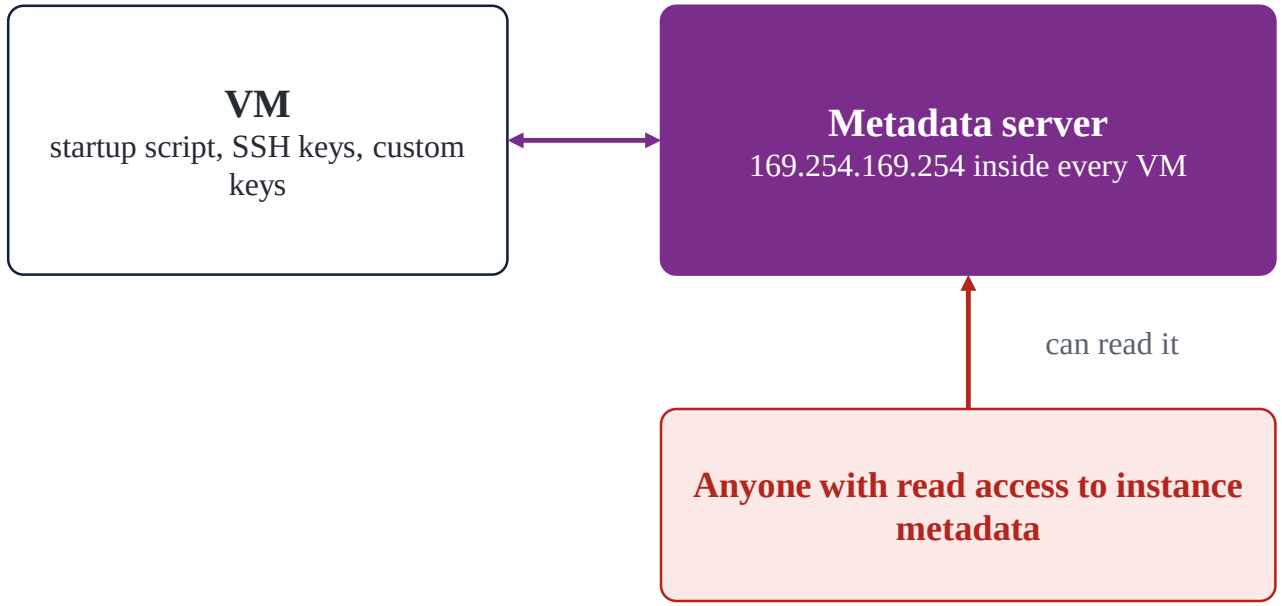
Secret Manager: Anatomy and Access



Role	Can do
Secret Manager Secret Accessor	Read secret payloads
Secret Version Manager	Add, enable, disable versions
Secret Manager Admin	Everything, including IAM
Secret Manager Viewer	Metadata only, not payloads

1. **Grant Accessor on the single secret** to the workload's service account, not on the project.
2. **Replication:** automatic, or user managed to pin regions for residency.
3. **Rotation** schedules send Pub/Sub messages; your function creates the new version.
4. **Every access** is recorded in Data Access audit logs.

Protecting Compute Instance Metadata



The metadata server also requires a special request header, which blunts simple server side request forgery attempts.

Never store secrets in metadata

Readable by many users and any process on the VM. Fetch from Secret Manager at boot.

SSH through OS Login

Enforce compute.requireOsLogin; block project wide SSH keys; access follows IAM and 2SV.

Shielded VM

Secure Boot, vTPM and integrity monitoring detect boot level tampering.

GKE nodes

Workload Identity Federation for GKE hides node metadata, including bootstrap credentials, from pods.

Case Study 33: Where Is Our PII?

THE SCENARIO

Wexford Building Society

Wexford has 9,000 BigQuery tables across 120 projects, and teams add new tables every day. The data protection officer needs to know continuously which tables contain personal data and how sensitive each is.

Findings must appear alongside other security risks.

What should you do?

A. Configure Sensitive Data Protection discovery at the organization level for BigQuery and publish data profiles to Security Command Center.

B. Ask each team to label tables that contain personal data.

C. Run an inspection job on every table once a month using a scheduled script.

D. Export all tables to Cloud Storage and scan them with a regular expression tool.

ANSWER | SENSITIVE DATA PROTECTION

Case Study 33 Answer: A

A

Configure Sensitive Data Protection discovery at the organization level for BigQuery and ...

Correct. Discovery profiles every table automatically, including new ones, and surfaces sensitivity and risk in Security Command Center.

B

Ask each team to label tables that contain personal data.

Incorrect. Manual labels are incomplete and unverifiable.

C

Run an inspection job on every table once a month using a scheduled script.

Incorrect. Expensive full scans, monthly gaps, and custom code to maintain.

D

Export all tables to Cloud Storage and scan them with a regular expression tool.

Incorrect. Copies sensitive data to a new place and reinvents detection badly.

Exam lesson

Continuous, organization wide visibility of sensitive data is SDP discovery, not one off inspection jobs.

Clue words in the stem

"Continuously", "9,000 tables", "new tables every day", "alongside other security risks"

Case Study 34: Join Without Seeing

THE SCENARIO

Larkspur Mobile

Data scientists must join call records with billing data on the customer account number, but must never see real account numbers.

The fraud team must occasionally recover the real account number for a flagged record.

Which de identification method should you use?

A. Cryptographic hashing with HMAC SHA256 using a KMS wrapped key.

B. Redaction of the account number field.

C. Character masking of all but the last four digits.

D. Deterministic encryption with a KMS wrapped key, re identifying for the fraud team with the same key.

ANSWER | PSEUDONYMIZATION

Case Study 34 Answer: D

A

Cryptographic hashing with HMAC SHA256 using a KMS wrapped key.

Incorrect. Consistent tokens allow joins, but hashing is one way; the fraud team could never recover the original.

B

Redaction of the account number field.

Incorrect. Removes the join key entirely.

C

Character masking of all but the last four digits.

Incorrect. Masked values collide (many accounts share last four digits), so joins break, and masking is not reversible.

D

Deterministic encryption with a KMS wrapped key, re identifying for the fraud team with ...

Correct. Consistent tokens keep joins working, and authorized users can reverse them with the same key.

Exam lesson

Joins plus authorized reversal means deterministic encryption. Joins without reversal means hashing.

Clue words in the stem

"Join on the account number", "never see", "occasionally recover"

Case Study 35: The Legacy Field Validator

THE SCENARIO

Halberd Payments

Halberd copies production card data into a test environment. A legacy test application rejects any value in the card field that is not 16 digits.

Testers must not see real card numbers, and a small production support team must be able to recover the original values.

What should you use?

A. Deterministic encryption with AES SIV.

B. Format preserving encryption (FFX) with a numeric alphabet and a KMS wrapped key.

C. Bucketing into ranges of card numbers.

D. Replace each value with the infoType name.

ANSWER | FORMAT PRESERVING ENCRYPTION

Case Study 35 Answer: B

A

Deterministic encryption with AES SIV.

Incorrect. Reversible, but its output is not a 16 digit number, so the legacy app rejects it.

B

Format preserving encryption (FFX) with a numeric alphabet and a KMS wrapped key.

Correct. Produces 16 digit ciphertext that passes the validator and can be decrypted by authorized staff.

C

Bucketing into ranges of card numbers.

Incorrect. Not reversible and meaningless for card numbers.

D

Replace each value with the infoType name.

Incorrect. Output is the text [CREDIT_CARD_NUMBER]; fails validation and is not reversible.

Exam lesson

Only format preserving encryption keeps both the format and reversibility. Use it when the format is a hard constraint.

Clue words in the stem

"Rejects any value that is not 16 digits", "recover the original"

Case Study 36: One Column Too Many

THE SCENARIO

Thornbury Health Trust

A BigQuery table of appointments includes a column with each patient's national health number. Two hundred analysts need the table for scheduling reports.

Only the records team may see the national health number; analysts should see the rest of the row. Thornbury wants one table, not copies.

What should you do?

A. Create a separate copy of the table without the column for analysts.

B. Grant analysts BigQuery Data Viewer only on other tables.

C. Create a row level access policy for analysts.

D. Apply a policy tag to the column, grant Fine Grained Reader on that tag to the records team only, and optionally add a masking rule for analysts.

ANSWER | BIGQUERY COLUMN SECURITY

Case Study 36 Answer: D

A

Create a separate copy of the table without the column for analysts.

Incorrect. Copies drift, double storage, and the stem asks for one table.

B

Grant analysts BigQuery Data Viewer only on other tables.

Incorrect. Analysts need this table, so this does not meet the requirement.

C

Create a row level access policy for analysts.

Incorrect. Row policies filter rows, not columns.

D

Apply a policy tag to the column, grant Fine Grained Reader on that tag to the records ...

Correct. Column level security hides the tagged column from everyone without the tag permission; masking lets queries still run.

Exam lesson

Hide a column, keep the table: policy tags with Fine Grained Reader, plus dynamic data masking if needed.

Clue words in the stem

"One column", "see the rest of the row", "one table, not copies"

Case Study 37: The Password in the Startup Script

THE SCENARIO

Pemberton Engineering

A VM startup script stored in instance metadata contains the database password in plain text. Twenty engineers have Compute Viewer on the project.

The security team wants the password out of metadata, readable only by the application, and every read audited. Secrets must remain in UK regions.

What should you do?

A. Store the password in Secret Manager with user managed replication in a UK region, grant Secret Accessor on that secret to the VM's service account, and fetch it at startup.

B. Store the password in a Cloud Storage bucket readable by all engineers.

C. Move the password to project wide metadata, which fewer people check.

D. Base64 encode the password in the startup script.

ANSWER | SECRET MANAGER

Case Study 37 Answer: A

A

Store the password in Secret Manager with user managed replication in a UK region, grant ...

Correct. Only the app's identity can read the secret, access is logged, and replication is pinned to the UK.

B

Store the password in a Cloud Storage bucket readable by all engineers.

Incorrect. Readable by everyone, which is the problem we are fixing.

C

Move the password to project wide metadata, which fewer people check.

Incorrect. Project metadata is just as readable, and applies to every VM.

D

Base64 encode the password in the startup script.

Incorrect. Encoding is not encryption; anyone can decode it.

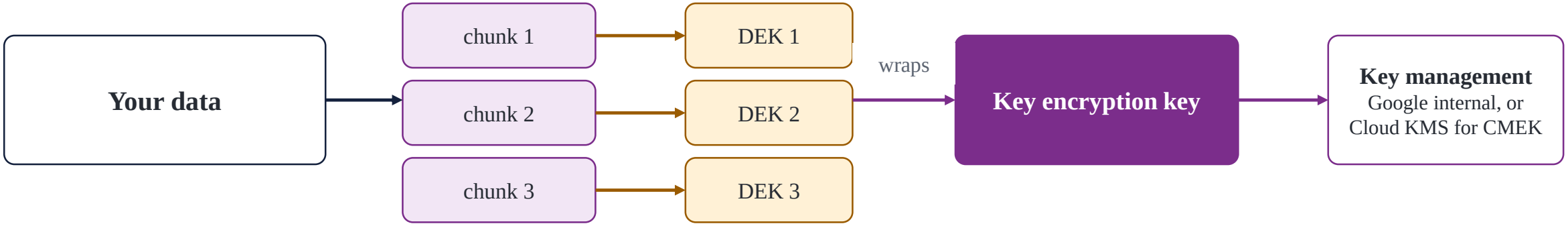
Exam lesson

Secrets go in Secret Manager, accessed at runtime by the workload identity, with replication chosen for residency.

Clue words in the stem

"Out of metadata", "only the application", "audited", "UK regions"

Default Encryption at Rest: Envelope Encryption



1. **Every byte at rest** in Google Cloud is encrypted by default with AES 256, at no cost and with no configuration.
2. **Each chunk** gets its own data encryption key (DEK), stored next to the data in wrapped form.
3. **DEKs are wrapped** by a key encryption key (KEK). Only the KEK lives in the key management service.
4. **CMEK changes one thing:** the KEK is now your Cloud KMS key, so you control its location, rotation, access and destruction.

Envelope encryption keeps bulk encryption fast while concentrating control in a few keys.

The Key Control Spectrum

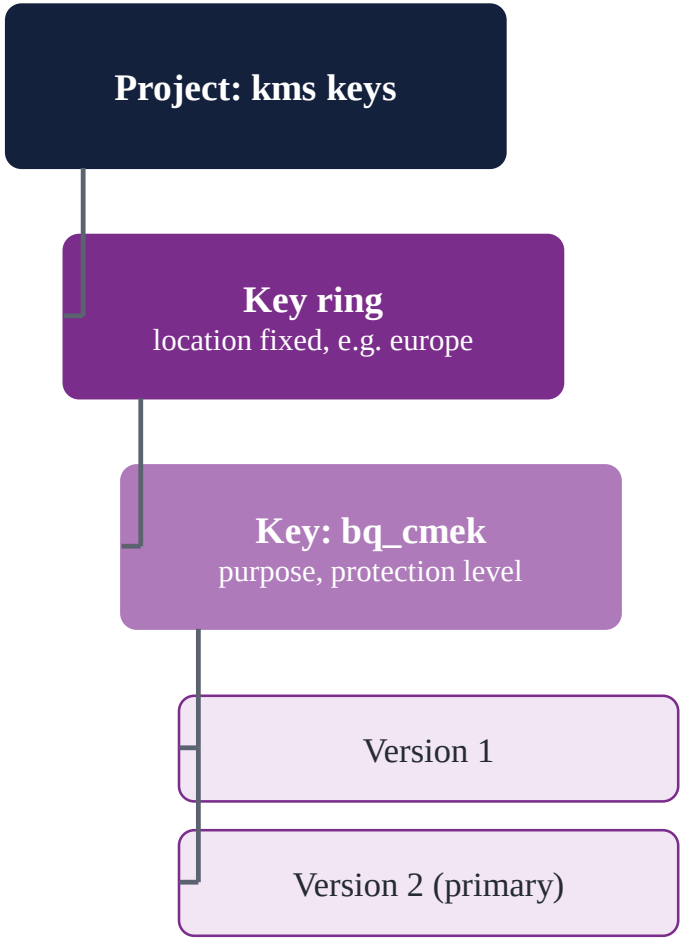
Less control, less overhead — *More control, more responsibility*



1	2	3	4	5
Google default	**CMEK, software**	**CMEK, Cloud HSM**	**Cloud EKM**	**CSEK**
Google creates, stores, rotates keys	Your Cloud KMS key, software protected	Your key in Google FIPS 140 level 3 HSMs	Key stays in a partner key manager outside Google	You send the raw key with each request
Use for: Most workloads	**Use for:** Control, audit, crypto shredding	**Use for:** Hardware key mandate	**Use for:** Sovereignty, key outside Google	**Use for:** Cloud Storage and Compute disks only

Exam rule: choose the least control that satisfies the stated requirement. More control always means more ways to lose data.

Cloud KMS Object Hierarchy



Attribute	Options and facts
Location	Regional, dual region, multi region or global; must suit the resource it protects
Protection level	SOFTWARE, HSM, EXTERNAL (EKM over internet), EXTERNAL_VPC (EKM over VPC)
Purpose	Symmetric encrypt and decrypt (CMEK), asymmetric sign, asymmetric decrypt, MAC
Rotation	Automatic schedule for symmetric keys; manual for asymmetric
Deletion	Key rings and keys cannot be deleted; key versions are destroyed
IAM	Grant at key level: Encrypter Decrypter to service agents; KMS Admin to key custodians

Software or Hardware Keys?

SOFTWARE protection level

- Validated to FIPS 140 level 1
- Lowest cost per key version and operation
- Same API, same CMEK integrations
- Right for most CMEK requirements

HSM protection level (Cloud HSM)

- Key material generated and used inside FIPS 140 level 3 validated HSMs
- Fully managed: no HSM hardware to run or cluster
- Attestations prove the key was created in an HSM
- Higher cost

Decision rule

If the stem says "hardware security module", "FIPS 140 level 3" or "tamper resistant hardware", choose Cloud HSM. If it only says "customer managed", software keys meet it at lower cost. If the key must live outside Google, neither: choose Cloud EKM.

Key Rotation: What Changes and What Does Not

1

Day 0
v1 created, primary

2

Day 90
v2 created, becomes primary

3

Day 180
v3 created, becomes primary

4

Day 270
v4 created, becomes primary

New writes

Use the current primary version automatically. No application change.

Old data

Stays encrypted with the version used at the time. Old versions stay enabled to decrypt it.

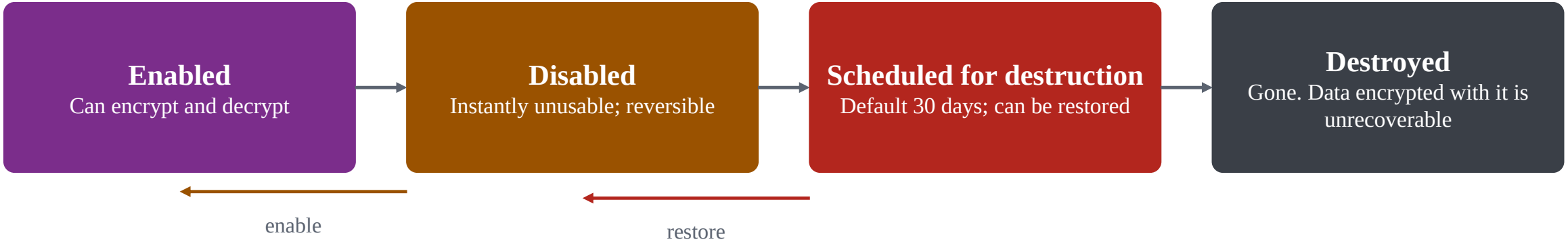
Re encryption

Not automatic. To move old data to the new version, rewrite it (for example copy the object or rewrite the table).

Asymmetric keys

No automatic rotation. Create a new version and update consumers yourself.

Disable, Destroy and Restore: The Key Version Lifecycle



Revoke access fast

Disable the key version. Services using CMEK can no longer decrypt; re enable to restore service.

Crypto shredding

Destroying the only version that protects a dataset makes that data permanently unreadable, even in backups encrypted with it.

Safety net

The scheduled destruction period is configurable at key creation. Alert on destroy requests in audit logs.

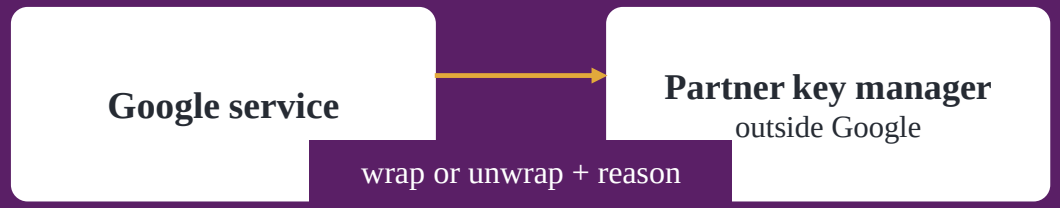
Importing Keys, Cloud EKM and Key Access Justifications

Key import (bring your own key)



- Key material originated on your premises, then lives in Cloud KMS (software or HSM)
- Use when policy says "we generate our own keys"
- Rotation means importing new versions

Cloud EKM (hold your own key)



- Key never leaves your external key manager
- Key Access Justifications attaches a reason to each request; your policy can refuse it
- Trade off: if the external manager is unavailable, so is your data

Organization Policies and Autokey for CMEK at Scale

gcp.restrictNonCmekServices

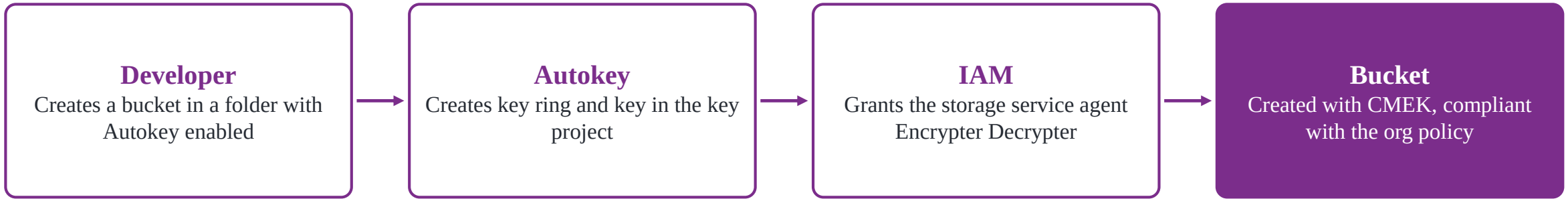
Listed services must be created with a customer managed key. Blocks a new BigQuery dataset without CMEK.

gcp.restrictCmekCryptoKeyProjects

CMEK keys may come only from approved key projects, preserving separation of duties.

Cloud KMS Autokey

When a resource is created, Autokey provisions a correctly located key ring and key in a dedicated key project and grants the service agent access. CMEK without manual key plumbing.



Org policy says "must use CMEK"; Autokey makes it painless to comply.

Encryption in Transit and in Use

In transit

User to Google: TLS terminated at the Google Front End

Inside Google: ALTS authenticates and encrypts service to service RPCs

Between data centres: traffic leaving physical boundaries Google controls is encrypted

Your apps: TLS or mTLS (Cloud Service Mesh, CAS certificates)

Hybrid: HA VPN (IPsec) or MACsec on Interconnect

In use: Confidential Computing

Confidential VMs: memory encrypted by the CPU (AMD SEV, SEV SNP, Intel TDX) with keys the hypervisor never sees

Confidential GKE Nodes: the same for Kubernetes node pools

Confidential Space: a hardened, attested environment where several parties combine data without seeing each other's inputs

Attestation proves the workload ran in genuine confidential hardware

Matching Encryption to the Use Case

Requirement in the stem	Answer
"Encrypt data at rest" and nothing more	Default encryption already does it; no action needed
"We must control and audit the key, and be able to revoke it"	CMEK with Cloud KMS
"Keys in FIPS 140 level 3 hardware"	CMEK with HSM protection level
"Key must never be stored by Google"	Cloud EKM, plus Key Access Justifications
"We supply the key for each request to Compute Engine disks"	CSEK
"Protect data while it is being processed in memory"	Confidential VMs or Confidential GKE Nodes
"Two organizations compute on combined data without sharing it"	Confidential Space
"Tokenize a field inside the data"	Sensitive Data Protection, not storage encryption
"Encrypt traffic on Interconnect"	MACsec or HA VPN over Interconnect

Cloud Storage Lifecycle and Retention Controls

1

Day 0
Object written, Standard class

2

Day 30
SetStorageClass to Nearline

3

Day 365
SetStorageClass to Archive

4

Year 7
Retention ends; Delete rule fires

Control	What it does	Key fact
Lifecycle rules	Delete or change class by age, version count, creation date	Cannot delete objects still under retention or hold
Object versioning	Keeps noncurrent versions on overwrite or delete	Pair with lifecycle to cap version count
Retention policy	Objects cannot be deleted or replaced until they reach an age	Bucket level, applies to every object
Bucket Lock	Locks the retention policy permanently (WORM)	Irreversible: cannot shorten or remove
Object holds	Event based or temporary hold on single objects	Legal hold until released
Soft delete	Deleted objects recoverable for a retention window	Protects against accidental or malicious deletion

Case Study 38: The Kill Switch

THE SCENARIO

Ostrava Reinsurance

Ostrava stores claims data in BigQuery and Cloud Storage. Its regulator requires that Ostrava can make the data unreadable to anyone, including the cloud provider, on demand, and can audit every use of the encryption key.

Keys may be stored in Google Cloud.

What should you do?

A. Encrypt each file in the application before upload and keep keys on a laptop.

B. Use customer supplied encryption keys for BigQuery and Cloud Storage.

C. Use CMEK with keys in Cloud KMS, monitor key usage in Cloud Audit Logs, and disable or destroy the key version when required.

D. Rely on Google default encryption at rest.

ANSWER | CMEK

Case Study 38 Answer: C

A

Encrypt each file in the application before upload and keep keys on a laptop.

Incorrect. Unmanageable, breaks BigQuery features, and a laptop is a single point of failure.

B

Use customer supplied encryption keys for BigQuery and Cloud Storage.

Incorrect. CSEK is not available for BigQuery.

C

Use CMEK with keys in Cloud KMS, monitor key usage in Cloud Audit Logs, and disable or ...

Correct. CMEK gives Ostrava control of the KEK: disabling it makes data unreadable, and key operations are logged.

D

Rely on Google default encryption at rest.

Incorrect. Google controls default keys; Ostrava cannot revoke them or audit their use.

Exam lesson

Control plus revocation plus audit, with keys allowed in Google Cloud, is CMEK.

Clue words in the stem

"Make the data unreadable on demand", "audit every use", "keys may be stored in Google Cloud"

Case Study 39: Hardware or Nothing

THE SCENARIO

Valdane Securities

Valdane's security standard says every key protecting customer data must be generated and used only inside a FIPS 140 level 3 validated hardware security module.

The team is small and does not want to operate HSM hardware. Keys may reside in Google Cloud.

Which approach meets the standard with the least operational overhead?

A. Customer supplied encryption keys generated on a laptop.

B. Cloud KMS keys with the HSM protection level, used as CMEK.

C. Self managed HSM appliances in a colocation facility with Cloud EKM.

D. Cloud KMS keys with the SOFTWARE protection level.

ANSWER | CLOUD HSM

Case Study 39 Answer: B

A

Customer supplied encryption keys generated on a laptop.

Incorrect. A laptop is not an HSM, and CSEK covers few services.

B

Cloud KMS keys with the HSM protection level, used as CMEK.

Correct. Cloud HSM keys are generated and used in level 3 validated HSMs that Google operates, with the same CMEK integrations.

C

Self managed HSM appliances in a colocation facility with Cloud EKM.

Incorrect. Satisfies the hardware requirement but adds the heavy operations the team wants to avoid.

D

Cloud KMS keys with the SOFTWARE protection level.

Incorrect. Software keys are validated to level 1, not level 3.

Exam lesson

Level 3 hardware with minimal overhead, keys allowed in Google: Cloud HSM protection level.

Clue words in the stem

"FIPS 140 level 3", "does not want to operate HSM hardware", "may reside in Google Cloud"

Case Study 40: Keys That Never Enter Google

THE SCENARIO

Brannock Defence Systems

A sovereignty requirement says encryption keys for Brannock's BigQuery data must never be stored inside Google infrastructure. Brannock already runs a supported third party key manager.

Brannock also wants to see, and be able to refuse, the reason for each request to use the key.

What should you configure?

A. Cloud KMS software keys with a 30 day rotation period.

B. Customer supplied encryption keys on each BigQuery query.

C. Cloud EKM keys backed by the external key manager, used as CMEK, with Key Access Justifications policies.

D. Import Brannock's keys into Cloud HSM.

ANSWER | CLOUD EKM

Case Study 40 Answer: C

A

Cloud KMS software keys with a 30 day rotation period.

Incorrect. Keys live in Google; rotation does not change that.

B

Customer supplied encryption keys on each BigQuery query.

Incorrect. BigQuery does not support CSEK.

C

Cloud EKM keys backed by the external key manager, used as CMEK, with Key Access ...

Correct. EKM keeps key material in Brannock's manager; Key Access Justifications shows the reason and lets the policy deny.

D

Import Brannock's keys into Cloud HSM.

Incorrect. Imported keys are stored in Google's HSMs, which breaks the requirement.

Exam lesson

Key material outside Google plus visibility into each access: Cloud EKM with Key Access Justifications.

Clue words in the stem

"Never stored inside Google", "see and refuse the reason for each request"

Case Study 41: Rotate Without Breaking Reads

THE SCENARIO

Ellery Logistics

An audit requires the symmetric CMEK key for Ellery's Cloud Storage buckets to be rotated every 90 days.

Objects written years ago must remain readable, and the team wants no custom code.

What should you do?

A. Set a 90 day automatic rotation period on the Cloud KMS key.

B. Rotate the key every 90 days and destroy the previous version to enforce the change.

C. Create a new key every 90 days and update every bucket's default key with a script.

D. Switch to Google default encryption, which Google rotates.

ANSWER | KEY ROTATION

Case Study 41 Answer: A

A

Set a 90 day automatic rotation period on the Cloud KMS key.

Correct. Each rotation creates a new primary version for new writes, while older versions remain available to decrypt old objects.

B

Rotate the key every 90 days and destroy the previous version to enforce the change.

Incorrect. Destroying old versions makes older objects unreadable: data loss.

C

Create a new key every 90 days and update every bucket's default key with a script.

Incorrect. Custom code, and every consumer must change; rotation within one key avoids this.

D

Switch to Google default encryption, which Google rotates.

Incorrect. Loses the customer managed control the audit expects.

Exam lesson

Automatic rotation adds versions; it never breaks old data unless you destroy the versions that encrypted it.

Clue words in the stem

"Every 90 days", "years ago must remain readable", "no custom code"

Case Study 42: Seven Years, Then Gone

THE SCENARIO

Ridgeway Pension Trust

Ridgeway must keep member statements in Cloud Storage for exactly seven years in a form that no one, including administrators, can delete or alter early.

After 90 days the statements are rarely read, and after seven years they must be deleted automatically to limit liability.

Which two configurations should you apply? (Choose two.)

A. An IAM deny policy on storage.objects.delete for all users.

B. Lifecycle rules: SetStorageClass to Archive at 90 days and Delete at seven years of age.

C. Object versioning with no other controls.

D. A seven year retention policy on the bucket, locked with Bucket Lock.

Case Study 42 Answer: B and D

A

An IAM deny policy on storage.objects.delete for all users.

Incorrect. Admins with Deny Admin could remove it, and it does not delete data after seven years.

B

Lifecycle rules: SetStorageClass to Archive at 90 days and Delete at seven years of age.

Correct. Lifecycle moves cold data to cheaper storage and deletes it once retention allows.

C

Object versioning with no other controls.

Incorrect. Versioning keeps old versions but anyone with permission can still delete them.

D

A seven year retention policy on the bucket, locked with Bucket Lock.

Correct. A locked retention policy is write once, read many: nobody can delete or replace objects before seven years, and the lock cannot be undone.

Exam lesson

WORM is a locked retention policy. Automatic aging and deletion is lifecycle management. They work together.

Clue words in the stem

"No one, including administrators", "deleted automatically", "rarely read"

Case Study 43: Two Hospitals, One Model

THE SCENARIO

Northfield and Calder Hospitals

Two hospital groups want to train a joint risk model on their combined patient data in Google Cloud.

Neither may see the other's raw data, the cloud operator must not access the data in memory, and each hospital must verify the exact code that runs before releasing its data.

What should you use?

A. CMEK on a shared Cloud Storage bucket.

B. Confidential Space, where each hospital releases its data only to an attested workload.

C. Shielded VMs with Secure Boot.

D. A shared project with VPC Service Controls around it.

ANSWER | CONFIDENTIAL COMPUTING

Case Study 43 Answer: B

A

CMEK on a shared Cloud Storage bucket.

Incorrect. Protects data at rest; anyone with decrypt access sees the data.

B

Confidential Space, where each hospital releases its data only to an attested workload.

Correct. Data is processed in a confidential, attested environment; keys are released only to the verified workload image.

C

Shielded VMs with Secure Boot.

Incorrect. Protects boot integrity, not data in memory or between parties.

D

A shared project with VPC Service Controls around it.

Incorrect. Prevents exfiltration but each hospital's admins could still read the other's data.

Exam lesson

Multi party computation with attestation and memory encryption is Confidential Space.

Clue words in the stem

"Neither may see", "in memory", "verify the exact code"

The AI Threat Landscape

Data poisoning
Malicious training data changes model behaviour

Prompt injection
Instructions hidden in user input or retrieved documents

Jailbreaks
Prompts that bypass safety behaviour

Sensitive data leakage
Model reveals PII or secrets from training or context

Model theft
Weights or endpoints copied or abused

Excessive agency
Agents with too much access take harmful actions

Supply chain
Untrusted models, packages or notebooks

Denial of wallet
Abuse that drives up inference cost

Google's Secure AI Framework (SAIF)

1. Extend strong security foundations to the AI ecosystem
2. Extend detection and response to AI
3. Automate defences
4. Harmonize platform level controls
5. Adapt controls with feedback loops and red teaming
6. Contextualize AI risks in business processes

Shared Responsibility: IaaS versus PaaS Training

	IaaS: GPU VMs or GKE	PaaS: managed training
Data access and IAM	You	You
Network isolation	You	You
Encryption keys (CMEK)	You	You
Training code and containers	You	You
Accelerator drivers and OS	You	Google
Cluster and node patching	You	Google
Physical infrastructure	Google	Google

IaaS checklist

- Shielded or Confidential nodes
- Private cluster, no public IPs
- Workload Identity Federation
- Hardened, scanned images

PaaS checklist

- Custom service account per job
- CMEK, VPC SC, private endpoints
- Region chosen for residency

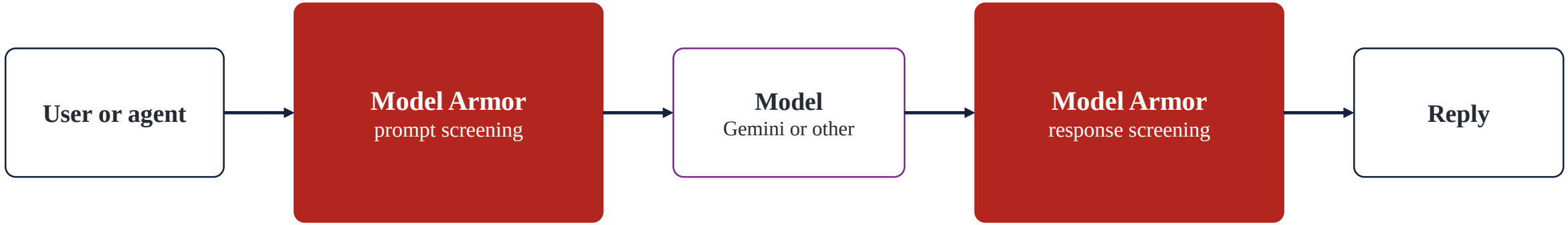
Security Controls for Gemini Enterprise Agent Platform

Control	Purpose on the platform
Data residency	Keep data at rest in the region you choose for supported features
CMEK	Encrypt datasets, models, endpoints and supported generative features with your keys
VPC Service Controls	Put the platform API inside a perimeter so data and models cannot be copied out
Access Transparency	Logs of Google personnel access for supported features
Private endpoints and PSC	Reach prediction endpoints without the public internet
Agent Identity	Each agent has its own IAM identity, so least privilege applies to agents
Agent Gateway and Agent Registry	Central policy enforcement and discoverability across your agents
Model Armor	Screens prompts and responses for injection, jailbreaks, sensitive data and malicious URLs

Not every control covers every feature or model. The exam expects you to know the controls exist and when each is the right one.

Model Armor: Screening Prompts and Responses

Templates hold filter settings; **floor settings** at organization, folder or project set the minimum every template must meet.



Prompt injection and jailbreak

Detects attempts to override instructions, including text hidden in documents.

Sensitive data

Uses Sensitive Data Protection to find or de identify PII and secrets.

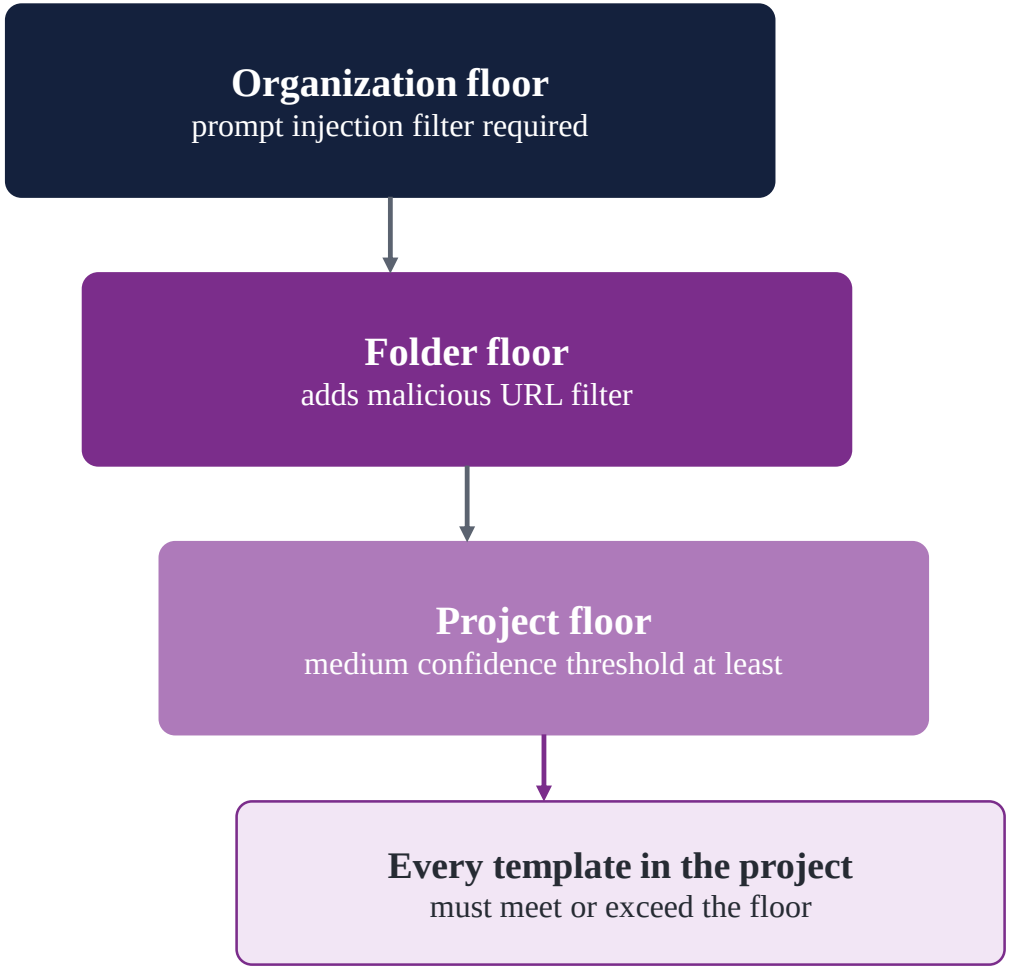
Malicious URLs

Flags links to known harmful sites in prompts or answers.

Responsible AI filters

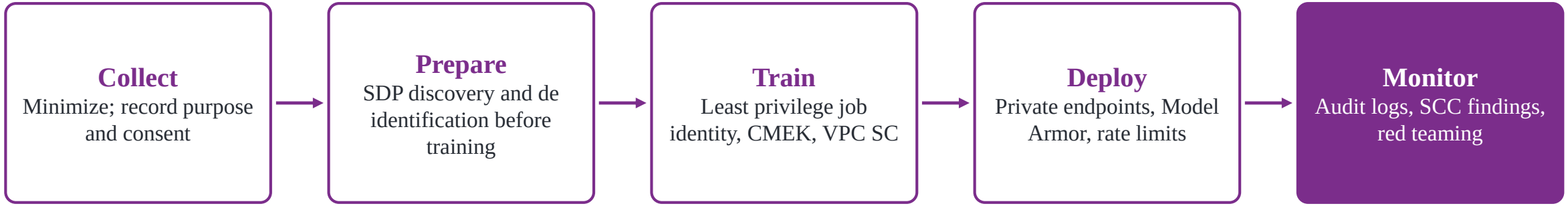
Hate, harassment, sexually explicit and dangerous content, with confidence thresholds.

Model Armor Floor Settings



1. **Purpose:** stop developers lowering protection below the security baseline, by accident or on purpose.
2. **Inheritance:** choose inherit from parent, custom, or disable at each level; the more specific level takes precedence.
3. **Enforcement:** new and updated templates must conform; floor settings must be enabled to enforce.
4. **Detection:** older, weaker templates surface as Security Command Center findings to fix.

Privacy Controls Across the AI Lifecycle



Unintentional exploitation of data

- De identify PII before it reaches training sets
- Separate raw and curated datasets with different IAM
- Screen responses for sensitive data

Unintentional exploitation of models

- Store weights in buckets with CMEK and VPC SC
- Restrict who can deploy or export models
- Scan model artefacts and containers in Artifact Registry

Agents and tools

- Give each agent its own identity
- Grant only the tools and data it needs
- Log every tool call and review

Case Study 44: The Helpful Assistant That Overshared

THE SCENARIO

Corbel Insurance

Corbel's customer assistant uses retrieval augmented generation over policy documents. Testers found that crafted questions made it reveal other customers' policy numbers and addresses that appear in retrieved documents.

A document uploaded by a tester also contained hidden text instructing the assistant to ignore its rules.

What should you implement to address both issues at runtime?

A. A VPC Service Controls perimeter around the assistant project.

B. Retrain the model on a smaller dataset.

C. Cloud Armor WAF rules on the assistant's load balancer.

D. Model Armor templates that screen prompts for prompt injection and screen responses for sensitive data, integrated in the assistant's request path.

ANSWER | MODEL ARMOR

Case Study 44 Answer: D

A

A VPC Service Controls perimeter around the assistant project.

Incorrect. Prevents API level exfiltration, but not what the model says to an authorized user.

B

Retrain the model on a smaller dataset.

Incorrect. Retraining does not stop runtime leakage from retrieved documents or injected instructions.

C

Cloud Armor WAF rules on the assistant's load balancer.

Incorrect. WAF signatures target web attacks like SQL injection, not natural language prompt injection or PII in answers.

D

Model Armor templates that screen prompts for prompt injection and screen responses for ...

Correct. Prompt screening catches injected instructions; response screening, backed by Sensitive Data Protection, blocks or redacts leaked personal data.

Exam lesson

Runtime protection for LLM prompts and responses is Model Armor: injection on the way in, sensitive data on the way out.

Clue words in the stem

"Reveal other customers' data", "hidden text instructing", "at runtime"

Case Study 45: A Baseline Nobody Can Lower

THE SCENARIO

Galloway Group

Thirty product teams build generative AI features, each with its own Model Armor templates. Some teams disabled prompt injection detection to reduce false positives.

The CISO wants a minimum standard across the organization that teams cannot weaken, and visibility of existing templates that fall short.

What should you do?

A. Set organization floor settings requiring prompt injection detection, enable enforcement, and review Security Command Center findings for weaker templates.

B. Create one shared template and ask teams to use it.

C. Remove Model Armor permissions from all product teams.

D. Review each team's templates in a monthly meeting.

ANSWER | MODEL ARMOR FLOOR SETTINGS

Case Study 45 Answer: A

A

Set organization floor settings requiring prompt injection detection, enable ...

Correct. Floor settings enforce minimums on new and updated templates, and older weaker templates appear as findings.

B

Create one shared template and ask teams to use it.

Incorrect. A suggestion is not enforcement; teams can still create weaker templates.

C

Remove Model Armor permissions from all product teams.

Incorrect. Stops teams from configuring protection at all.

D

Review each team's templates in a monthly meeting.

Incorrect. Manual, periodic, and teams can still weaken templates between reviews.

Exam lesson

Organization wide minimums for Model Armor are floor settings, the same idea as an organization policy.

Clue words in the stem

"Minimum standard", "cannot weaken", "visibility of existing templates"

Case Study 46: Training Data That Must Not Leave

THE SCENARIO

Arden Pharmaceuticals

Arden trains models on proprietary compound data using the Gemini Enterprise Agent Platform. Security requires that training data and resulting models cannot be copied to projects outside Arden's research environment.

Arden also requires its own encryption keys for datasets and models.

Which two controls should you apply? (Choose two.)

A. Public endpoints with API keys for model serving.

B. Cloud Armor on the training jobs.

C. CMEK for the platform resources and training data stores.

D. A VPC Service Controls perimeter that includes the research projects and restricts the platform API, Cloud Storage and BigQuery.

ANSWER | AGENT PLATFORM SECURITY

Case Study 46 Answer: C and D

A

Public endpoints with API keys for model serving.

Incorrect. Public endpoints with API keys weaken, not strengthen, protection.

B

Cloud Armor on the training jobs.

Incorrect. Cloud Armor protects web load balancers, not training jobs.

C

CMEK for the platform resources and training data stores.

Correct. Arden controls the keys protecting datasets and models.

D

A VPC Service Controls perimeter that includes the research projects and restricts the ...

Correct. Blocks copying data or models to projects outside the perimeter, even with valid credentials.

Exam lesson

For managed AI platforms the core trio is VPC Service Controls, CMEK and least privilege service accounts.

Clue words in the stem

"Cannot be copied to projects outside", "its own encryption keys", "choose two"

Case Study 47: Fewer Things to Patch

THE SCENARIO

Sorrel Robotics

Sorrel currently trains vision models on self managed GPU VMs. An audit found outdated GPU drivers and OS packages, and VMs with public IPs.

Sorrel has two engineers and wants to reduce the security tasks it must perform while keeping control of data access and keys.

What should you recommend?

A. Keep the VMs and write scripts to patch them weekly.

B. Move training to managed custom training jobs on the Agent Platform, using a dedicated service account, CMEK, and private networking.

C. Move to a larger GPU VM type with a newer image.

D. Keep the VMs and add Cloud Armor.

ANSWER | IAAS VERSUS PAAS

Case Study 47 Answer: B

A

Keep the VMs and write scripts to patch them weekly.

Incorrect. Keeps the patching burden the audit exposed.

B

Move training to managed custom training jobs on the Agent Platform, using a dedicated ...

Correct. Google operates the infrastructure, drivers and OS; Sorrel keeps control of identity, keys and network.

C

Move to a larger GPU VM type with a newer image.

Incorrect. Fixes today's image only; patching remains Sorrel's job.

D

Keep the VMs and add Cloud Armor.

Incorrect. Cloud Armor does not patch VMs or remove public IPs.

Exam lesson

PaaS shifts infrastructure security to Google; you still own identity, data access, keys and network choices.

Clue words in the stem

"Two engineers", "reduce the security tasks", "keep control of data access and keys"

SECTION 3 RECAP

Section 3 Recap: Data Protection

Must remember

- SDP: discover, inspect, de identify
- Hash: consistent, irreversible. Deterministic: consistent, reversible. FPE: reversible, keeps format
- Envelope encryption: DEKs wrapped by a KEK
- Software keys FIPS 140 level 1; HSM keys level 3
- Rotation adds versions; old data needs old versions
- Destroy is scheduled (default 30 days) and then final
- Bucket Lock is irreversible WORM

Pick this when you read...

"Where is PII, continuously" SDP discovery

"Join but reverse" deterministic encryption

"Hide one column" policy tags

"Revoke and audit keys" CMEK

"Key outside Google" Cloud EKM

"In memory" Confidential VMs

"Two parties, attested" Confidential Space

"Prompt injection, PII in answers" Model Armor

Classic traps

- CSEK for BigQuery
- Destroying old key versions after rotation
- Hashing when reversal is needed
- Secrets in metadata or startup scripts
- VPC SC to stop an LLM revealing data to a user
- Assuming rotation re encrypts old data

04

Managing Operations

Security that depends on people remembering does not scale. Build it into pipelines, images and policies, then watch everything with logs and Security Command Center.

Exam weight: about 19% of questions

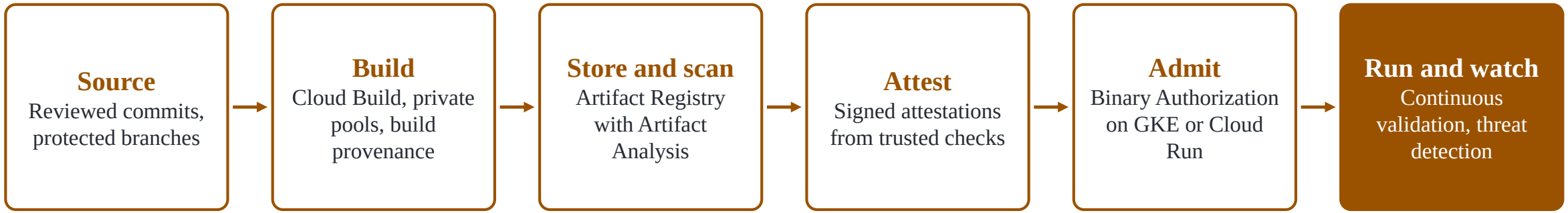


Bar scaled so that 30% would fill the track

4.1 Automating infrastructure and application security

4.2 Logging, monitoring and detection

The Secure Software Supply Chain



Threats along the chain

- Tampered source or dependencies
- Compromised build system
- Images with known CVEs
- Unreviewed images deployed by hand

SLSA in one sentence

- Supply chain Levels for Software Artifacts: a framework of increasing guarantees that an artifact was built from the claimed source by a trusted, tamper resistant build. Cloud Build generates provenance that supports it.

Exam reflex

- "Only trusted images may run" means Binary Authorization.
- "Find CVEs before deploy" means scanning in the pipeline.
- "Find CVEs in what is already running" means continuous scanning and validation.

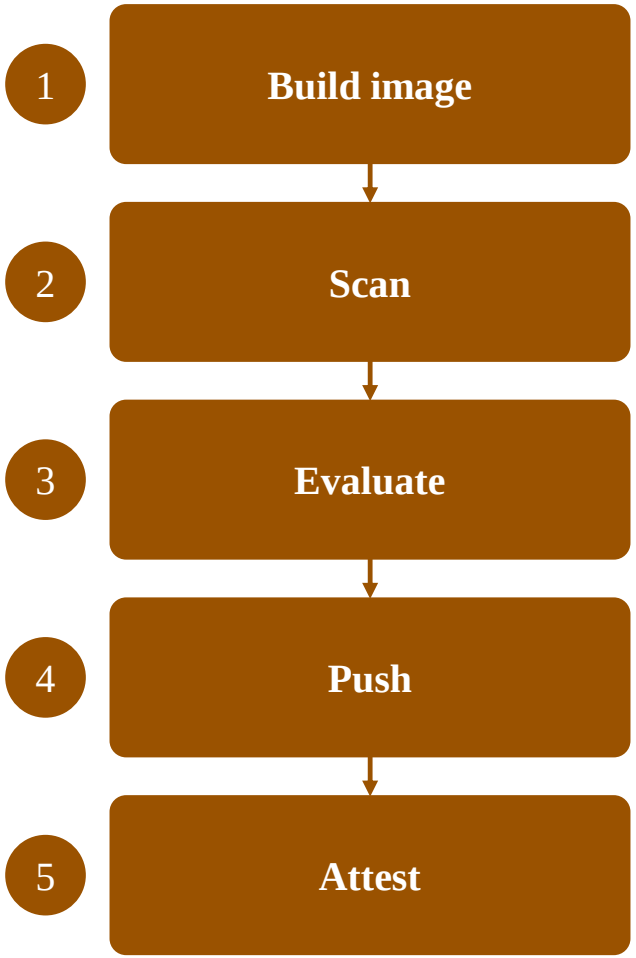
Scanning for CVEs: Automatic versus On Demand

	Automatic scanning	On Demand Scanning
Trigger	Image pushed to Artifact Registry	An API call or gcloud step you run, for example inside Cloud Build
Where the image is	Already in the registry	Local build output or any registry, before push
Keeps up to date	Yes: continuous analysis refreshes results for recently pulled images as new CVEs are published	No: a point in time result
Best use	Ongoing visibility of everything stored	A gate that fails the build before the image is published
Covers	OS packages and supported language packages	OS packages and supported language packages

Use both

On Demand Scanning stops a known bad image from ever reaching the registry. Automatic scanning catches CVEs disclosed after the image was built. A mature pipeline gates with the first and monitors with the second.

A CVE Gate Inside the Pipeline



docker build in Cloud Build

On Demand Scanning of the local image

Any CRITICAL or HIGH with a fix? Fail the build

Only passing images reach Artifact Registry

Sign a "vulnerability checked" attestation with a KMS key

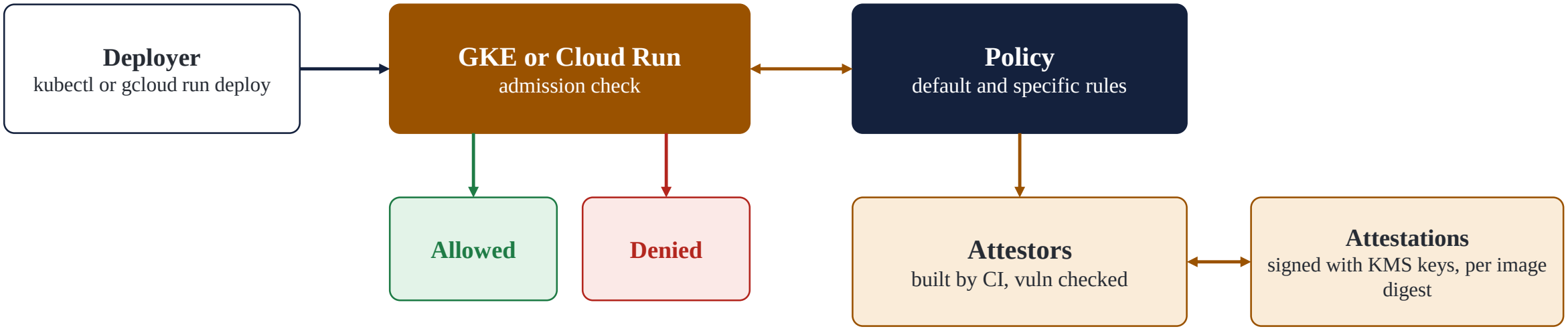
fail

Build fails
developer fixes the base image or package

Why gate on fixable

Blocking on every CVE stalls delivery forever. Gate on severities that have a fix available, and track the rest as findings with owners and deadlines.

Binary Authorization: How Admission Works



1. **Rules evaluate** each image: always allow, always deny, or require attestations from listed attestors.
2. **Images must be referenced by digest,** so an attested image cannot be swapped under the same tag.
3. **Attestations** are signatures created by your pipeline after each check passes, verified with the attestor's public key.
4. **Exempt images** (for example Google maintained system images) can be allowlisted by path pattern.

Binary Authorization: Rolling Out and Staying Safe

Dry run mode

Violations are logged in Cloud Audit Logs but deployments proceed. Start here, fix the pipeline, then enforce.

Enforced mode

Non compliant images are rejected at admission. The setting that actually prevents untrusted code.

Breakglass

An annotation lets an emergency deployment bypass the policy. It is always logged, so alert on it.

Continuous validation

For GKE, periodically checks running pods against check based platform policies and reports pods that no longer comply.

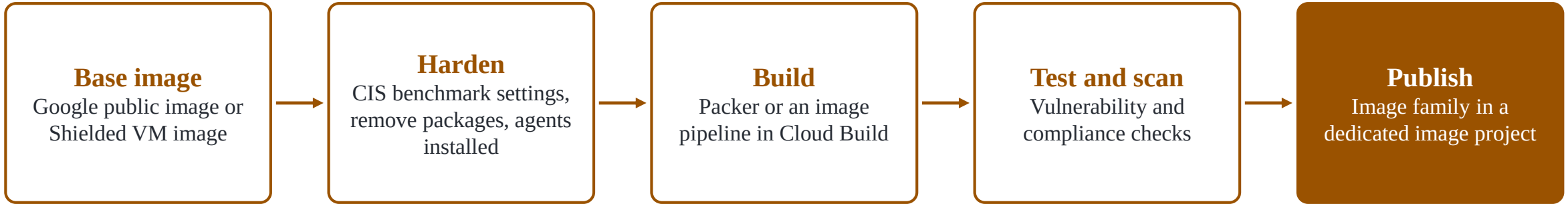
Per cluster rules

Stricter rules for production clusters, relaxed rules for development, in one project policy.

Enforce its use

A custom organization policy constraint can require Binary Authorization on every new GKE cluster.

Automating Hardened VM Images



Only boot trusted images

Org policy compute.trustedImageProjects lists the image projects VMs may boot from. Everything else is rejected at creation.

Image families

Point instance templates at a family; deprecate old images so new VMs always get the latest hardened build.

Rebuild, do not patch forever

Rebuild images on a schedule and on critical CVEs, then roll managed instance groups to the new template.

VM Manager: Patching and Inventory at Scale

VM Manager
OS Config API and agent

Linux and Windows. Results feed compliance dashboards, so you can prove patch levels to auditors.

Patch deployments
Scheduled patch jobs across fleets by label, zone or OS, with rollout and pre and post scripts

OS inventory
Installed packages and available updates on every VM

Vulnerability reports
CVEs affecting each VM, from inventory data

OS policies
Declare required packages, files and settings; drift is corrected

Container Image Hygiene and GKE Maintenance

Minimal base images

- Distroless or slim bases: fewer packages, fewer CVEs
- No shells or package managers in production images

Rebuild often

- Automated rebuilds pick up patched base layers
- Pin by digest, update deliberately

GKE upgrades

- Release channels with node auto upgrade
- Maintenance windows and exclusions control timing
- Container Optimized OS on nodes

Cluster hardening

- Private clusters, Shielded GKE nodes
- Workload Identity Federation for GKE
- Binary Authorization and Security Posture dashboard

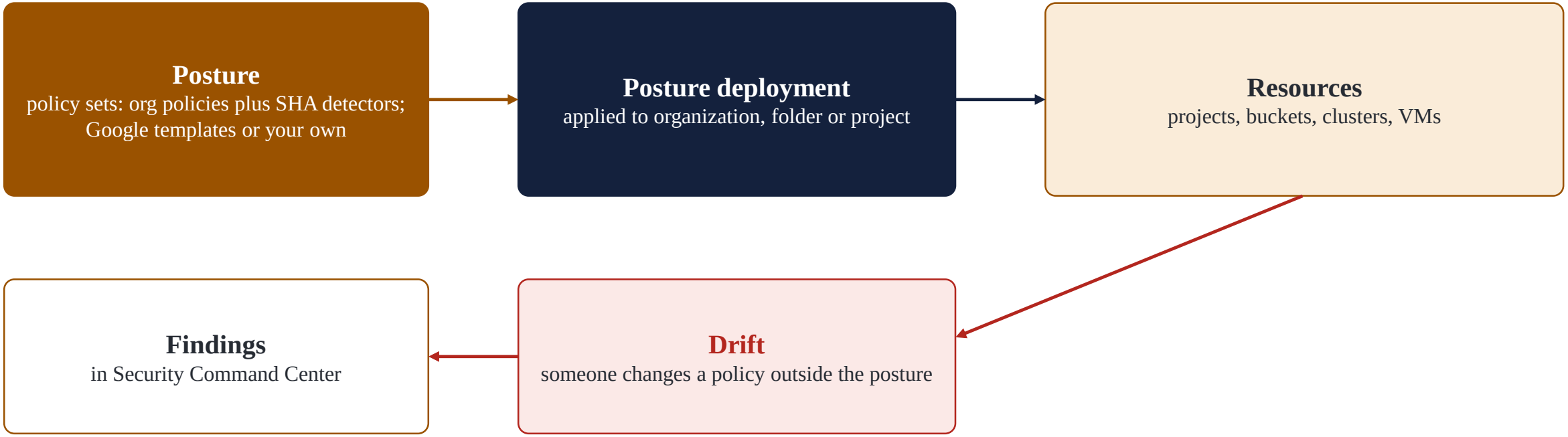
Policy at Scale: Prevent, Detect, Correct

	Prevent (before creation)	Detect (after creation)
Google defined rules	Predefined organization policy constraints	Security Health Analytics built in detectors
Your own rules	Custom organization policy constraints (CEL)	Security Health Analytics custom modules (CEL)
Bundled baseline	Security posture: org policies in a posture	Security posture: SHA detectors and drift reports
Infrastructure as code	Validate Terraform plans against a posture before apply	Cloud Asset Inventory history and feeds
Correct	Remediate findings through pipelines, not console clicks	Automate responses from finding notifications

The pairing to remember

For every rule you care about, prevent the new (organization policy) and detect the existing (Security Health Analytics). Prevention alone ignores yesterday's resources.

Security Posture Service and Drift Detection



1. **One baseline** for many environments, versioned and reviewable.
2. **Drift reports** show exactly which policy was changed and where, so you can restore it.
3. **Shift left:** validate infrastructure as code against the same posture before deployment.

Case Study 48: Stop It Before the Registry

THE SCENARIO

Juniper Health Apps

Juniper builds container images in Cloud Build and pushes them to Artifact Registry. Last month an image with a critical, fixable OpenSSL vulnerability reached production.

Security wants images with critical fixable vulnerabilities to never be published, with no manual review.

What should you do?

A. Grant only the security team permission to push to Artifact Registry.

B. Enable Web Security Scanner on the production application.

C. Add a Cloud Build step that runs On Demand Scanning on the built image and fails the build if critical fixable vulnerabilities are found, before the push step.

D. Review Security Command Center findings weekly and delete vulnerable images.

ANSWER | VULNERABILITY SCANNING

Case Study 48 Answer: C

A

Grant only the security team permission to push to Artifact Registry.

Incorrect. Adds a manual bottleneck without checking vulnerabilities.

B

Enable Web Security Scanner on the production application.

Incorrect. Scans running web apps for issues like XSS; it does not inspect image packages before publish.

C

Add a Cloud Build step that runs On Demand Scanning on the built image and fails the ...

Correct. The gate runs inside the pipeline, so a failing image never reaches the registry, with no human in the loop.

D

Review Security Command Center findings weekly and delete vulnerable images.

Incorrect. Detective and manual; the image is already published and maybe deployed.

Exam lesson

Preventing vulnerable artifacts is a pipeline gate with On Demand Scanning before push.

Clue words in the stem

"Never be published", "no manual review", "Cloud Build"

Case Study 49: Only What the Pipeline Built

THE SCENARIO

Strand Commerce

Strand runs GKE clusters for production. A developer once deployed an image built on a laptop directly to production.

Strand wants only images built by its Cloud Build pipeline and checked for vulnerabilities to run in production clusters, with a logged emergency path.

What should you configure?

A. Binary Authorization in enforced mode for production clusters, requiring attestations from a build attestor and a vulnerability check attestor, with breakglass for emergencies.

B. Restrict Kubernetes Engine Developer to the release team.

C. A Kubernetes admission webhook written in house that checks image names.

D. Artifact Registry IAM so that only Cloud Build can push.

ANSWER | BINARY AUTHORIZATION

Case Study 49 Answer: A

A

Binary Authorization in enforced mode for production clusters, requiring attestations ...

Correct. Admission requires signed proof of both checks for each image digest, and breakglass is logged.

B

Restrict Kubernetes Engine Developer to the release team.

Incorrect. Limits who deploys, but a permitted person could still deploy an unbuilt or unchecked image.

C

A Kubernetes admission webhook written in house that checks image names.

Incorrect. Custom code to maintain, and image names are easy to fake.

D

Artifact Registry IAM so that only Cloud Build can push.

Incorrect. Helps, but images from other registries could still be deployed.

Exam lesson

Trust based on how an image was built and checked, enforced at deploy time, is Binary Authorization with attestors.

Clue words in the stem

"Only images built by its pipeline and checked", "production", "emergency path"

Case Study 50: Boot Only What We Hardened

THE SCENARIO

Hollins Aerospace

Hollins's security team publishes CIS hardened images to a dedicated image project. Teams still create VMs from public images and from images they built themselves.

Hollins wants every new VM in the organization to boot only from the security team's images.

What should you do?

A. Send monthly reminders to all teams.

B. Create a Security Health Analytics custom module that flags VMs from other images.

C. Remove Compute Image User from all teams on public image projects.

D. Set the organization policy compute.trustedImageProjects to allow only the security team's image project.

ANSWER | TRUSTED IMAGES

Case Study 50 Answer: D

A

Send monthly reminders to all teams.

Incorrect. No enforcement.

B

Create a Security Health Analytics custom module that flags VMs from other images.

Incorrect. Detects after the fact; non compliant VMs still run.

C

Remove Compute Image User from all teams on public image projects.

Incorrect. Public images are available to everyone; removing a role does not block them, and teams' own images remain.

D

Set the organization policy compute.trustedImageProjects to allow only the security ...

Correct. Rejects VM creation from any image outside the listed project, organization wide.

Exam lesson

Trusted image enforcement is an organization policy: compute.trustedImageProjects.

Clue words in the stem

"Every new VM", "only from the security team's images"

Case Study 51: Three Thousand Servers, One Patch Tuesday

THE SCENARIO

Pellam Retail

Pellam runs 3,000 Linux and Windows VMs across 60 projects. Patching is done by engineers with SSH scripts, and auditors cannot get evidence of patch levels.

Pellam wants scheduled patching by environment, with reporting of compliance.

What should you use?

A. Recreate every VM monthly from the latest public image.

B. VM Manager patch deployments targeted by labels per environment, with OS inventory and patch compliance reporting.

C. Cloud Scheduler calling SSH on each VM.

D. A startup script that runs the package manager on every reboot.

ANSWER | PATCH MANAGEMENT

Case Study 51 Answer: B

A

Recreate every VM monthly from the latest public image.

Incorrect. Disruptive for stateful VMs and loses hardening applied to custom images.

B

VM Manager patch deployments targeted by labels per environment, with OS inventory and ...

Correct. Scheduled, targeted patch jobs plus inventory give both automation and audit evidence.

C

Cloud Scheduler calling SSH on each VM.

Incorrect. Custom, brittle, and needs SSH access to every VM.

D

A startup script that runs the package manager on every reboot.

Incorrect. VMs that rarely reboot never get patched, and there is no reporting.

Exam lesson

Fleet patching with evidence on Compute Engine is VM Manager.

Clue words in the stem

"Scheduled patching by environment", "reporting of compliance", "Linux and Windows"

Case Study 52: Find Yesterday's Mistakes

THE SCENARIO

Ashby Learning

Ashby has just enforced a custom organization policy that blocks new Cloud SQL instances without automated backups.

An auditor asks how Ashby will find the 200 existing instances created before the policy that may lack backups, and keep watching for them.

What should you do?

A. Export the Cloud SQL instance list once to a spreadsheet.

B. Rely on the custom organization policy; it also fixes existing instances.

C. Recreate all existing instances.

D. Create a Security Health Analytics custom module that detects Cloud SQL instances without automated backups, and review its findings in Security Command Center.

Case Study 52 Answer: D

A

Export the Cloud SQL instance list once to a spreadsheet.

Incorrect. One time and manual; nothing keeps watching.

B

Rely on the custom organization policy; it also fixes existing instances.

Incorrect. Organization policies evaluate create and update requests; existing resources are not changed or reported by enforcement.

C

Recreate all existing instances.

Incorrect. Drastic and risky, and still no ongoing detection.

D

Create a Security Health Analytics custom module that detects Cloud SQL instances ...

Correct. Custom modules continuously scan existing resources against your rule and raise findings.

Exam lesson

Custom org policy prevents the new; SHA custom module detects the existing. Use both.

Clue words in the stem

"Existing instances created before the policy", "keep watching"

Case Study 53: Who Changed the Baseline?

THE SCENARIO

Dunmore Energy

Dunmore applies a security baseline of organization policies and detectors to 12 folders. Twice this quarter an administrator weakened a policy on one folder to unblock a deployment and forgot to restore it.

Dunmore wants the baseline defined once and to be alerted when it is changed anywhere.

What should you use?

A. Security Command Center security posture: define a posture, deploy it to the folders, and monitor drift findings.

B. Cloud Monitoring uptime checks.

C. A nightly script that compares organization policies with a spreadsheet.

D. IAM role recommendations.

ANSWER | SECURITY POSTURE

Case Study 53 Answer: A

A

Security Command Center security posture: define a posture, deploy it to the folders, ...

Correct. Postures package policies and detectors, and drift detection reports changes made outside the posture.

B

Cloud Monitoring uptime checks.

Incorrect. Uptime checks test availability, not configuration.

C

A nightly script that compares organization policies with a spreadsheet.

Incorrect. Custom, delayed, and the spreadsheet itself can drift.

D

IAM role recommendations.

Incorrect. Recommends role changes; unrelated to policy drift.

Exam lesson

A managed baseline with drift alerts is the security posture service.

Clue words in the stem

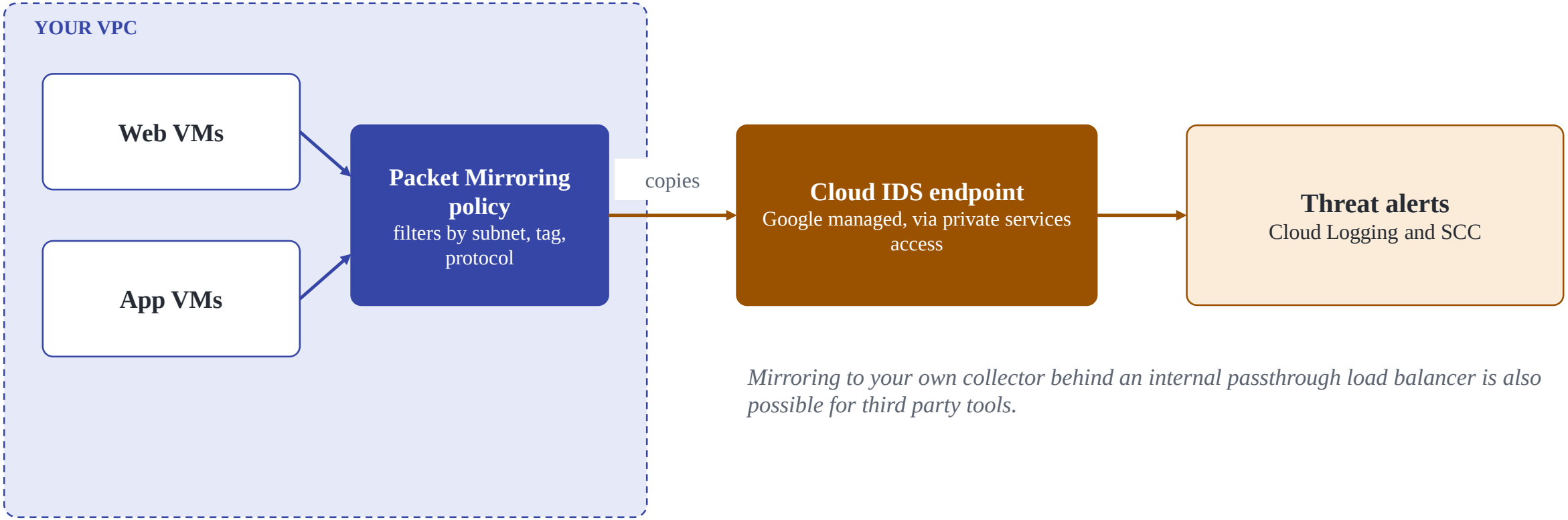
"Defined once", "alerted when it is changed", "baseline"

Network Logs at a Glance

Source	What it records	Use it for
VPC Flow Logs	Sampled flow records (5 tuple, bytes, packets, metadata) per subnet or attachment	Traffic analysis, forensics, exfiltration hunting
Firewall Rules Logging	Each connection matched by a logged rule, allowed or denied	Proving a rule works; who hit a deny rule
Cloud NGFW threat logs	Threats detected or blocked by intrusion prevention	Investigating exploit attempts
Packet Mirroring	Full copies of packets sent to a collector	Deep inspection by IDS or forensic tools
Cloud IDS	Threat alerts from mirrored traffic	Managed detection without inline blocking
Cloud DNS logs	Queries made from VPC networks	Malware callbacks, DNS tunnelling
Log Analytics	SQL over log buckets	Ad hoc investigation across all of the above

Trap: the implied deny rule cannot be logged. To log denied attempts, create an explicit low priority deny rule with logging enabled.

Packet Mirroring and Cloud IDS



Mirroring to your own collector behind an internal passthrough load balancer is also possible for third party tools.

1. **Out of band:** mirrored copies are inspected; original traffic is never delayed or blocked.
2. **Cloud IDS** uses threat detection technology from Palo Alto Networks and reports by severity.
3. **Choose it** when the requirement is detection or compliance evidence of an IDS. Choose NGFW Enterprise when it must block.

Cloud Audit Logs: Four Types

Type	Records	On by default?	Retention (bucket)
Admin Activity	Configuration and metadata changes: create VM, set IAM policy	Always on; cannot be disabled	400 days in _Required
System Event	Google initiated changes, such as live migration	Always on	400 days in _Required
Data Access	Reads of configuration or data, and data writes	Off, except BigQuery; enable per service	30 days in _Default (configurable)
Policy Denied	Access denied by VPC Service Controls or organization policy	On; can be excluded	30 days in _Default (configurable)

Data Access subtypes

ADMIN_READ (read config), DATA_READ (read user data), DATA_WRITE (write user data). Enable only what you need; volume can be large.

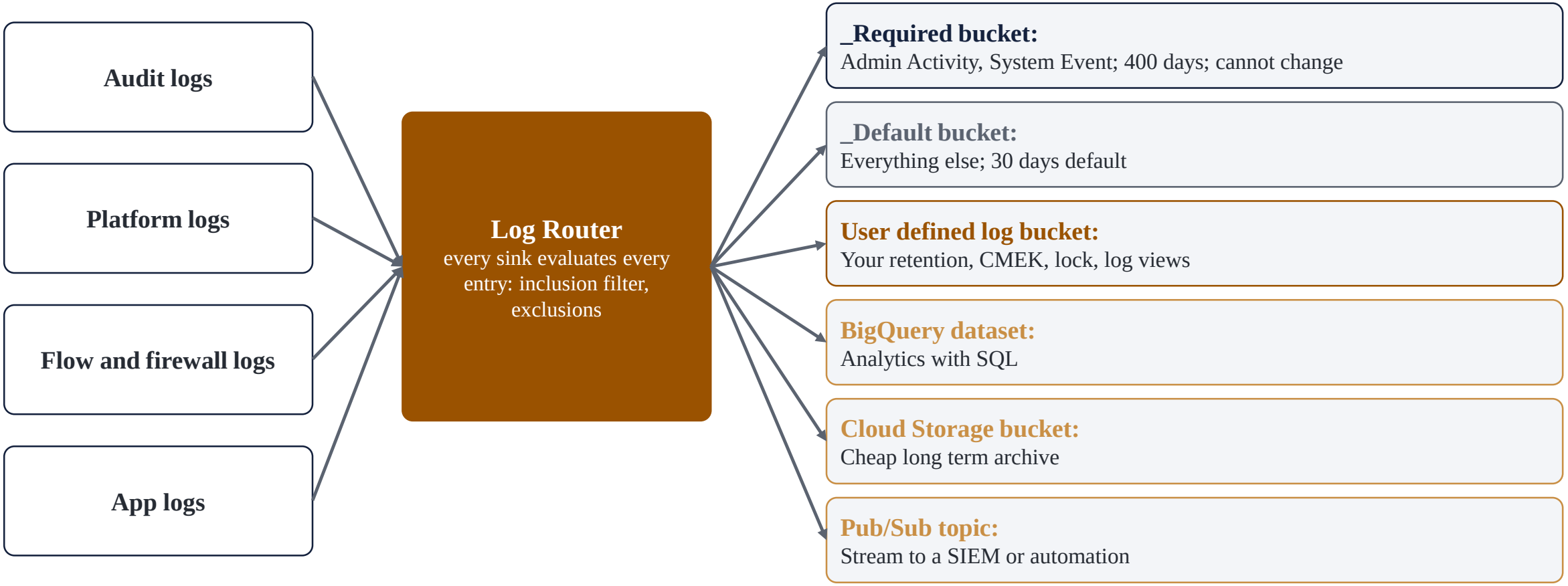
Where to enable

In the IAM policy audit configuration at organization, folder or project, per service, with optional exempted principals.

Who did what

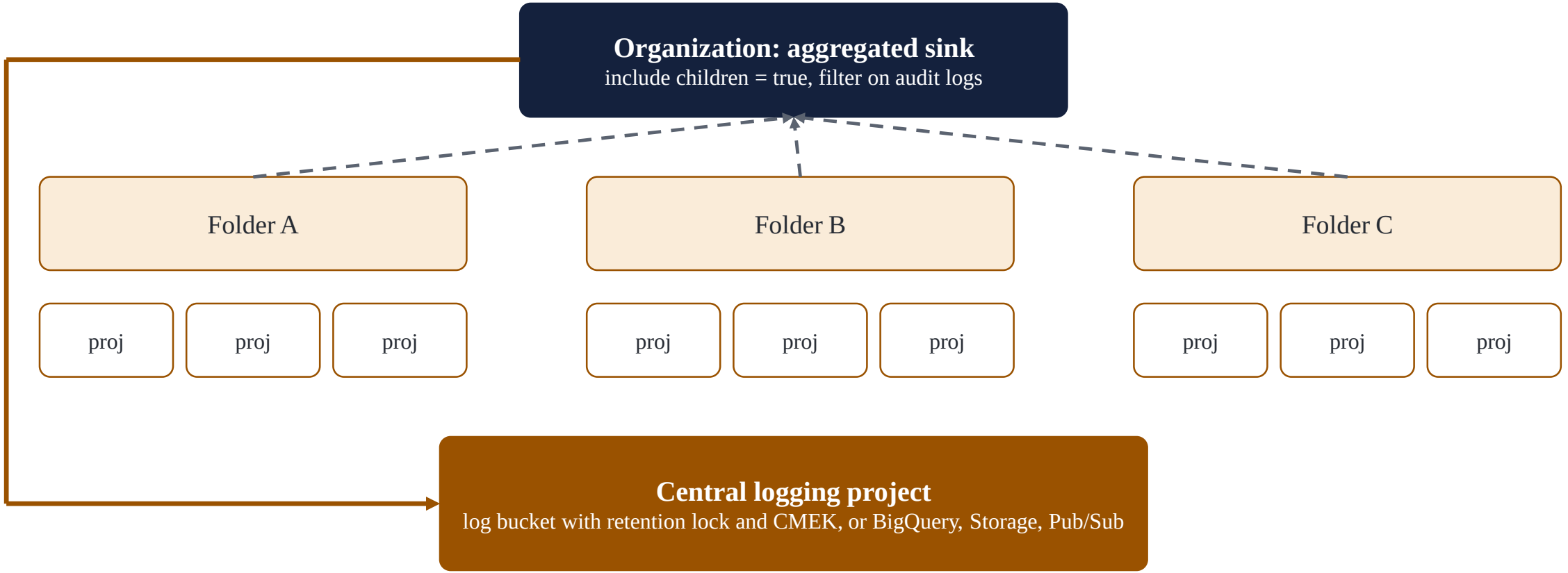
Each entry records the principal, method, resource, caller IP, and for service account keys the key ID.

The Log Router, Buckets and Sinks



Writer identity: each sink writes as its own service account, which you must grant permission on the destination.

Aggregated Sinks: Centralizing an Organization



Why aggregated: one sink covers every existing and future project. Project owners cannot delete it, unlike sinks created inside their projects.

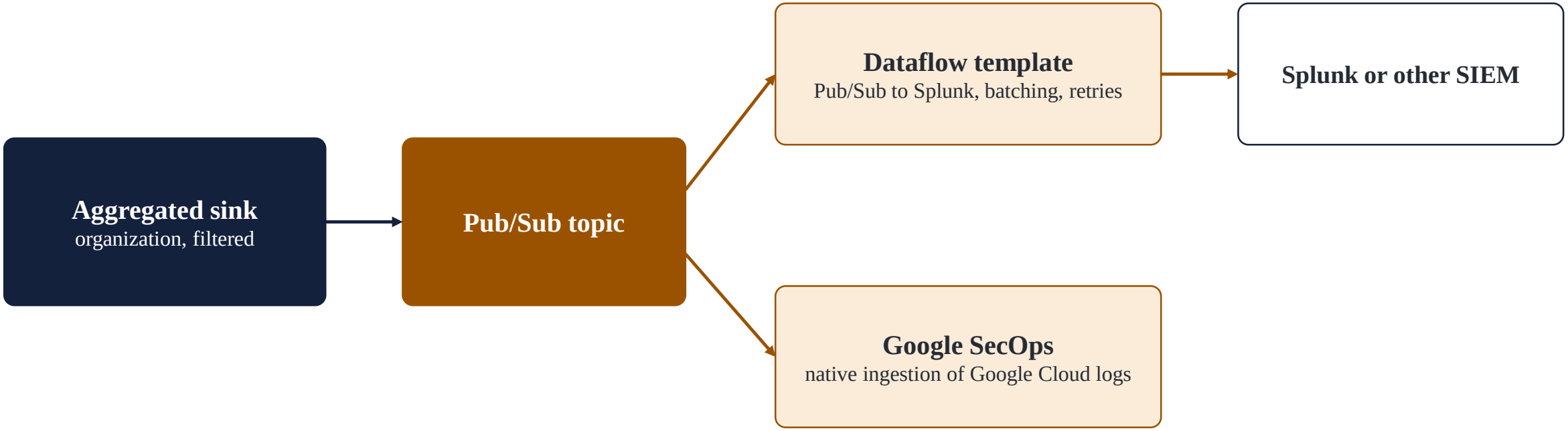
Designing Secure Access to Logs

Need	Control
Read most logs but not Data Access logs	Logs Viewer
Read Data Access logs (they may contain sensitive request details)	Private Logs Viewer, granted sparingly
A team sees only its own projects' logs in a central bucket	Log views with a filter, plus Logs View Accessor on that view
Nobody can shorten retention or delete evidence	Locked retention on the log bucket
Encrypt logs with your key	CMEK on log buckets (and CMEK for the Log Router where required)
Separate operators from auditors	Central logging project owned by the security team, not by workload teams

Exam reflex

Least privilege for log readers is a log view with Logs View Accessor, not Logs Viewer on the whole central project.

Exporting Logs to External Security Systems



1. **Pub/Sub** is the streaming hand off for almost every third party SIEM.
2. **Dataflow** handles scale, batching, retries and a dead letter topic for failed deliveries.
3. **BigQuery or Cloud Storage** sinks suit analytics and archives, not near real time alerting.

An Effective Logging Strategy

Decide what to collect

- Admin Activity: automatic
- Data Access: for sensitive data services
- Flow, firewall and DNS logs: where workloads live
- Application security events

Centralize and protect

- Aggregated sinks to a security owned project
- Locked retention, CMEK
- Separate duties for log admins

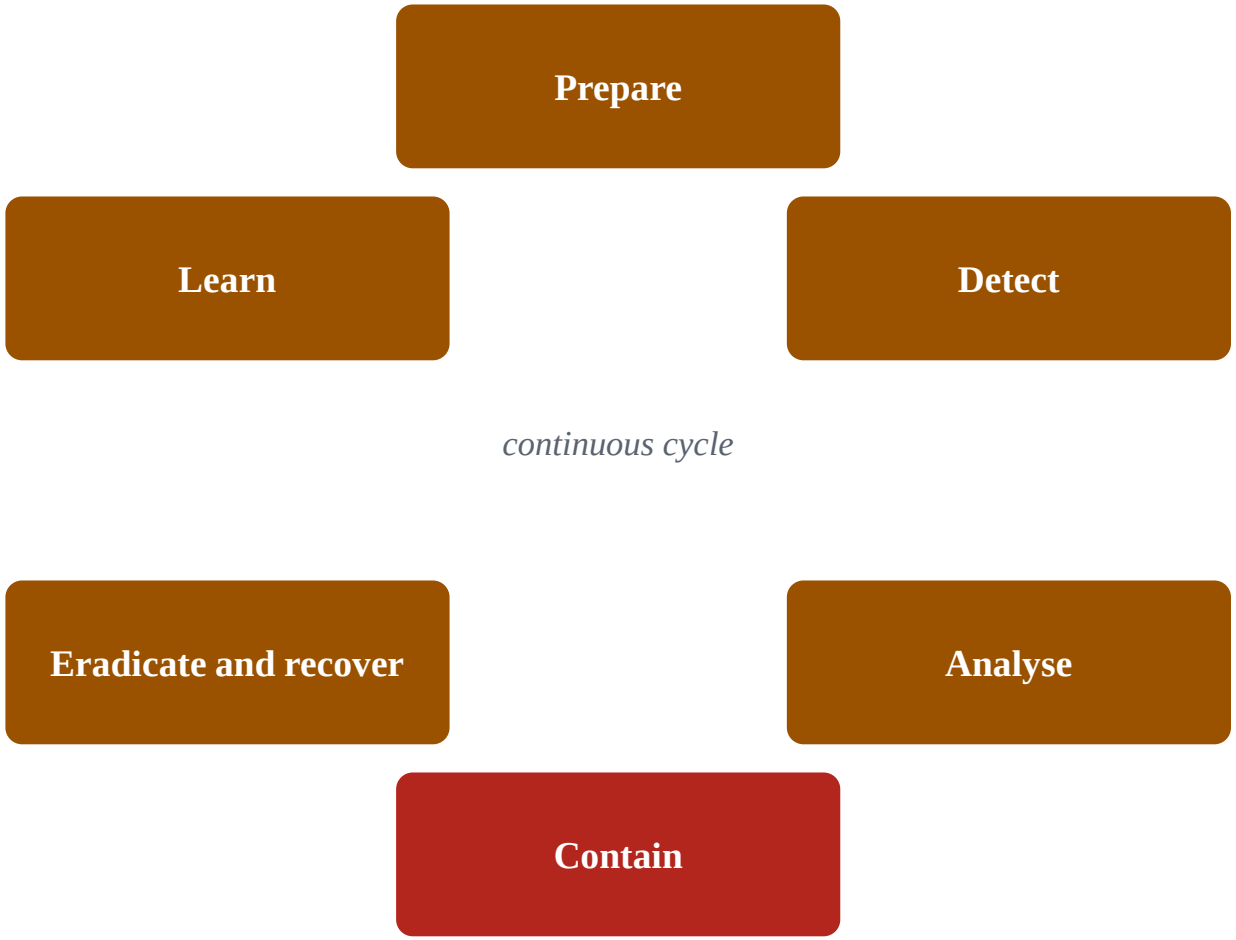
Retain to requirements

- Hot: log buckets for search
- Analytics: BigQuery or Log Analytics
- Archive: Cloud Storage with lifecycle and Bucket Lock

Control cost and noise

- Exclusion filters for high volume debug logs
- Never exclude audit logs you are required to keep
- Sampling for flow logs

Incident Response Lifecycle on Google Cloud



Phase	Google Cloud tools
Prepare	Playbooks, logging on, forensic project, PAM entitlements
Detect	SCC threat detection, alerting policies, SIEM rules
Analyse	Log Analytics, audit logs, flow logs, asset history
Contain	Quarantine firewall, disable keys, suspend users
Eradicate and recover	Rebuild from trusted images, rotate secrets
Learn	Post incident review, new detections and policies

Containing a Compromised VM



Why snapshot first

Deleting or rebooting destroys evidence. Snapshots are cheap and can be shared to a forensic project.

Why a tag, not deletion

Isolation stops spread while keeping the machine for analysis. Tags let automation apply it in seconds.

Automate it

A Security Command Center notification can trigger a function or SOAR playbook that runs these steps.

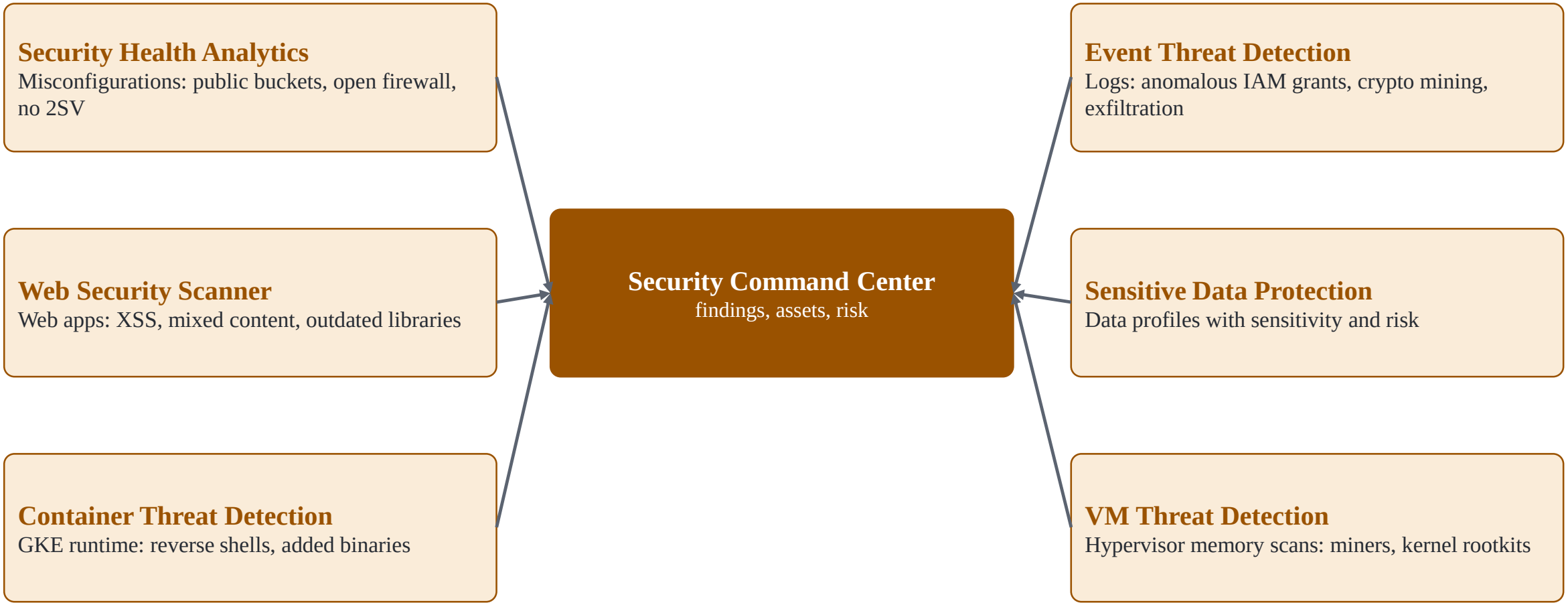
Security Command Center Tiers

Capability	Standard	Premium	Enterprise
Security Health Analytics	Core misconfiguration detectors	All detectors plus custom modules	Yes
Event Threat Detection (log based threats)		Yes	Yes
Container and VM Threat Detection		Yes	Yes
Attack path simulation and toxic combinations		Yes	Yes
Compliance reporting and security posture		Yes	Yes
Multicloud (AWS, Azure) and SIEM, SOAR case management			Yes

Activate at the organization

Organization level activation covers every project, including new ones, and lets you set mute rules and notifications centrally.

Security Command Center Detectors Mapped



Operating Security Command Center

Notifications

Continuous export of findings matching a filter (for example severity HIGH or CRITICAL) to Pub/Sub for paging, tickets or automated response.

BigQuery export

Stream findings to BigQuery for trend dashboards and long term reporting.

Mute rules

Hide findings for accepted risks or test environments by filter, without disabling the detector everywhere.

Security marks

Your own key value labels on assets and findings, used in filters and automation.

Attack exposure

Scores show which findings an attacker could chain to reach high value resources. Fix those first.

Roles

Admin Viewer for read only investigators; Findings Editor for responders; Admin for configuration.

Case Study 54: Who Read the File?

THE SCENARIO

Marlow Legal

A confidential merger document in a Cloud Storage bucket was leaked. Investigators asked who read the object in the past week, but the audit logs show only bucket configuration changes.

Marlow wants this answerable in future for buckets holding client documents.

What should you do?

A. Enable Access Transparency.

B. Enable VPC Flow Logs on all subnets.

C. Enable Data Access audit logs (DATA_READ and DATA_WRITE) for Cloud Storage on the projects holding client documents.

D. Nothing: Admin Activity logs already record object reads.

ANSWER | DATA ACCESS AUDIT LOGS

Case Study 54 Answer: C

A

Enable Access Transparency.

Incorrect. Access Transparency logs Google personnel access, not your own users.

B

Enable VPC Flow Logs on all subnets.

Incorrect. Flow logs show network flows of VMs, not identities reading objects through the API.

C

Enable Data Access audit logs (DATA_READ and DATA_WRITE) for Cloud Storage on the ...

Correct. Data Access logs record who read and wrote objects; they are off by default for Cloud Storage.

D

Nothing: Admin Activity logs already record object reads.

Incorrect. Admin Activity covers configuration changes, not reads of object contents.

Exam lesson

Reads of data are Data Access audit logs, which must be enabled for most services.

Clue words in the stem

"Who read the object", "logs show only configuration changes"

Case Study 55: Four Hundred Projects, One Evidence Store

THE SCENARIO

Carrow Financial Group

Carrow has 400 projects across many folders, with new projects added weekly. Regulators require all audit logs to be retained for seven years where no one, including project owners, can delete or shorten them.

The security team must search recent logs easily.

What should you do?

A. Ask project owners to export logs monthly.

B. Create an aggregated sink at the organization with include children, filtered to audit logs, routing to a log bucket in a central security project with seven year locked retention.

C. Create a sink in each project to a bucket in that project.

D. Increase retention of each project's _Default bucket to seven years.

ANSWER | AGGREGATED SINKS

Case Study 55 Answer: B

A

Ask project owners to export logs monthly.

Incorrect. Manual and unreliable.

B

Create an aggregated sink at the organization with include children, filtered to audit ...

Correct. Covers every current and future project, is controlled by the security team, and locked retention prevents deletion.

C

Create a sink in each project to a bucket in that project.

Incorrect. 400 sinks to maintain, new projects missed, and project owners can delete them.

D

Increase retention of each project's _Default bucket to seven years.

Incorrect. Spread across 400 projects under the control of their owners, with no lock.

Exam lesson

Organization wide, tamper resistant log collection is an aggregated sink into a locked bucket in a central project.

Clue words in the stem

"400 projects", "new projects weekly", "no one can delete or shorten"

Case Study 56: Feeding the On Premises SIEM

THE SCENARIO

Kestle Mining

Kestle's security operations centre uses Splunk on premises. It needs Google Cloud audit and firewall logs from the whole organization in near real time.

The solution must scale with log volume and handle delivery failures.

What should you do?

A. Create a sink to Cloud Storage and upload the files to Splunk daily.

B. Write a script on a VM that calls the Logging API every minute.

C. Create an organization aggregated sink to a Pub/Sub topic and use the Dataflow Pub/Sub to Splunk template.

D. Create an organization aggregated sink to BigQuery and let Splunk query it every hour.

ANSWER | SIEM EXPORT

Case Study 56 Answer: C

A

Create a sink to Cloud Storage and upload the files to Splunk daily.

Incorrect. Daily batches are far from near real time.

B

Write a script on a VM that calls the Logging API every minute.

Incorrect. Custom, single point of failure, and API quotas.

C

Create an organization aggregated sink to a Pub/Sub topic and use the Dataflow Pub/Sub ...

Correct. Pub/Sub streams logs as they are written; Dataflow scales, batches, retries and dead letters failures.

D

Create an organization aggregated sink to BigQuery and let Splunk query it every hour.

Incorrect. Hourly queries are not near real time and are costly.

Exam lesson

Streaming logs to a third party SIEM: aggregated sink to Pub/Sub, then a subscriber such as Dataflow.

Clue words in the stem

"Near real time", "scale", "delivery failures", "Splunk"

Case Study 57: Each Team Sees Its Own

THE SCENARIO

Ingram Media

All Ingram projects route logs to one central log bucket. Application teams want to search their own logs there.

Each team must see only logs from its own projects, and the security team must keep sole control of the bucket.

What should you do?

A. Create a log view per team filtered to its projects, and grant Logs View Accessor on that view to the team's group.

B. Grant every team Logs Viewer on the central logging project.

C. Copy each team's logs to a bucket in the team's project with a second sink.

D. Grant teams Private Logs Viewer on the central project.

ANSWER | LOG ACCESS

Case Study 57 Answer: A

A

Create a log view per team filtered to its projects, and grant Logs View Accessor on ...

Correct. Log views restrict visible entries by filter, and the accessor role is granted per view, keeping least privilege.

B

Grant every team Logs Viewer on the central logging project.

Incorrect. Teams would see every project's logs.

C

Copy each team's logs to a bucket in the team's project with a second sink.

Incorrect. Duplicates storage and gives teams control over copies of evidence.

D

Grant teams Private Logs Viewer on the central project.

Incorrect. Even broader: includes Data Access logs from everyone.

Exam lesson

Partitioning a shared log bucket by audience is done with log views and Logs View Accessor.

Clue words in the stem

"Only logs from its own projects", "one central bucket"

Case Study 58: Knocking on the Database Door

THE SCENARIO

Treadwell Clinics

Auditors require a record of every connection attempt to the patient database subnet that is denied by the firewall, including source IP and time.

Today the only rules are an allow rule for the app tier and the implied deny.

What should you do?

A. Enable logging on the implied deny ingress rule.

B. Enable VPC Flow Logs with 100% sampling.

C. Enable Data Access audit logs for Compute Engine.

D. Create an explicit deny ingress rule for the database subnet at a lower priority than the allow rule, with Firewall Rules Logging enabled.

ANSWER | FIREWALL RULES LOGGING

Case Study 58 Answer: D

A

Enable logging on the implied deny ingress rule.

Incorrect. Implied rules cannot have logging enabled.

B

Enable VPC Flow Logs with 100% sampling.

Incorrect. Flow logs are designed around observed flows, not as an authoritative record of each firewall denial.

C

Enable Data Access audit logs for Compute Engine.

Incorrect. Audit logs record API calls, not network packets.

D

Create an explicit deny ingress rule for the database subnet at a lower priority than ...

Correct. An explicit deny catches the same traffic, and its logging records each denied connection with source and time.

Exam lesson

To log denied traffic, replace reliance on the implied deny with an explicit, logged deny rule.

Clue words in the stem

"Denied by the firewall", "every connection attempt", "only the implied deny"

Case Study 59: A Miner in the Machine

THE SCENARIO

Osprey Games

Event Threat Detection reports cryptocurrency mining from a Compute Engine VM that runs as a service account with Storage Admin.

Osprey must stop the activity and preserve evidence for a forensic investigation.

Which two actions should you take first? (Choose two.)

A. Delete the VM immediately.

B. Snapshot the VM's disks, then apply a quarantine secure tag whose firewall rules deny all ingress and egress except from the forensic subnet.

C. Mute the finding to stop further alerts.

D. Disable the VM's service account (or remove its roles) and disable any of its keys.

ANSWER | INCIDENT RESPONSE

Case Study 59 Answer: B and D

A

Delete the VM immediately.

Incorrect. Destroys the evidence the investigation needs.

B

Snapshot the VM's disks, then apply a quarantine secure tag whose firewall rules deny ...

Correct. Preserves the disk state and stops the VM communicating, while keeping it for analysis.

C

Mute the finding to stop further alerts.

Incorrect. Hides the problem without containing it.

D

Disable the VM's service account (or remove its roles) and disable any of its keys.

Correct. Stops the attacker using the VM's powerful identity elsewhere, for example against Cloud Storage.

Exam lesson

Contain without destroying: snapshot, isolate the network, and cut the identity.

Clue words in the stem

"Stop the activity", "preserve evidence", "Storage Admin"

Case Study 60: Page Me for Critical Only

THE SCENARIO

Wren Bank

Wren's on call security engineer checks the Security Command Center console twice a day. A critical finding sat unnoticed for nine hours.

Wren wants HIGH and CRITICAL findings sent to its paging tool within minutes, and nothing else.

What should you configure?

A. A daily export of all findings to BigQuery.

B. Email digests of all findings to the on call engineer.

C. Mute rules for all MEDIUM and LOW findings.

D. A Security Command Center notification config (continuous export) to Pub/Sub filtered on HIGH and CRITICAL severity, with a subscriber that calls the paging tool.

ANSWER | SCC NOTIFICATIONS

Case Study 60 Answer: D

A

A daily export of all findings to BigQuery.

Incorrect. Daily is not within minutes, and BigQuery is not a paging system.

B

Email digests of all findings to the on call engineer.

Incorrect. Not filtered, and digests are not immediate.

C

Mute rules for all MEDIUM and LOW findings.

Incorrect. Reduces noise but still requires someone to watch the console.

D

A Security Command Center notification config (continuous export) to Pub/Sub filtered on ...

Correct. Filtered notifications stream matching findings as they are created; a subscriber turns them into pages.

Exam lesson

Near real time routing of findings is a Security Command Center notification to Pub/Sub with a filter.

Clue words in the stem

"Within minutes", "HIGH and CRITICAL", "paging tool"

SECTION 4 RECAP

Section 4 Recap: Managing Operations

Must remember

- On Demand Scanning gates the pipeline; automatic scanning watches the registry
- Binary Authorization: attestors, digests, dry run, breakglass
- compute.trustedImageProjects for golden images
- Admin Activity: always on, 400 days; Data Access: mostly off
- Implied deny cannot be logged
- Aggregated sinks cover future projects
- Snapshot before you isolate

Pick this when you read...

"Never published if vulnerable" On Demand Scanning gate

"Only trusted images run" Binary Authorization

"Patch thousands of VMs" VM Manager

"Existing resources" SHA custom module

"Baseline drift" Security posture

"Who read data" Data Access logs

"Team sees own logs" Log views

"Splunk, near real time" Pub/Sub sink

Classic traps

- Organization policy to find existing resources
- Logs Viewer for Data Access logs
- Deleting a compromised VM first
- Cloud IDS when blocking is required
- BigQuery sink for real time alerting
- Per project sinks for organization coverage

05

Supporting Compliance Requirements

Regulations describe outcomes. Your job is to translate each outcome into Google Cloud controls and prove they work.

Exam weight: about 11% of questions



Bar scaled so that 30% would fill the track

5.1 Regulatory and industry standards: shared responsibility, Assured Workloads, Access Transparency and Approval, residency, scoping and control mapping

The Shared Responsibility Model

	IaaS	PaaS	SaaS
Data and content	Customer	Customer	Customer
Identities and access	Customer	Customer	Customer
Application	Customer	Customer	Google
Network configuration	Customer	Shared	Google
Operating system	Customer	Google	Google
Virtualization	Google	Google	Google
Hardware and network	Google	Google	Google
Physical facilities	Google	Google	Google

Never moves

Your data, who can access it, and how you configure services are always yours, in every model.

Shared fate

Google goes further with secure defaults, blueprints and Assured Workloads to help you carry your share.

Determining Technical Needs: Compute, Data, Network, Storage

Domain	Typical regulatory need	Google Cloud controls
Compute	Isolation, integrity, protection in use	Shielded VMs, Confidential VMs, sole tenant nodes, trusted images, OS Login
Data	Classification, minimization, key control	Sensitive Data Protection, CMEK, Cloud EKM, Secret Manager, column security
Network	Segmentation, encryption in transit, no public exposure	VPC design, Cloud NGFW, VPC Service Controls, private connectivity, MACsec or HA VPN
Storage	Residency, retention, immutability, deletion	Resource location policy, retention policies and Bucket Lock, lifecycle rules, crypto shredding
Identity	Strong authentication, least privilege, reviews	SSO, 2SV with security keys, IAM recommender, PAM, deny policies
Evidence	Audit trails and reports	Cloud Audit Logs, locked log buckets, SCC compliance reports, Access Transparency

Assured Workloads: Compliance Guardrails in a Folder

Choose a control package
for example FedRAMP High, IL4, CJIS, ITAR, EU Sovereign Controls

Assured Workloads folder
created with the right policies applied

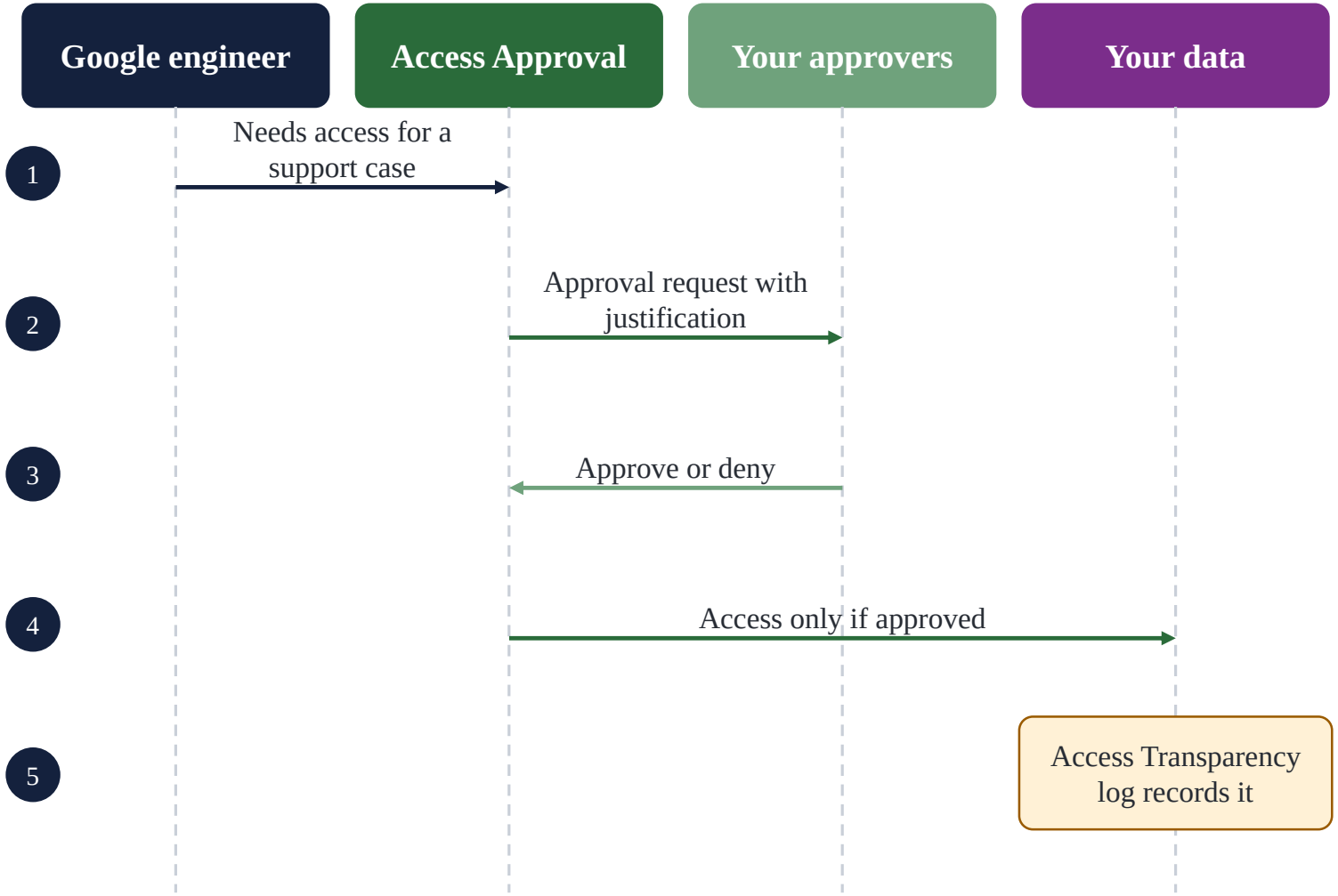
Exam cue: a named regulatory regime (FedRAMP, IL4, CJIS, ITAR, EU sovereignty) plus "with minimal configuration" points to Assured Workloads.

Data residency	Resource location policy limits regions
Service restrictions	Only services approved for the package
Personnel controls	Support by personnel meeting location or citizenship rules
Encryption	CMEK or EKM requirements where the package demands
Monitoring	Alerts when someone changes a guardrail in the folder

Remember

Assured Workloads configures guardrails; you still own compliant use.

Access Transparency, Access Approval, Key Access Justifications



Control	Gives you
Access Transparency	Logs of Google personnel access, with reason
Access Approval	A veto: access waits for your approval
Key Access Justifications	A reason with each EKM key request, and a policy to refuse

Memory hook

Transparency tells you.
Approval asks you.
Justifications explain each key use.

5.1 COMPLIANCE

Regionalization of Data and Services

Resource location policy

gcp.resourceLocations allows creation only in listed regions or value groups (for example the EU group). Applies at creation of location aware resources.

Choose regional services

Regional buckets, datasets and key rings; avoid multi regions outside the allowed area.

Keys in the same place

Cloud KMS key location must match the region of the data it protects.

Logs have locations too

Set the organization default storage location for log buckets so new _Default buckets are regional.

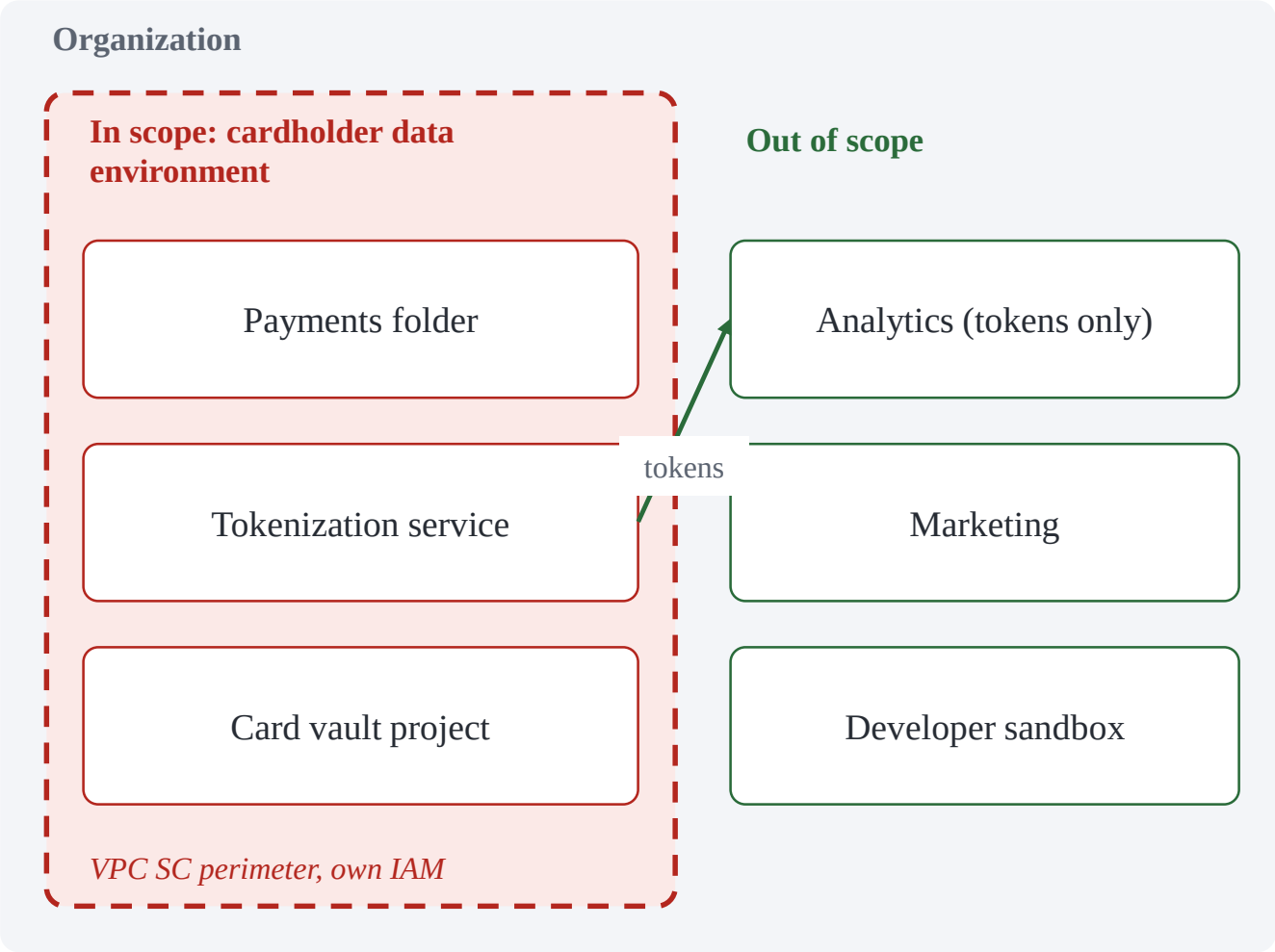
Regional endpoints

Use locational API endpoints where data in transit must stay within a jurisdiction.

Know the limits

Some global resources and metadata are outside the policy; check each service's residency terms.

Determining the Environment in Scope



1. **Scope follows the data.** Any system that stores, processes or transmits regulated data, or can affect its security, is in scope.

2. **Shrink scope** by isolating in dedicated folders, projects and perimeters.

3. **Tokenize** with Sensitive Data Protection so downstream systems never hold raw data.

4. **Check Google's list** of in scope services for the standard before choosing a service.

Mapping Requirements to Controls: PCI DSS Example

Requirement theme	Google Cloud controls
Network security controls and segmentation	Cloud NGFW policies, Shared VPC, VPC Service Controls, private connectivity
Protect stored account data	Tokenization with SDP, CMEK or HSM keys, column level security
Encrypt transmission over open networks	TLS at load balancers with SSL policies, HA VPN, MACsec
Secure systems and software	Artifact Analysis scanning, Binary Authorization, VM Manager patching
Restrict access by need to know	IAM least privilege, groups, deny policies, PAM
Identify and authenticate users	SSO, 2SV with security keys, session control, no shared accounts
Log and monitor all access	Admin Activity and Data Access logs, aggregated sinks, locked retention
Test security regularly	Security Command Center, Web Security Scanner, penetration tests

Audit log coverage is a frequent gap: Data Access logs are off by default for most services.

Producing Compliance Evidence

1 Compliance Reports Manager

Download Google's certifications and audit reports (ISO 27001, SOC 2, PCI DSS attestation) to show your auditor Google's side.

2 SCC compliance reports

Map Security Health Analytics findings to frameworks such as CIS, PCI DSS and NIST, showing your configuration side.

3 Audit logs and Access Transparency

Prove who did what, including Google personnel, with retention that matches the regulation.

4 Policy as evidence

Organization policies, postures and Assured Workloads monitoring show preventive controls are enforced, not just written.

Case Study 61: A Government Contract

THE SCENARIO

Brightline Civic Software

Brightline won a contract to host a US federal agency workload that must meet FedRAMP High. Data must stay in US regions, only approved services may be used, and support access must be limited to qualified US personnel.

Brightline has a small team and wants the controls configured for it.

What should you do?

A. Create an Assured Workloads folder with the FedRAMP High control package and deploy the workload there.

B. Enable Access Transparency for the organization.

C. Create a normal folder and set the resource location policy to US regions.

D. Create a VPC Service Controls perimeter around the agency projects.

ANSWER | ASSURED WORKLOADS

Case Study 61 Answer: A

A

Create an Assured Workloads folder with the FedRAMP High control package and deploy the ...

Correct. Applies residency, approved services, personnel and monitoring guardrails for FedRAMP High in one step.

B

Enable Access Transparency for the organization.

Incorrect. Provides visibility of access, not the full set of FedRAMP controls.

C

Create a normal folder and set the resource location policy to US regions.

Incorrect. Covers residency only; service restrictions and personnel controls are missing.

D

Create a VPC Service Controls perimeter around the agency projects.

Incorrect. Limits data movement but has nothing to do with FedRAMP scope or personnel.

Exam lesson

A named regime with residency, service and personnel requirements: Assured Workloads with that control package.

Clue words in the stem

"FedRAMP High", "US personnel", "configured for it"

CASE STUDY 62 | DATA RESIDENCY

Case Study 62: Europe Only

THE SCENARIO

Lucerna Health

Under its data protection commitments, Lucerna must ensure that no storage or compute resources holding patient data are ever created outside the European Union.

Developers in 40 projects create resources daily through Terraform.

What should you do?

A. Add a code review checklist item for regions in Terraform.

B. Use Security Health Analytics to find resources outside the EU every day.

C. Enforce gcp.resourceLocations at the organization (or patient data folder) with the EU location group.

D. Create a VPC Service Controls perimeter including only EU projects.

ANSWER | DATA RESIDENCY

Case Study 62 Answer: C

A

Add a code review checklist item for regions in Terraform.

Incorrect. A human check that can be skipped or missed.

B

Use Security Health Analytics to find resources outside the EU every day.

Incorrect. Detects after creation; the requirement is that they are never created.

C

Enforce gcp.resourceLocations at the organization (or patient data folder) with the EU ...

Correct. Requests to create location aware resources outside the allowed group are rejected, for every project below.

D

Create a VPC Service Controls perimeter including only EU projects.

Incorrect. Perimeters control API access paths, not where resources are created.

Exam lesson

Preventing resource creation outside a region is the resource location organization policy.

Clue words in the stem

"Never created outside the EU", "40 projects", "daily"

Case Study 63: Ask Us First

THE SCENARIO

Harrowgate Private Bank

Harrowgate's regulator requires that no cloud provider employee may access the bank's customer data unless a named bank officer explicitly approves each access in advance.

Harrowgate also needs a record of every access that does occur.

Which two controls should you enable? (Choose two.)

A. Access Approval, with the bank officers as approvers.

B. Data Access audit logs only.

C. VPC Service Controls.

D. Access Transparency.

ANSWER | ACCESS APPROVAL

Case Study 63 Answer: A and D

A

Access Approval, with the bank officers as approvers.

Correct. Google personnel access to supported services waits for an explicit approval from the configured approvers.

B

Data Access audit logs only.

Incorrect. Records your own principals' access, not provider personnel access with justifications.

C

VPC Service Controls.

Incorrect. Perimeters constrain API access paths; they do not govern provider personnel access processes.

D

Access Transparency.

Correct. Records Google personnel access with justification, giving the required log.

Exam lesson

Approval before access: Access Approval. A log of provider access: Access Transparency.

Clue words in the stem

"Explicitly approves each access in advance", "record of every access"

Case Study 64: Who Patches Now?

THE SCENARIO

Fernhill Logistics

Fernhill is migrating a self managed MySQL database on Compute Engine to Cloud SQL. The operations manager asks which security tasks will still belong to Fernhill after the move.

Which responsibility remains with Fernhill?

A. Hypervisor security of the host machines.

B. Physical security of the database hardware.

C. Controlling who can connect: IAM, database users, network access and connection encryption settings.

D. Patching the database server operating system.

ANSWER | SHARED RESPONSIBILITY

Case Study 64 Answer: C

A

Hypervisor security of the host machines.

Incorrect. Always Google's responsibility.

B

Physical security of the database hardware.

Incorrect. Always Google's responsibility.

C

Controlling who can connect: IAM, database users, network access and connection ...

Correct. Access configuration, identities and data are always the customer's, even on a managed service.

D

Patching the database server operating system.

Incorrect. Cloud SQL is managed; Google maintains the underlying OS and database engine patches.

Exam lesson

Managed services shift infrastructure tasks to Google; identity, access configuration and data never move.

Clue words in the stem

"Self managed to Cloud SQL", "still belong to Fernhill"

Case Study 65: Shrinking the PCI Scope

THE SCENARIO

Kittering Retail

Kittering stores primary account numbers in BigQuery tables used by 15 analytics projects, so all 15 are in PCI DSS scope.

Kittering wants to reduce the number of systems in scope while analysts keep the ability to count purchases per card.

Which two actions should you take? (Choose two.)

A. Enable Access Transparency on analytics projects.

B. Grant analysts BigQuery Admin to speed up work.

C. Tokenize card numbers with Sensitive Data Protection using deterministic encryption before data reaches analytics projects.

D. Keep raw card data only in a dedicated, isolated cardholder data environment (its own folder, projects and VPC Service Controls perimeter).

ANSWER | COMPLIANCE SCOPE

Case Study 65 Answer: C and D

A

Enable Access Transparency on analytics projects.

Incorrect. Useful visibility, but it does not change scope.

B

Grant analysts BigQuery Admin to speed up work.

Incorrect. Broadens access; increases risk and does nothing for scope.

C

Tokenize card numbers with Sensitive Data Protection using deterministic encryption ...

Correct. Consistent tokens still allow counting per card, while analytics systems never hold real card numbers.

D

Keep raw card data only in a dedicated, isolated cardholder data environment (its own ...

Correct. Concentrates in scope systems in one controlled environment, taking the rest out of scope.

Exam lesson

Reduce compliance scope by isolating regulated data and tokenizing it for everyone else.

Clue words in the stem

"Reduce the number of systems in scope", "count purchases per card"

Case Study 66: The Auditor Wants Google's Report

THE SCENARIO

Ambercourt Services

Ambercourt's external auditor asks for evidence that the cloud provider's own controls have been independently audited, specifically a recent SOC 2 report for Google Cloud.

Where should you obtain it?

A. A Google Cloud support case requesting Google's internal logs.

B. Cloud Audit Logs for the organization.

C. Security Command Center compliance dashboard.

D. Compliance Reports Manager.

ANSWER | EVIDENCE

Case Study 66 Answer: D

A

A Google Cloud support case requesting Google's internal logs.

Incorrect. Unnecessary; reports are self service.

B

Cloud Audit Logs for the organization.

Incorrect. Your activity logs, not an independent audit of Google.

C

Security Command Center compliance dashboard.

Incorrect. Shows your configuration against frameworks, not Google's third party audit reports.

D

Compliance Reports Manager.

Correct. Provides Google's certifications and audit reports, such as SOC 2 and ISO 27001, for download.

Exam lesson

Google's side of compliance evidence: Compliance Reports Manager. Your side: SCC reports, logs and policies.

Clue words in the stem

"Cloud provider's own controls", "SOC 2 report"

SECTION 5 RECAP

Section 5 Recap: Compliance

Must remember

- Data, identities and access configuration are always yours
- Assured Workloads applies a control package to a folder
- Transparency logs; Approval asks first
- gcp.resourceLocations prevents creation outside allowed regions
- Scope follows the data; isolate and tokenize to shrink it
- Data Access logs are off by default

Pick this when you read...

"FedRAMP, IL4, ITAR, sovereign" Assured Workloads

"Only in the EU" resource location policy

"Approve before Google accesses" Access Approval

"Log of Google access" Access Transparency

"Reduce PCI scope" isolate and tokenize

"Google's SOC 2" Compliance Reports Manager

Classic traps

- VPC SC as a residency control
- Access Transparency when approval is required
- Thinking managed services move IAM duties to Google
- Detective scans for "never created" requirements

06

Mixed Mock Exam

Real questions mix domains. Each scenario below needs at least two sections of this tutorial to answer well.

M Ten cross domain case studies, written to the same standard as the real exam

T Give yourself two minutes per question

R Score yourself, then revisit the section of every miss

Case Study 67: Day One of a New Organization

THE SCENARIO

Pellucid Labs

Pellucid has just created its Google Cloud organization. Every user in the domain can currently create projects, and there are no guardrails.

The CISO asks for the two highest value preventive changes to make before teams start building.

Which two actions should you take? (Choose two.)

A. Grant every engineer Viewer at the organization so they can learn.

B. Enable Security Command Center notifications for all findings.

C. Remove Project Creator and Billing Account Creator from the whole domain and grant them only to the platform team's automation.

D. Enforce baseline organization policies: domain restricted sharing, disable service account key creation, skip default network creation, and restrict external IPs.

ANSWER | MIXED: IDENTITY AND ORGANIZATION

Case Study 67 Answer: C and D

A

Grant every engineer Viewer at the organization so they can learn.

Incorrect. Broad read access to everything conflicts with least privilege.

B

Enable Security Command Center notifications for all findings.

Incorrect. Detective, not preventive; useful later.

C

Remove Project Creator and Billing Account Creator from the whole domain and grant them ...

Correct. Stops shadow projects outside the guardrails from day one.

D

Enforce baseline organization policies: domain restricted sharing, disable service ...

Correct. Blocks the most common misconfigurations everywhere, for every future project.

Exam lesson

Bootstrap an organization by controlling project creation and applying baseline organization policies first.

Clue words in the stem

"Just created", "preventive", "before teams start building"

Case Study 68: An Internal App for Employees

THE SCENARIO

Thistledown Media

Thistledown runs an internal HR app on Cloud Run. Only employees should reach it, from company managed devices, through a browser.

The app must not be reachable directly from the internet, and the team will not change application code for authentication.

What should you do?

A. Make the Cloud Run service public and add a login page in the app.

B. Use Cloud NAT so the service has no public address.

C. Allow only the corporate IP range with a VPC firewall rule.

D. Put the service behind an external Application Load Balancer, set Cloud Run ingress to internal and Cloud Load Balancing, and enable IAP with an access level requiring managed devices.

ANSWER | MIXED: NETWORK AND IDENTITY

Case Study 68 Answer: D

A

Make the Cloud Run service public and add a login page in the app.

Incorrect. Requires code changes and exposes the service directly.

B

Use Cloud NAT so the service has no public address.

Incorrect. Cloud NAT is outbound only and unrelated to who can reach Cloud Run.

C

Allow only the corporate IP range with a VPC firewall rule.

Incorrect. Cloud Run is not a VM in your VPC; firewall rules do not protect its public URL, and IP alone ignores device posture.

D

Put the service behind an external Application Load Balancer, set Cloud Run ingress to ...

Correct. IAP enforces identity and device context at the load balancer; the ingress setting blocks direct internet access to the service URL.

Exam lesson

Identity and device aware access to web apps without code changes is IAP behind a load balancer.

Clue words in the stem

"Only employees", "managed devices", "not reachable directly", "no code changes"

Case Study 69: The Owner Who Could Erase the Trail

THE SCENARIO

Gorsedale Bank

Project owners at Gorsedale can delete project level log sinks and change _Default bucket retention. An internal audit warns that a malicious owner could remove evidence of their own actions.

Audit logs must be preserved for five years beyond the reach of project owners.

What should you do?

A. Create an organization aggregated sink for audit logs to a log bucket in a security owned project, with a five year retention policy that is locked.

B. Remove the Owner role from everyone.

C. Create an alert when a project sink is deleted.

D. Enable Data Access logs in every project.

ANSWER | MIXED: LOGGING AND IAM

Case Study 69 Answer: A

A

Create an organization aggregated sink for audit logs to a log bucket in a security ...

Correct. Owners of workload projects have no permissions on the organization sink or the central locked bucket, so evidence survives.

B

Remove the Owner role from everyone.

Incorrect. Impractical, and does not address where logs are kept.

C

Create an alert when a project sink is deleted.

Incorrect. Detects after evidence is already at risk.

D

Enable Data Access logs in every project.

Incorrect. Adds more logs that owners could still remove.

Exam lesson

Separate the log store from those being logged: aggregated sink, central project, locked retention.

Clue words in the stem

"Beyond the reach of project owners", "five years"

Case Study 70: Two Teams, One Cluster

THE SCENARIO

Corvid Analytics

Two teams share a GKE cluster in separate namespaces. Team A's pods must read only bucket A; team B's pods only bucket B.

Today both teams use the node service account, which can read both buckets.

What should you do?

A. Create separate node pools and keep the node service account.

B. Give each team a separate service account key mounted as a Kubernetes secret.

C. Enable Workload Identity Federation for GKE, give each namespace its own Kubernetes service account, and grant each one access only to its team's bucket.

D. Use network policies to block traffic to the other team's bucket.

ANSWER | MIXED: GKE IDENTITY AND DATA

Case Study 70 Answer: C

A

Create separate node pools and keep the node service account.

Incorrect. Pods on both pools still share the same node identity unless more is changed; it is the heavy route.

B

Give each team a separate service account key mounted as a Kubernetes secret.

Incorrect. Keys are long lived secrets; this is the anti pattern Google warns against.

C

Enable Workload Identity Federation for GKE, give each namespace its own Kubernetes ...

Correct. Each workload gets its own IAM identity, so bucket permissions follow least privilege per team.

D

Use network policies to block traffic to the other team's bucket.

Incorrect. Cloud Storage is a Google API; network policies do not express per bucket authorization.

Exam lesson

Per workload identity on GKE is Workload Identity Federation for GKE, not node accounts or keys.

Clue words in the stem

"Shared cluster", "only bucket A", "node service account"

Case Study 71: Forget One Customer

THE SCENARIO

Ledgerline SaaS

Ledgerline is a multi tenant SaaS provider. When a customer leaves, contracts require their data, including data in backups, to be rendered unrecoverable within 30 days.

Each tenant's data already lives in its own Cloud Storage bucket and BigQuery dataset.

Which design makes this achievable?

A. Use one CMEK key for all tenants and rotate it when a tenant leaves.

B. Use a separate CMEK key per tenant for its bucket, dataset and backups, and destroy that key's versions when the tenant leaves.

C. Use Google default encryption and delete live data when a tenant leaves.

D. Enable object versioning and soft delete for all buckets.

Case Study 71 Answer: B

A

Use one CMEK key for all tenants and rotate it when a tenant leaves.

Incorrect. Rotation keeps old versions to decrypt old data; destroying them would affect every tenant.

B

Use a separate CMEK key per tenant for its bucket, dataset and backups, and destroy that ...

Correct. Destroying a tenant's key versions crypto shreds every copy encrypted with it, including backups.

C

Use Google default encryption and delete live data when a tenant leaves.

Incorrect. Backups and copies may survive deletion of live data.

D

Enable object versioning and soft delete for all buckets.

Incorrect. Increases data retention, the opposite of the requirement.

Exam lesson

Per tenant keys enable per tenant crypto shredding.

Clue words in the stem

"Including backups", "unrecoverable", "multi tenant"

Case Study 72: Owner Granted at Midnight

THE SCENARIO

Sandford Utilities

Security wants to know within minutes if anyone grants a highly privileged role at the organization, or grants any role to an identity outside Sandford's domain.

The team prefers managed detection over writing its own log queries.

What should you use?

A. VPC Flow Logs with alerting.

B. A weekly Policy Analyzer report.

C. Security Command Center Event Threat Detection IAM anomaly findings, with a notification to Pub/Sub for paging.

D. IAM role recommendations.

ANSWER | MIXED: DETECTION

Case Study 72 Answer: C

A

VPC Flow Logs with alerting.

Incorrect. Network traffic does not show IAM changes.

B

A weekly Policy Analyzer report.

Incorrect. Weekly is far from minutes.

C

Security Command Center Event Threat Detection IAM anomaly findings, with a notification ...

Correct. Event Threat Detection analyses audit logs for anomalous and external IAM grants, and notifications deliver findings quickly.

D

IAM role recommendations.

Incorrect. Recommends role reductions; not a detection service.

Exam lesson

Managed detection of suspicious IAM changes is Event Threat Detection; route findings with notifications.

Clue words in the stem

"Within minutes", "outside our domain", "managed detection"

Case Study 73: Service to Service on Cloud Run

THE SCENARIO

Nettlebed Insurance

A quoting service on Cloud Run calls a pricing service, also on Cloud Run. The pricing service must accept calls only from the quoting service, never from the internet or other services.

No shared secrets may be used.

What should you do?

A. Set pricing service ingress to internal, require authentication, grant Cloud Run Invoker on it to the quoting service's service account, and have the caller send a Google signed ID token.

B. Make the pricing service public and check an API key header.

C. Allow the quoting service's IP address in a firewall rule.

D. Store a shared password in Secret Manager for both services.

ANSWER | MIXED: SERVERLESS IDENTITY

Case Study 73 Answer: A

A

Set pricing service ingress to internal, require authentication, grant Cloud Run Invoker ...

Correct. Ingress limits network reachability; IAM with ID tokens proves the caller's identity with no secrets.

B

Make the pricing service public and check an API key header.

Incorrect. API keys are shared secrets and the service stays internet facing.

C

Allow the quoting service's IP address in a firewall rule.

Incorrect. Cloud Run egress IPs are not fixed per service, and IP is not identity.

D

Store a shared password in Secret Manager for both services.

Incorrect. Still a shared secret, which is forbidden.

Exam lesson

Service to service authentication on Google Cloud uses IAM and ID tokens from the caller's service account.

Clue words in the stem

"Only from the quoting service", "no shared secrets"

Case Study 74: Notebooks That Leak

THE SCENARIO

Ravensworth Research

Data scientists use managed notebook instances to explore sensitive clinical data in BigQuery. Security found that one user copied query results to a personal cloud drive over the internet.

Researchers still need Python packages from a public package index.

What should you do?

A. Enable Data Access logs and review them monthly.

B. Remove BigQuery access from all researchers.

C. Give each notebook an external IP and a firewall rule blocking the personal drive's IP range.

D. Run notebooks without external IPs inside a VPC Service Controls perimeter with BigQuery, and route egress through Secure Web Proxy allowing only the package index.

ANSWER | MIXED: DATA AND AI

Case Study 74 Answer: D

A

Enable Data Access logs and review them monthly.

Incorrect. Detects too late, and monthly.

B

Remove BigQuery access from all researchers.

Incorrect. Stops the research entirely.

C

Give each notebook an external IP and a firewall rule blocking the personal drive's IP ...

Incorrect. Blocklists are easy to evade by using another destination.

D

Run notebooks without external IPs inside a VPC Service Controls perimeter with ...

Correct. The perimeter stops API based copies; no external IP plus an allowlisting proxy stops internet uploads while permitting package downloads.

Exam lesson

Exfiltration has two paths: Google APIs (VPC SC) and the internet (egress control). Close both.

Clue words in the stem

"Copied results to a personal drive", "still need packages"

Case Study 75: Keys and People

THE SCENARIO

Alpenrand Bank

Alpenrand's regulator requires that encryption keys for customer data are held outside the cloud provider, and that provider personnel cannot access customer data without the bank's prior approval.

Which two controls should you use? (Choose two.)

A. Cloud HSM keys.

B. Access Approval.

C. Cloud EKM keys as CMEK, with Key Access Justifications.

D. Default encryption with Access Transparency only.

ANSWER | MIXED: SOVEREIGNTY

Case Study 75 Answer: B and C

A

Cloud HSM keys.

Incorrect. HSM keys are inside Google's infrastructure.

B

Access Approval.

Correct. Provider personnel access to supported services requires the bank's approval.

C

Cloud EKM keys as CMEK, with Key Access Justifications.

Correct. Key material stays in the bank's external key manager, with a reason attached to each use.

D

Default encryption with Access Transparency only.

Incorrect. Transparency logs access but does not require approval, and keys are Google managed.

Exam lesson

Sovereignty requirements usually split into key location (EKM) and personnel access (Access Approval).

Clue words in the stem

"Held outside the provider", "prior approval"

Case Study 76: Every Cluster, Every Image

THE SCENARIO

Quarrington Systems

Quarrington has 70 GKE clusters across many projects. The security standard says only attested images may run in production, and no team may create a production cluster that skips this check.

Which combination meets the standard with the least ongoing effort?

A. A weekly scan of running images with a custom script.

B. Kubernetes RBAC limiting who can deploy.

C. Artifact Registry IAM that allows only Cloud Build to push.

D. Binary Authorization requiring attestations, plus a custom organization policy constraint requiring its enforcement on every production GKE cluster.

ANSWER | MIXED: SUPPLY CHAIN AND POLICY

Case Study 76 Answer: D

A

A weekly scan of running images with a custom script.

Incorrect. Detective, delayed and custom.

B

Kubernetes RBAC limiting who can deploy.

Incorrect. Limits who deploys, not what they deploy.

C

Artifact Registry IAM that allows only Cloud Build to push.

Incorrect. Does not stop images from other registries.

D

Binary Authorization requiring attestations, plus a custom organization policy ...

Correct. Binary Authorization enforces attestation at deploy; the custom constraint guarantees no new cluster can opt out.

Exam lesson

Combine a runtime control (Binary Authorization) with a policy that makes the control mandatory (custom constraint).

Clue words in the stem

"Only attested images", "no team may create a cluster that skips", "least ongoing effort"

MOCK EXAM

Mock Exam Answer Key and Where to Revisit

Case	Scenario	Answer	Revisit sections
67	Day One of a New Organization	C and D	1.4, 1.5
68	An Internal App for Employees	D	2.1, 1.4
69	The Owner Who Could Erase the Trail	A	4.2
70	Two Teams, One Cluster	C	1.2, 3.1
71	Forget One Customer	B	3.2
72	Owner Granted at Midnight	C	4.2, 1.4
73	Service to Service on Cloud Run	A	1.2, 2.1
74	Notebooks That Leak	D	2.2, 2.1, 3.3
75	Keys and People	B and C	3.2, 5.1
76	Every Cluster, Every Image	D	4.1, 1.5

Scoring: 9 or 10 correct, you are ready. 7 or 8, revisit the listed sections. 6 or fewer, rework every section's case studies first.

EXAM STRATEGY

Exam Day Strategy



Multiple select

The stem says how many. Each chosen option must be correct on its own; partial combinations score nothing.

Two good answers

Return to the qualifier. "Minimal overhead" picks the managed option; "most secure" picks the stronger control.

Unknown service names

Reason from principles: prevent beats detect, federation beats keys, organization level beats per project.

EXAM STRATEGY

Final Cheat Sheet: Forty Facts in One Slide

- GCDS: one way, AD to Google
- Super admins bypass SSO at Admin console
- Workforce federation: humans; Workload: machines
- Token Creator: impersonate; User: attach
- Keys last; disable before delete
- Deny before allow; allow only adds
- Custom roles: org or project only
- PAM: temporary, justified, approved
- Domain restricted sharing uses customer IDs
- Custom constraints: CEL, CREATE and UPDATE

- Hierarchical firewall first; implied rules last
- IAP range 35.235.240.0/20
- Tags weak; service accounts and secure tags strong
- NGFW Enterprise blocks; Cloud IDS detects
- Cloud Armor for L7 at the load balancer
- Secure Web Proxy for egress by URL
- VPC SC: exfiltration, dry run first
- Peering not transitive; Shared VPC same org
- restricted 199.36.153.4/30; private .8/30
- Interconnect not encrypted: MACsec or HA VPN

- SDP: discover, inspect, de identify
- Deterministic: joins and reversible
- FPE: keeps format; hash: irreversible
- Software keys level 1; HSM level 3
- EKM: key outside Google, KAJ reasons
- Rotation adds versions; no re encryption
- Destroy scheduled 30 days by default
- Bucket Lock irreversible
- Confidential Space for multi party
- Model Armor floor settings set minimums

- On Demand Scanning gates builds
- Binary Authorization uses digests
- trustedImageProjects for golden images
- Org policy prevents; SHA detects
- Admin Activity always on, 400 days
- Data Access off except BigQuery
- Implied deny cannot be logged
- Aggregated sink covers future projects
- Pub/Sub for SIEM streaming
- Snapshot, isolate, cut identity

You are ready when you can explain why three options are wrong.

Go back through every case study you missed, reread its concept slides, and redraw the diagram from memory. Then take the official sample questions under timed conditions.

Section 1
Access

Section 2
Boundaries

Section 3
Data

Section 4
Operations

Section 5
Compliance

Good luck on the Professional Cloud Security Engineer exam.